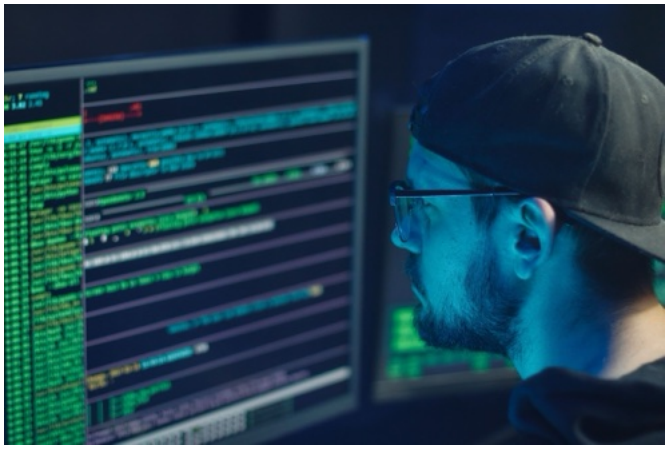


CYSA+

ASSIGNMENT

EDUV12936584

ITVSA0-44

Formative Assessment

EDUV12936584

ABSTRACT

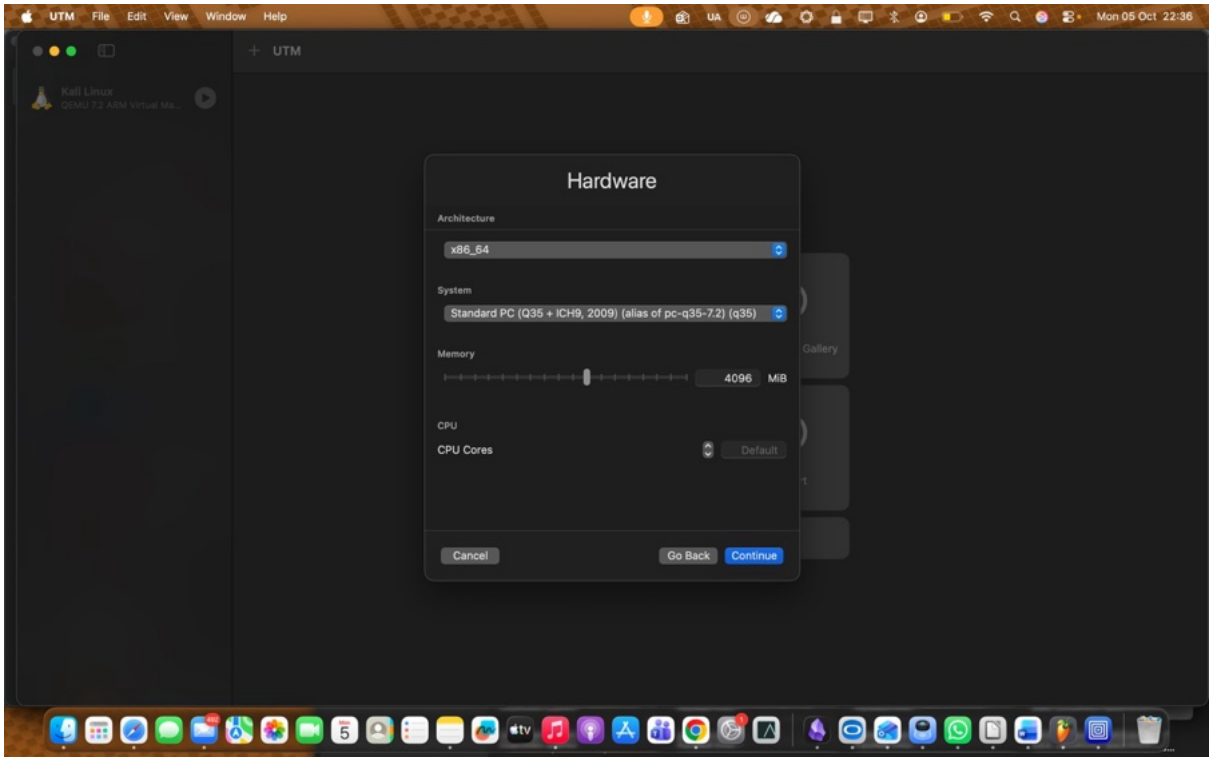
This project simulates a network security assessment for SkyTru Corp, covering the full lifecycle from building a test environment to configuring an Intrusion Detection System. It involves reconnaissance, exploitation, vulnerability scanning, and detection techniques using various tools and technologies.

Branny Aurthur Branfield

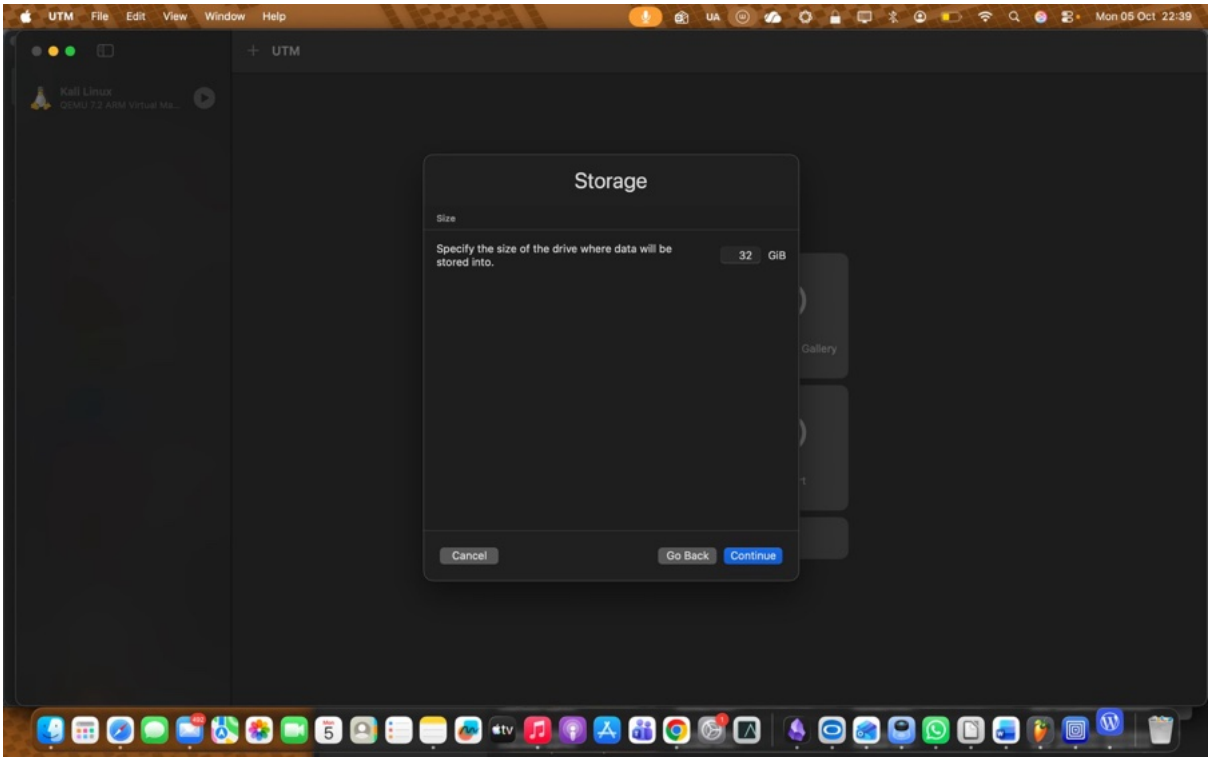
Analysing

Question 1

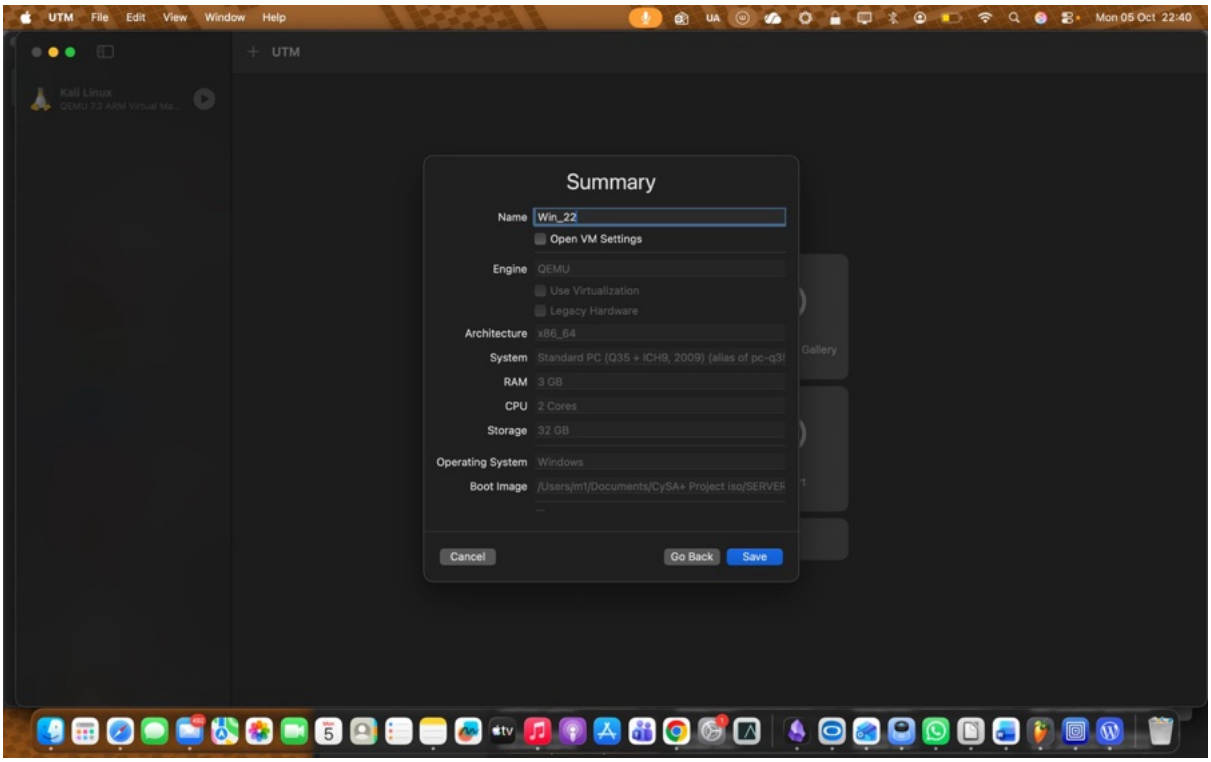
NOTE: Due to the fact of me using a Arm64 M Chip MacBook I will note be able to run VM machines on VMware or VirtualBox instead I'll be using "UTM" for Mac devices.



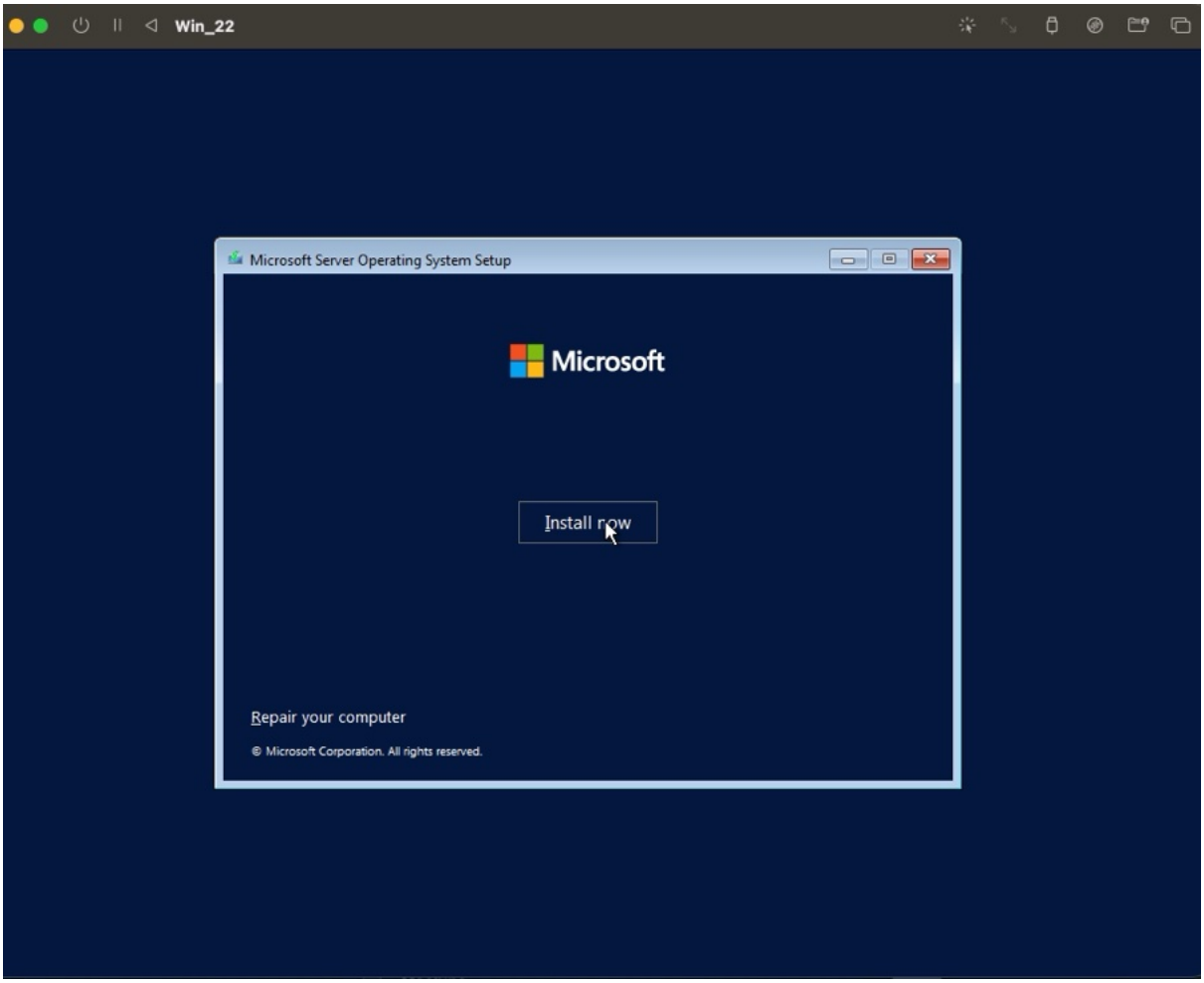
Setting up Memory, Architecture, System and CPU Cores.



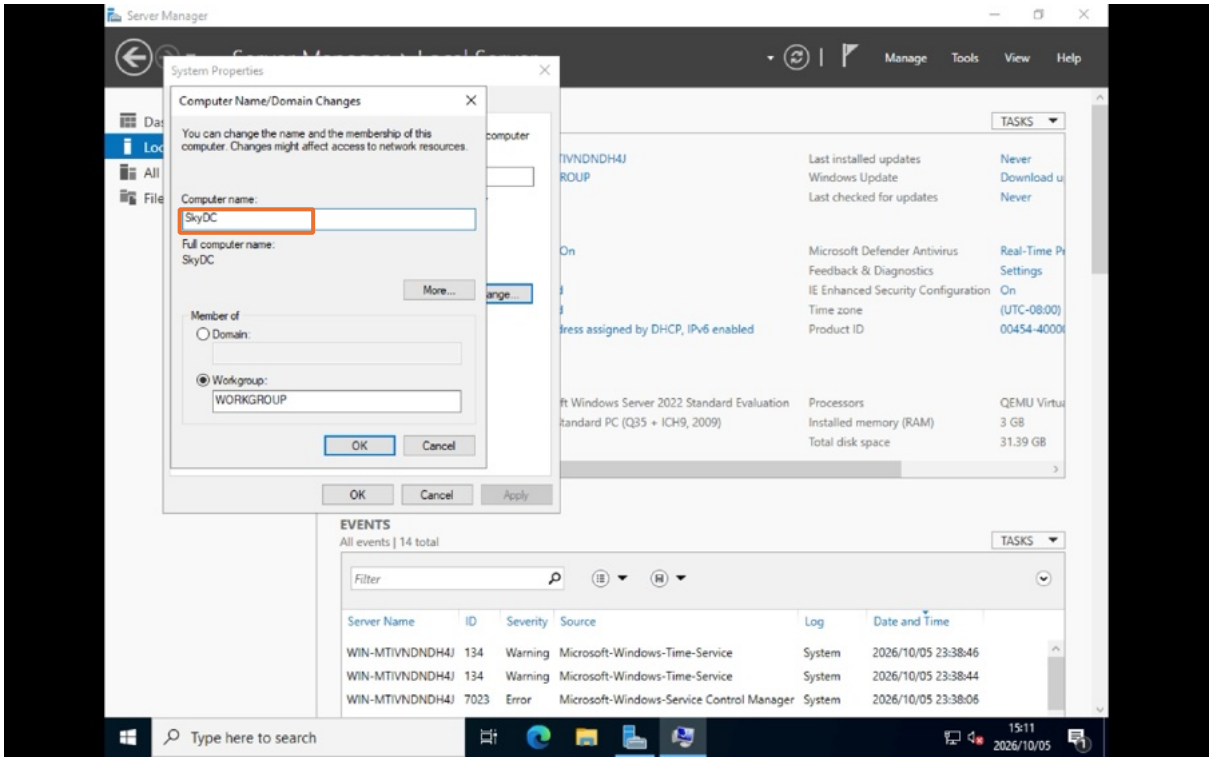
Setting up Storage.



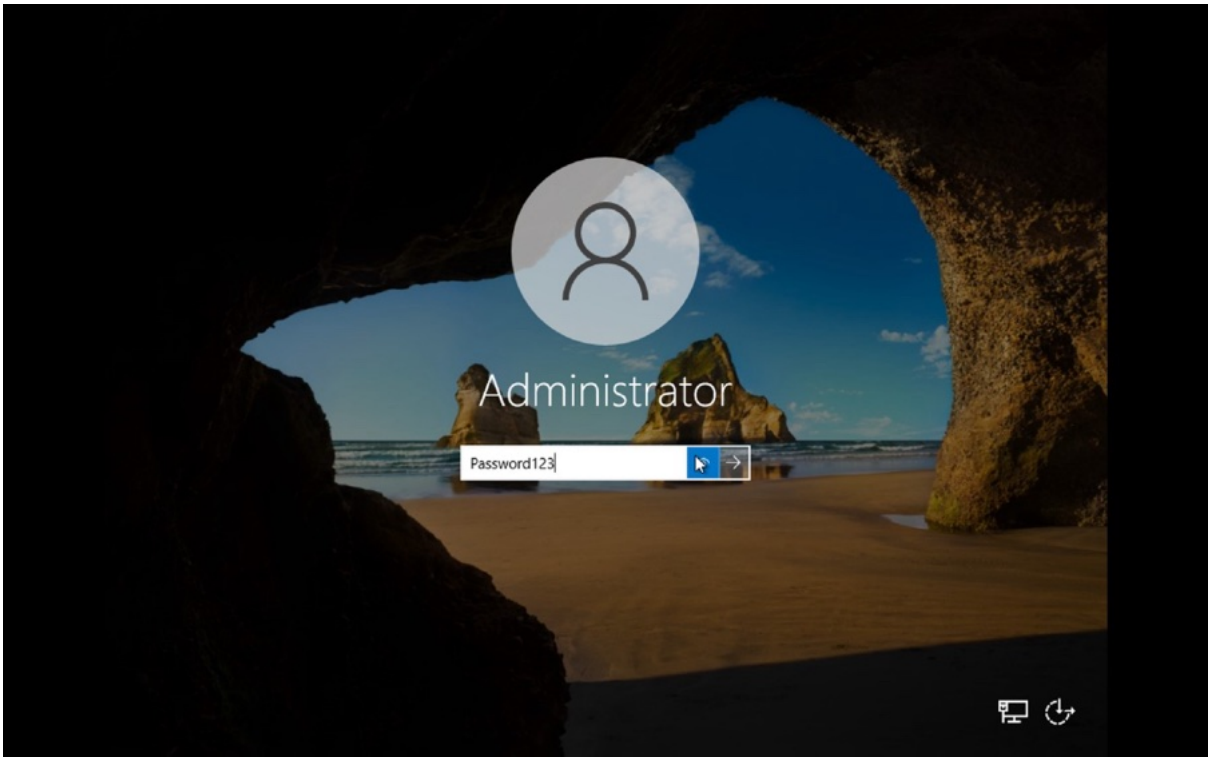
Name machine “Win_22”



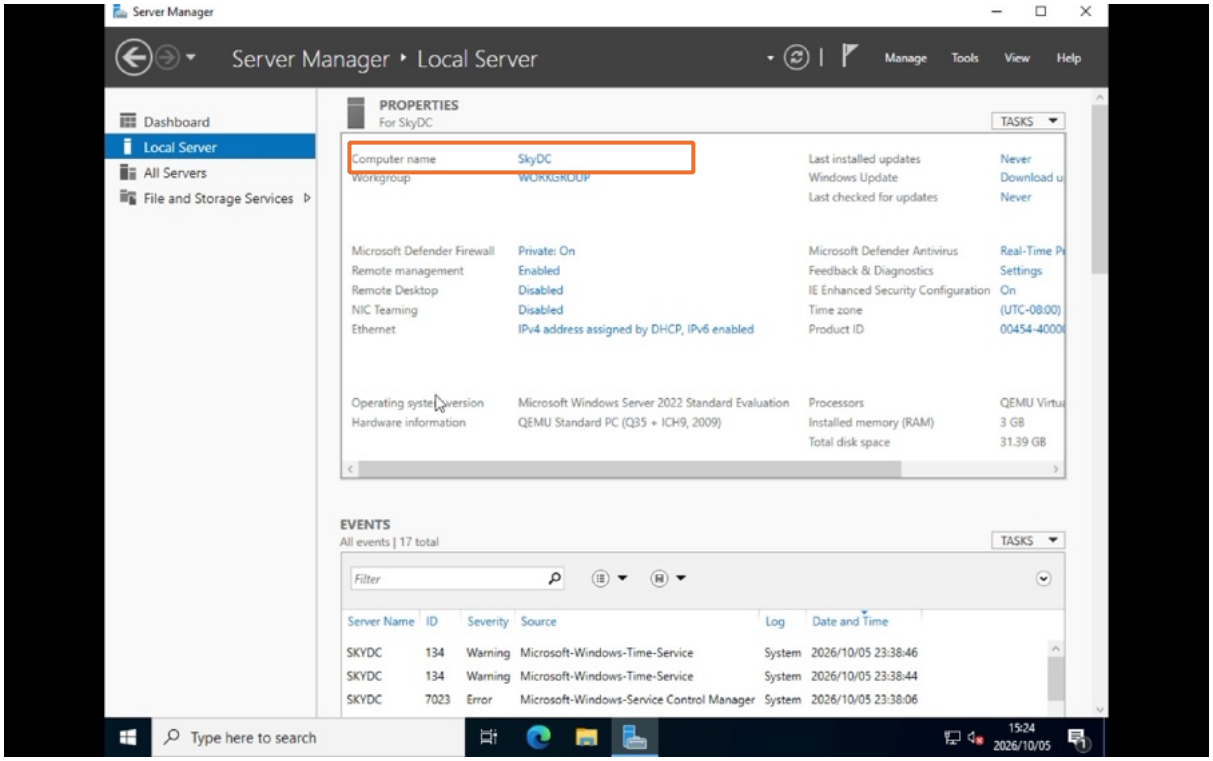
Installing “Windows Server 2022 Standard Edition” on Win_22.



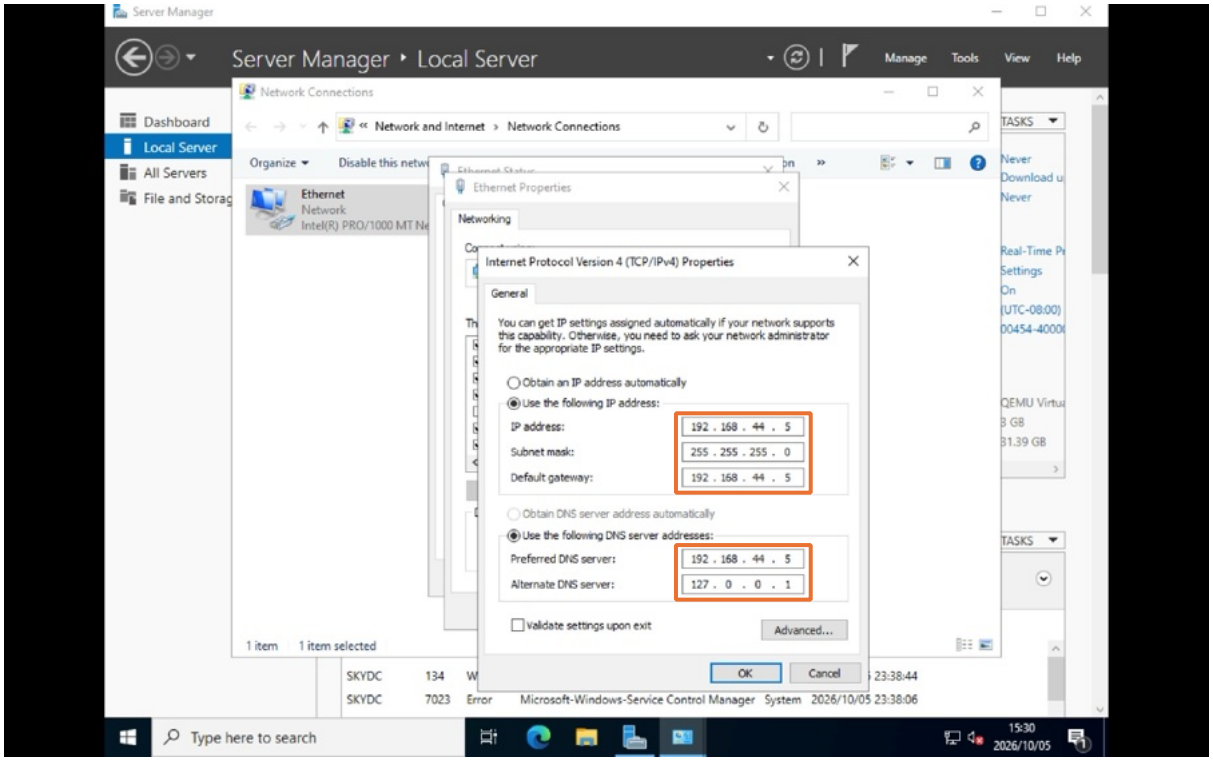
Naming Computer: SkyDC



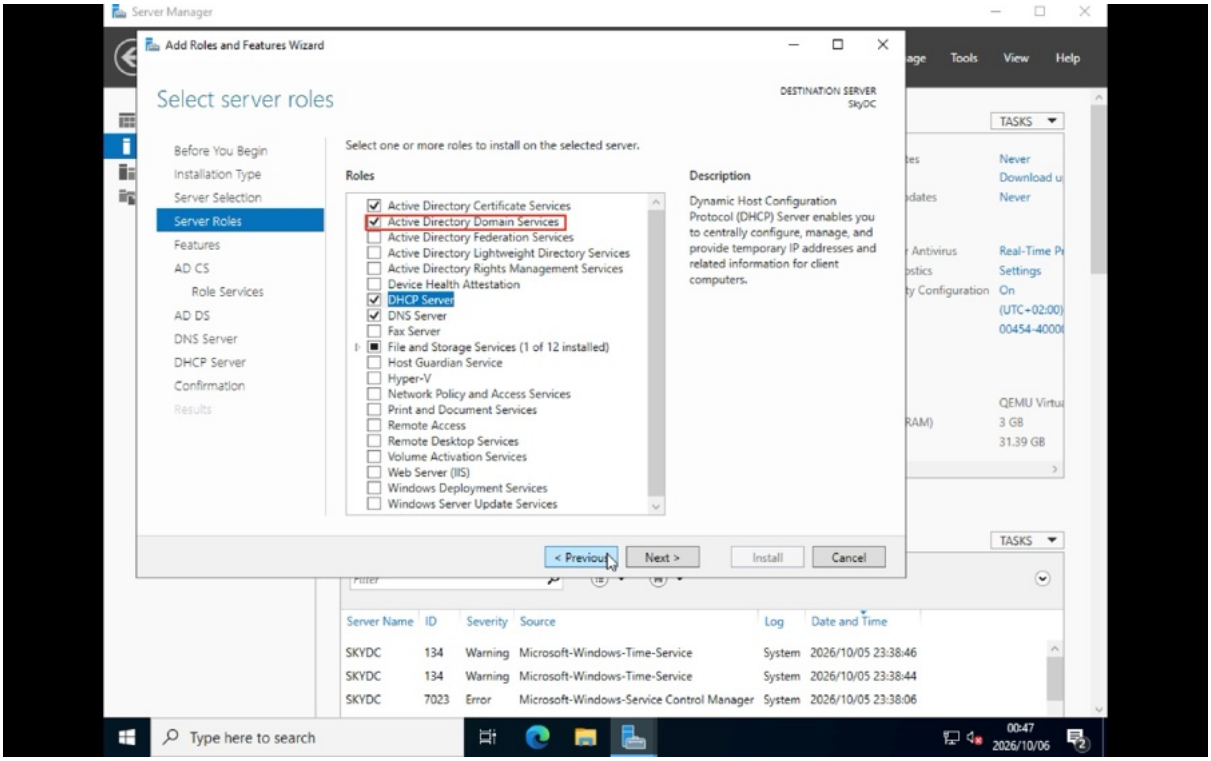
Password set during installation.



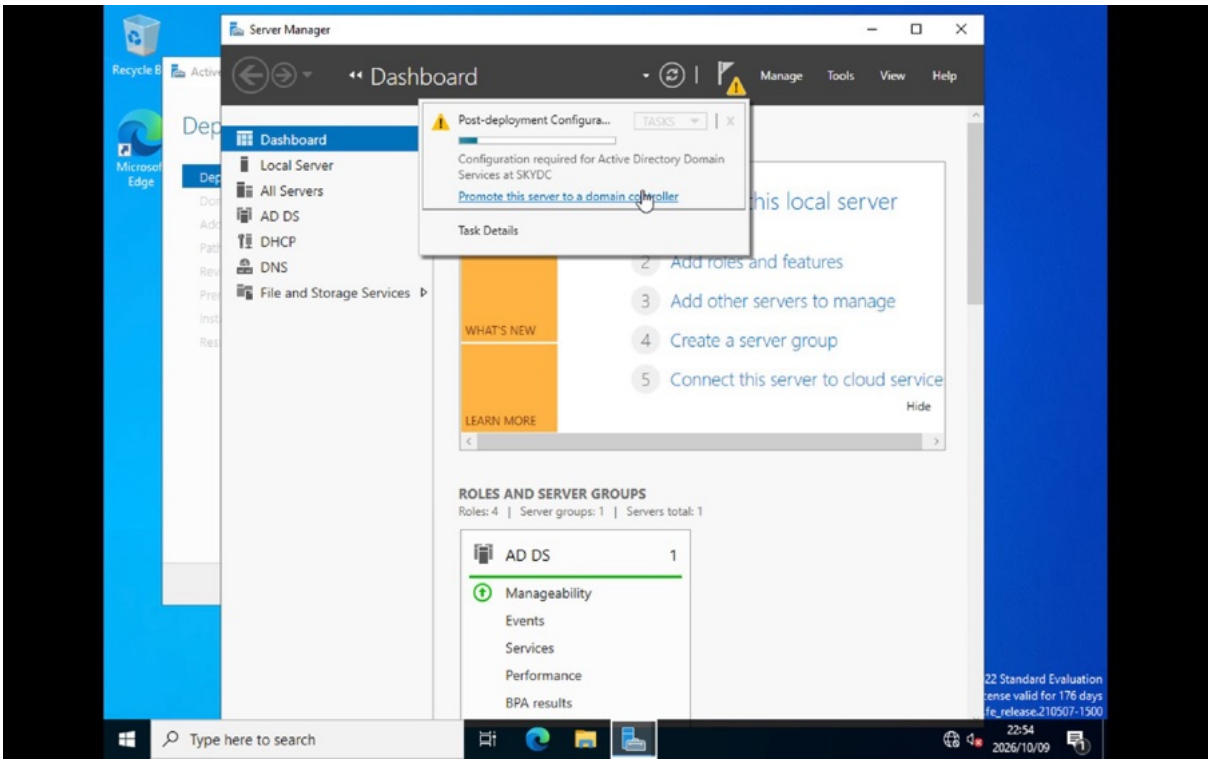
Successful Computer Naming



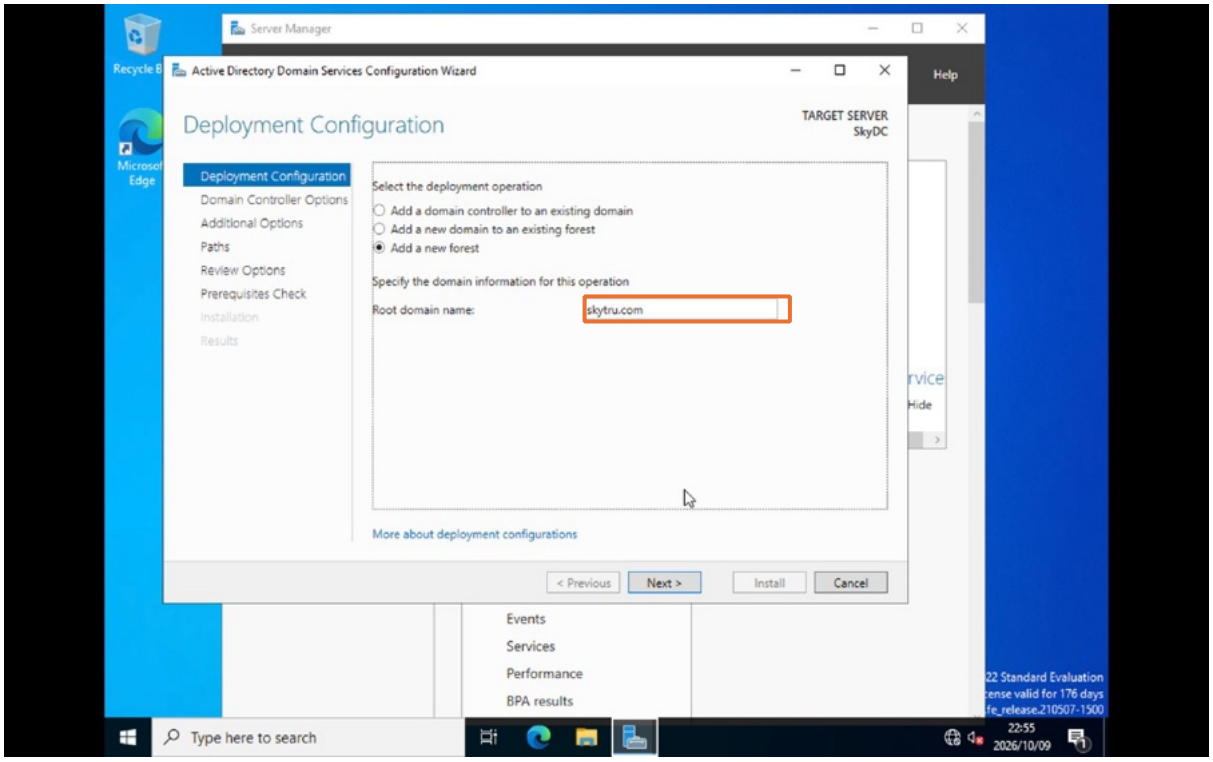
Setting IP Address, Subnet Mask and DNS Server Address.



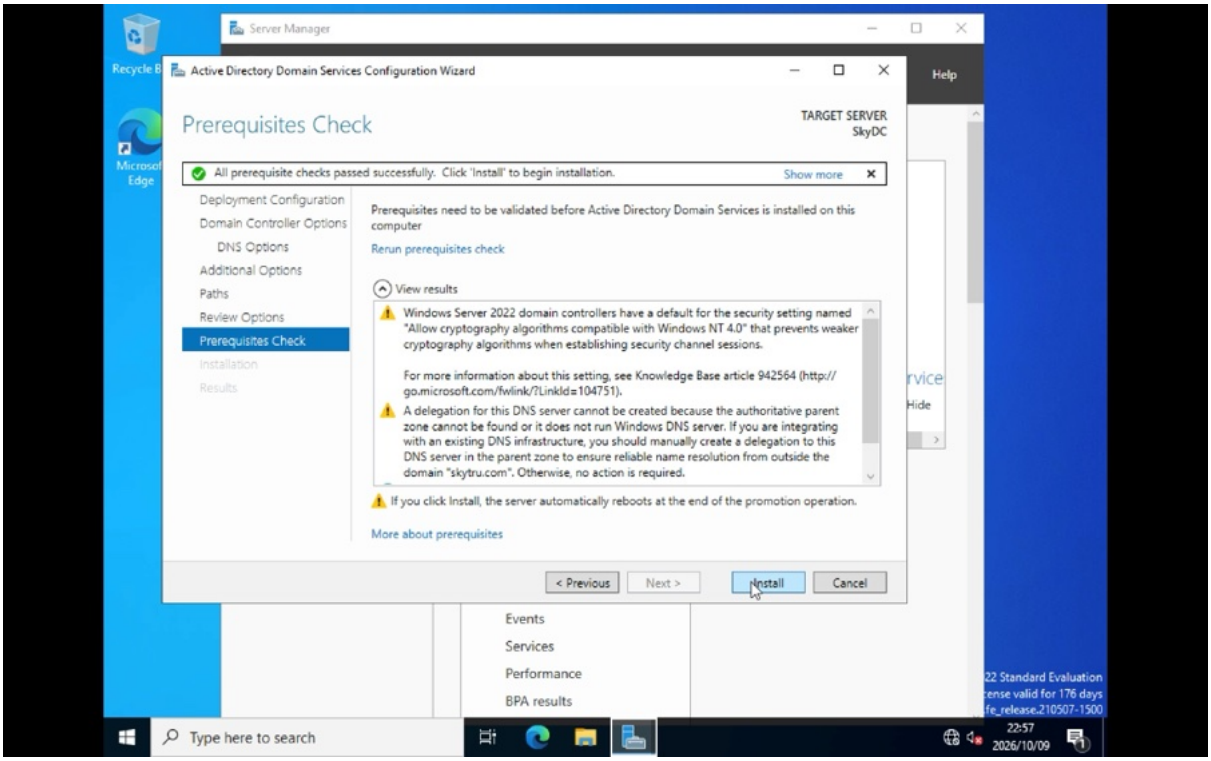
Installing Role and Features of Domain Controller.



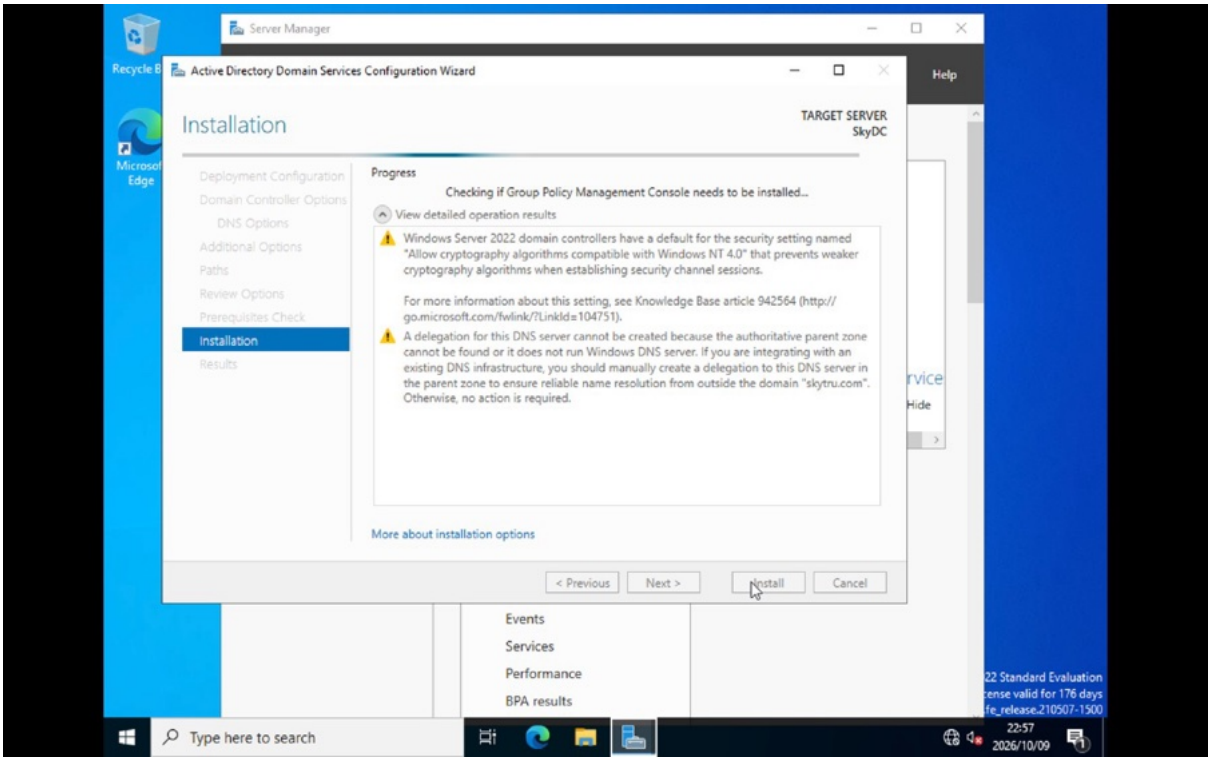
Promoting the Server to Domain Controller.



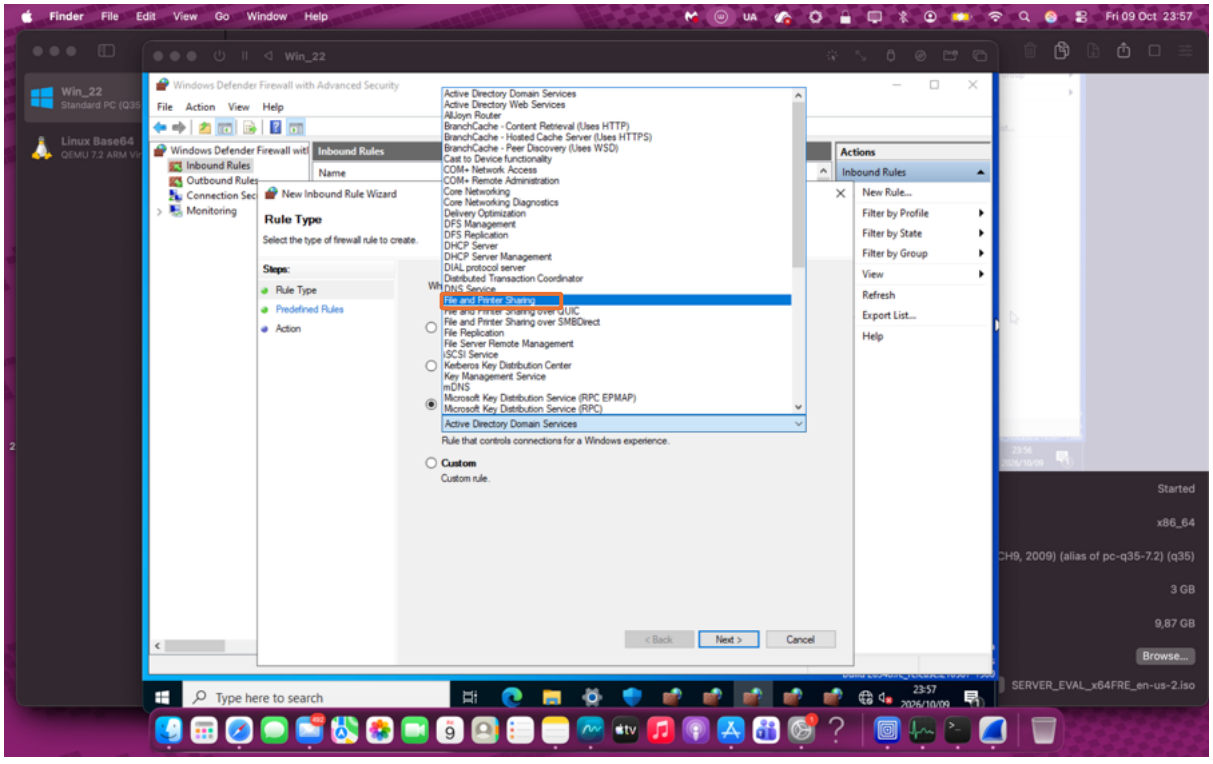
Promoting into skytru.com forest.



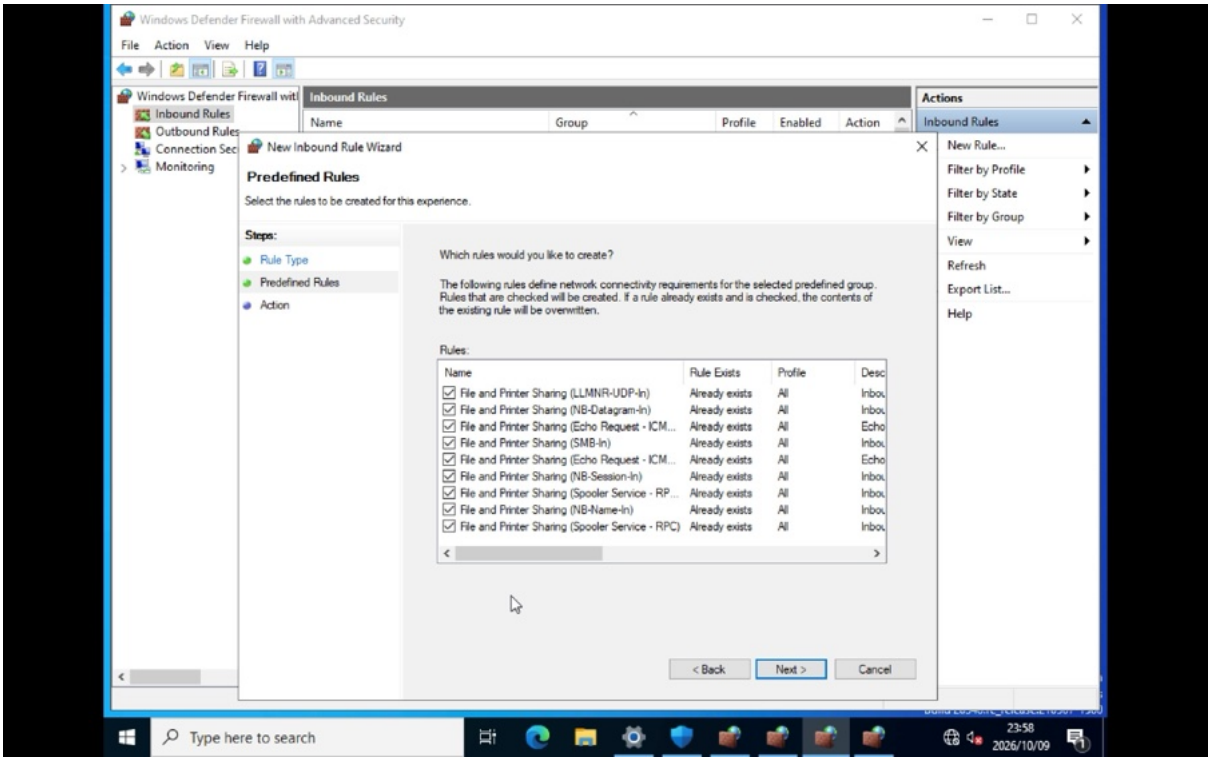
Installing Domain Server Configurations.



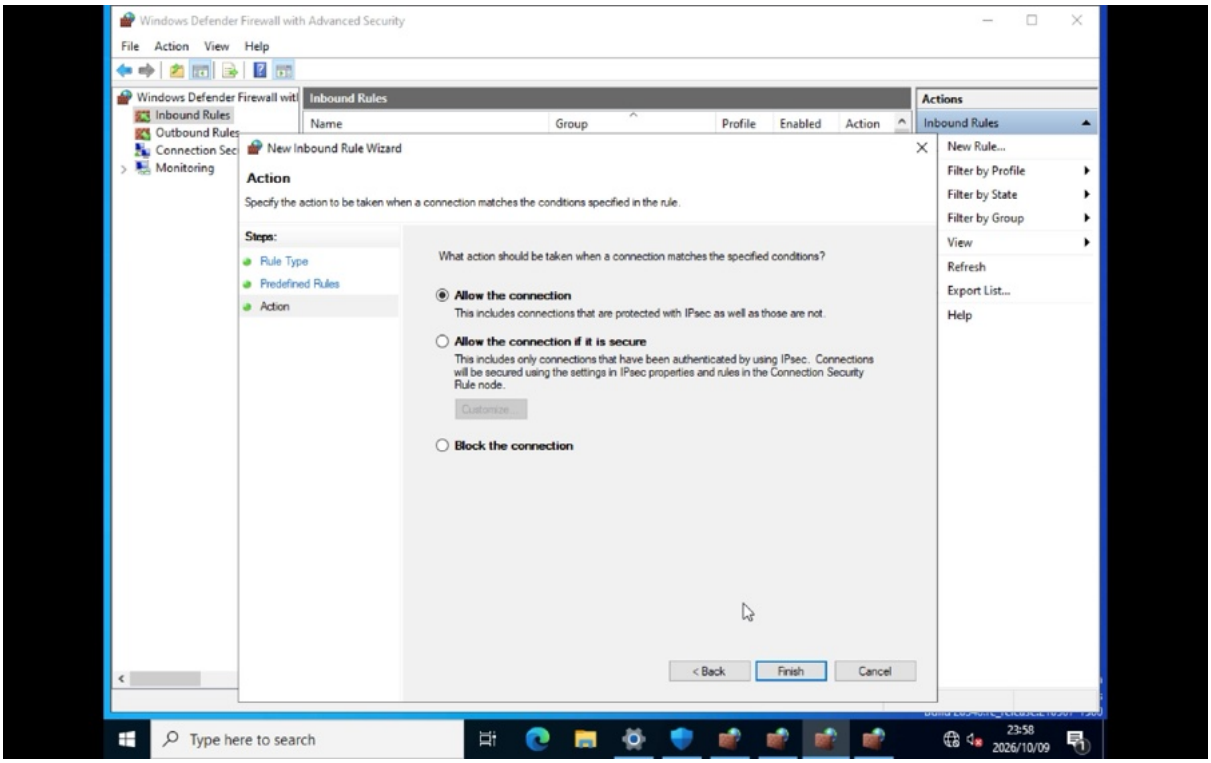
Installing.



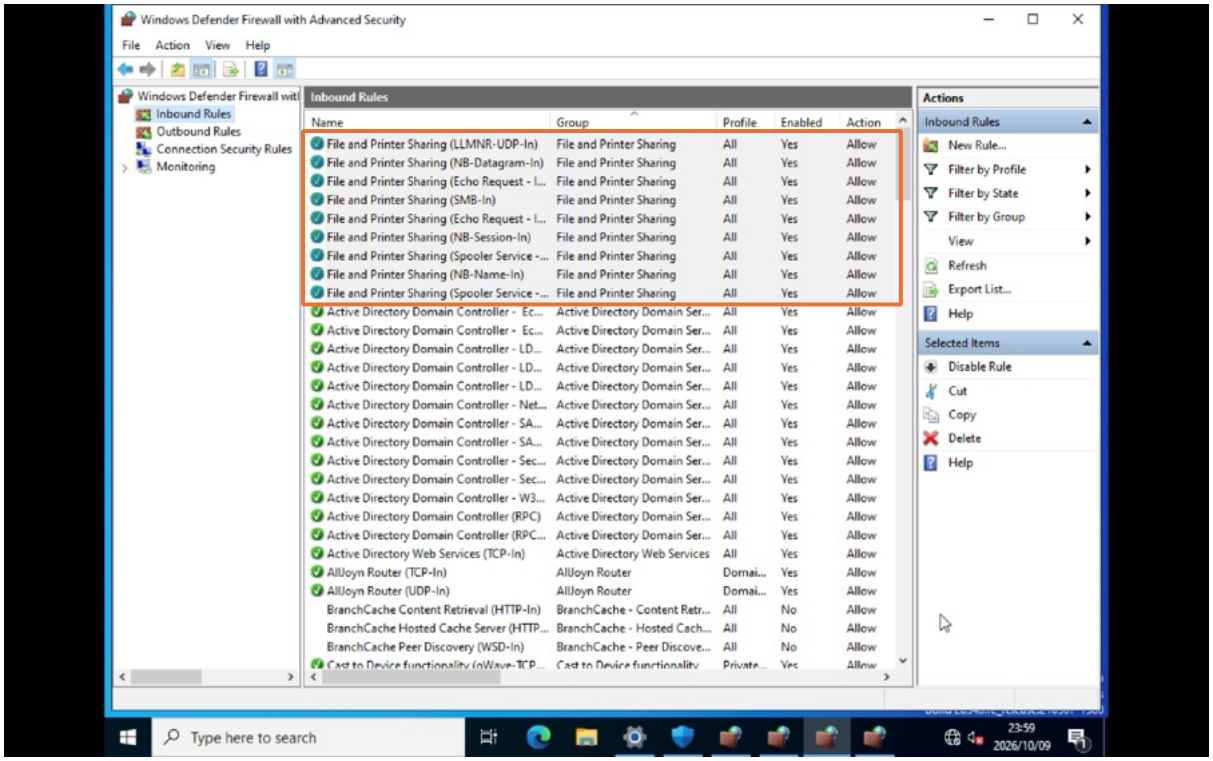
Setting File and Printer Sharing.



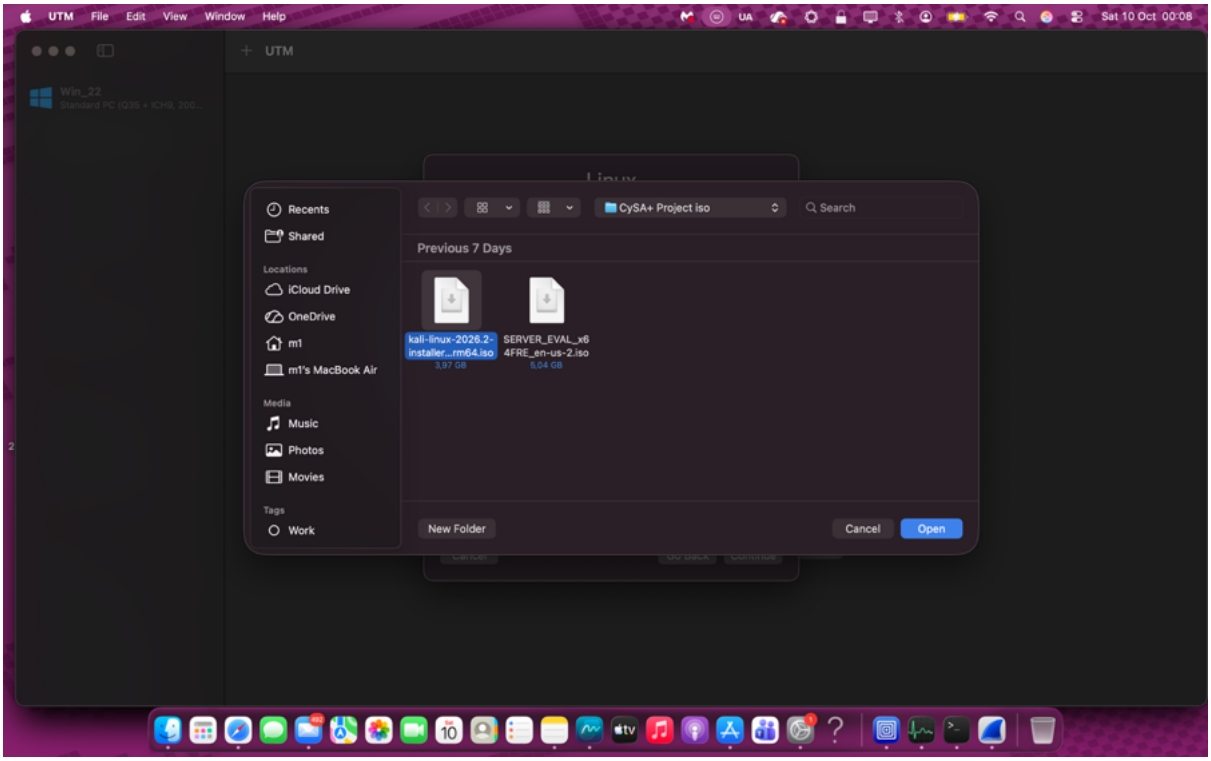
Adding Predefined Rules.



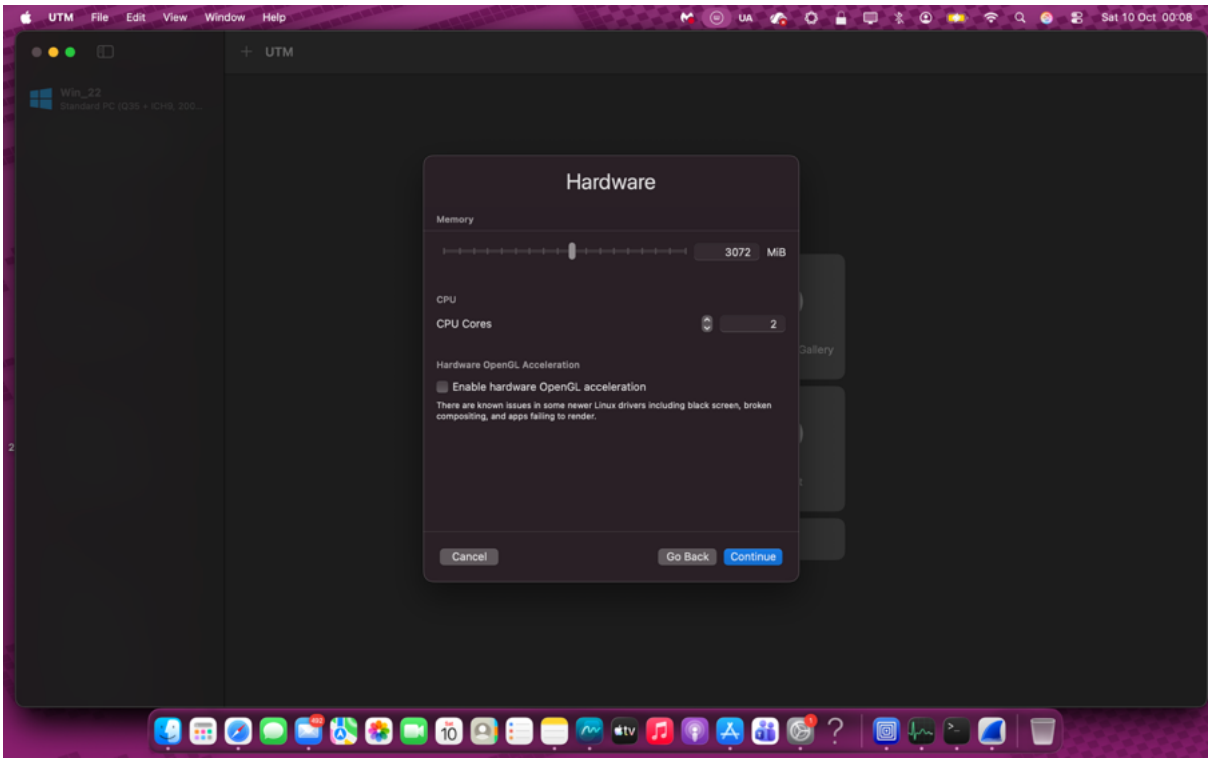
Allowing File and Printer Sharing on All Profiles.



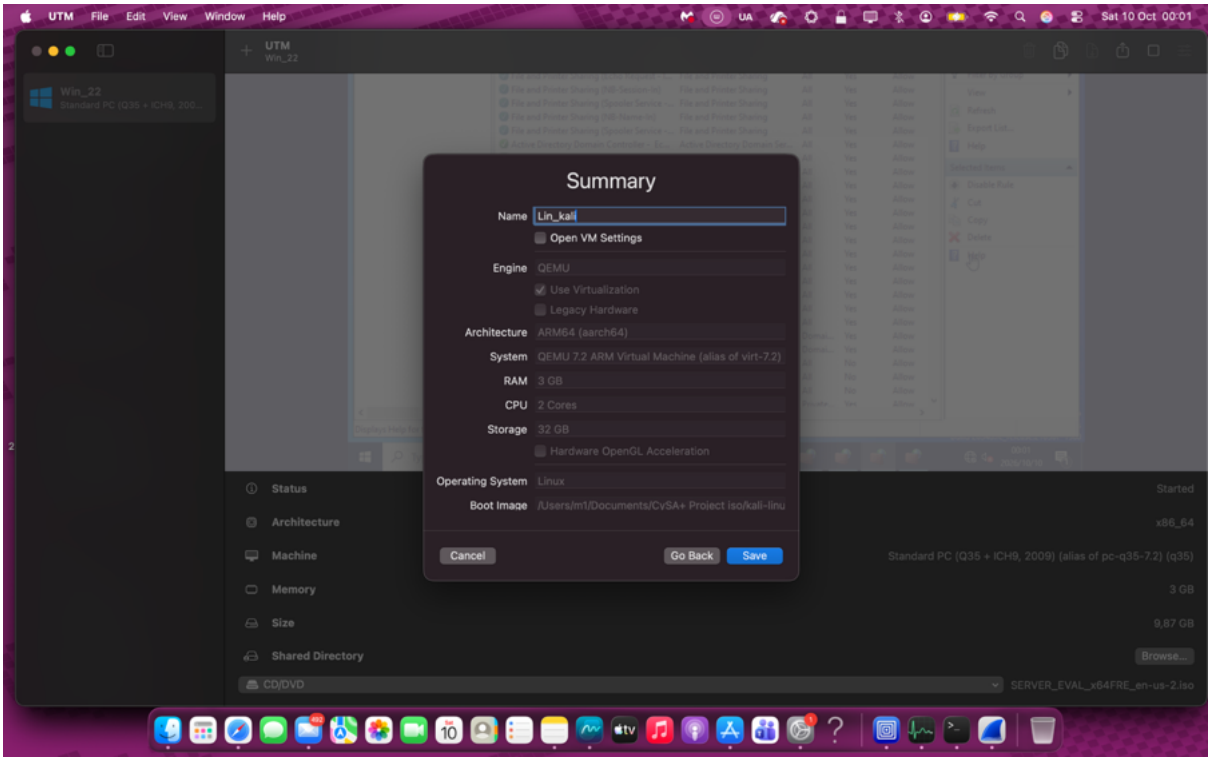
Successfully set File and Printer Sharing on all Profiles.



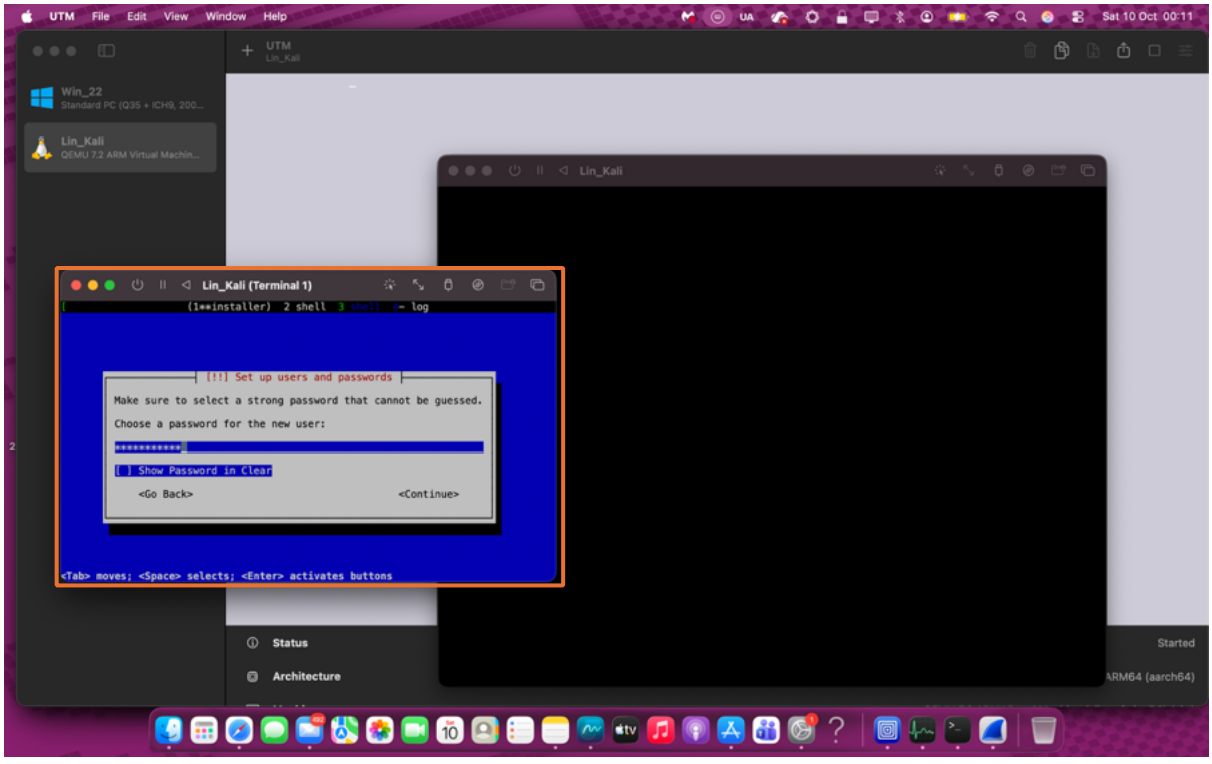
Importing iso files to Lin_Kali Machine.



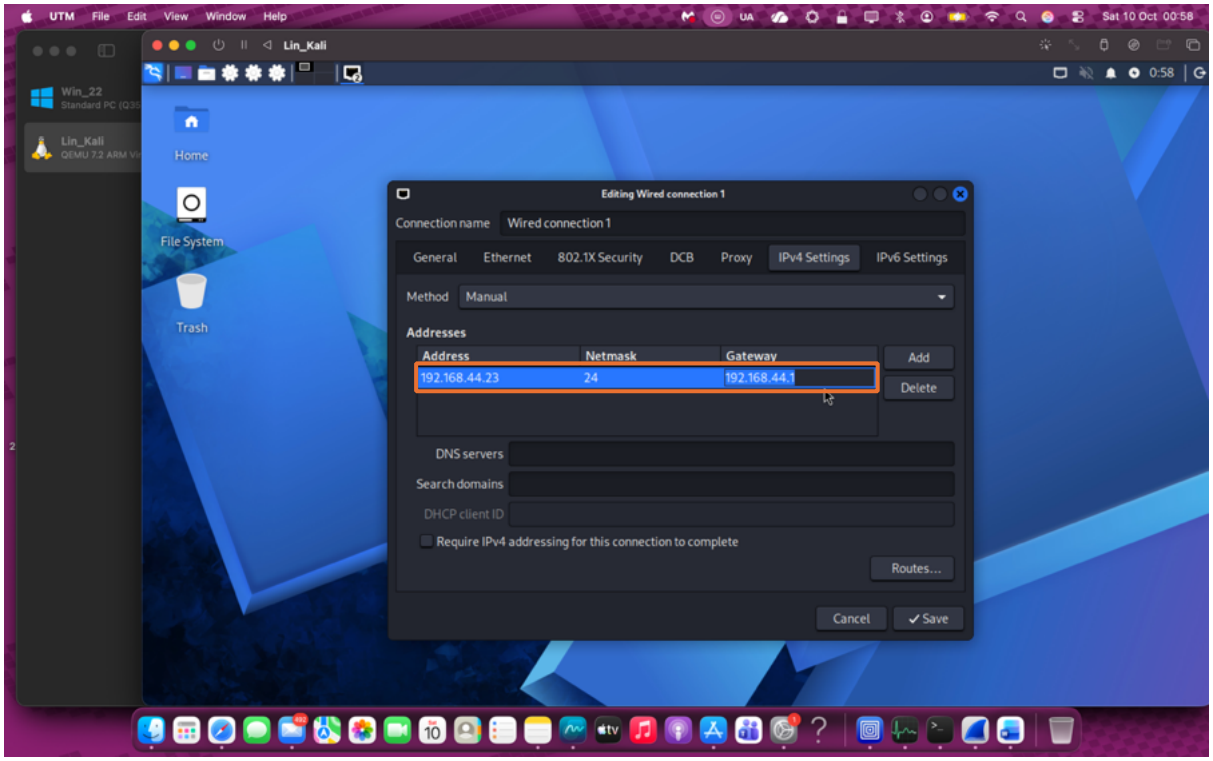
Setting up Memory and CPU Cores.



Naming Machine Lin_kali

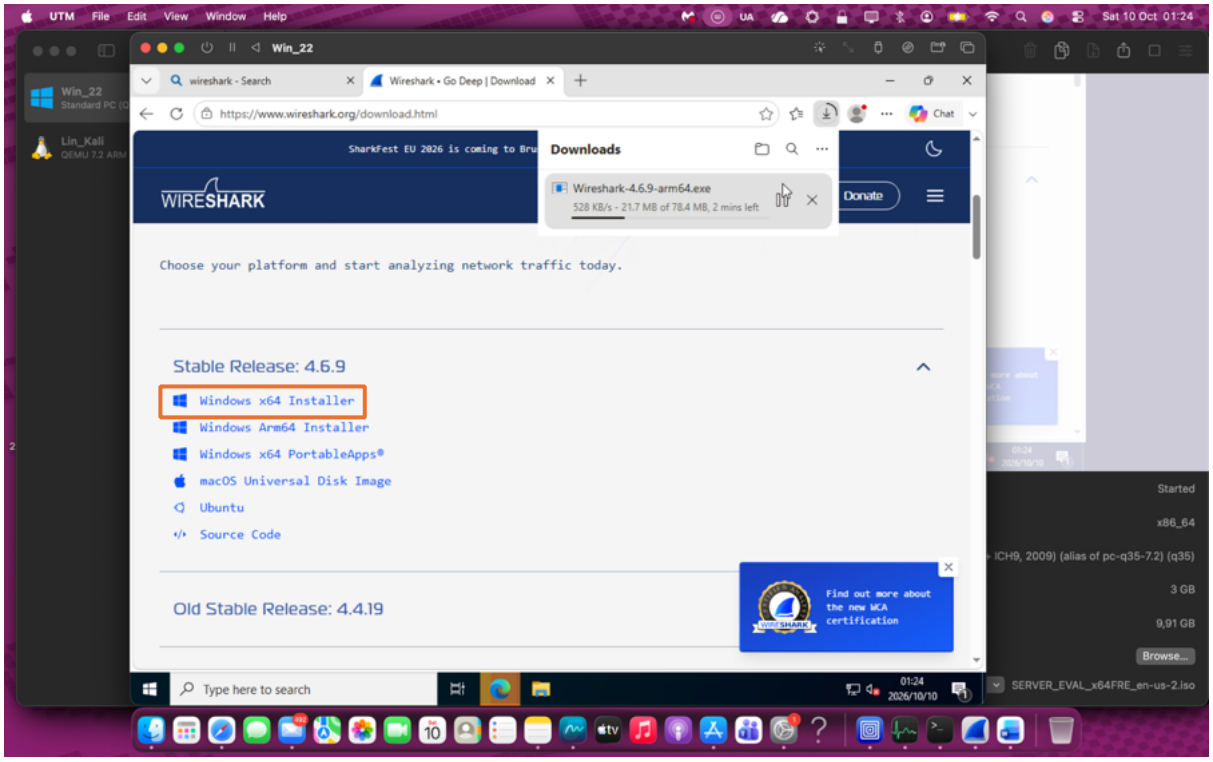


Setting Suitable Password.

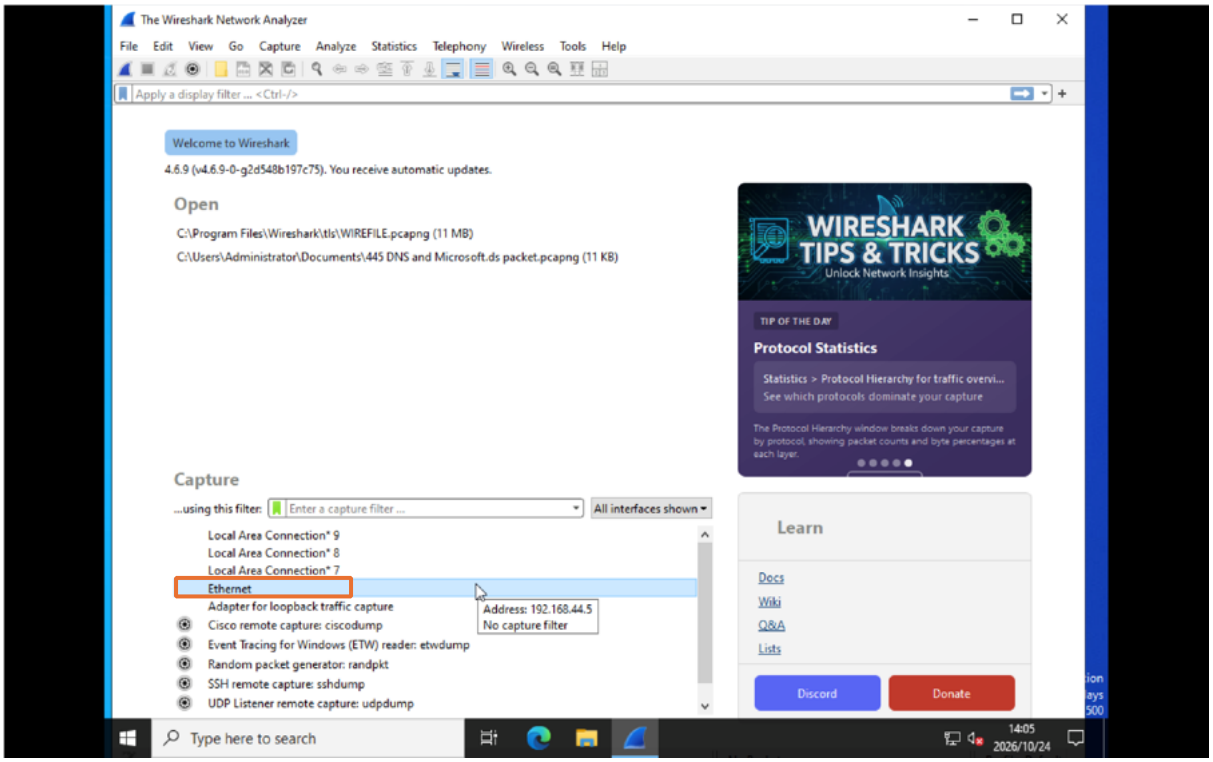


Setting TCP/IP: IP Address and Subnet Mask.

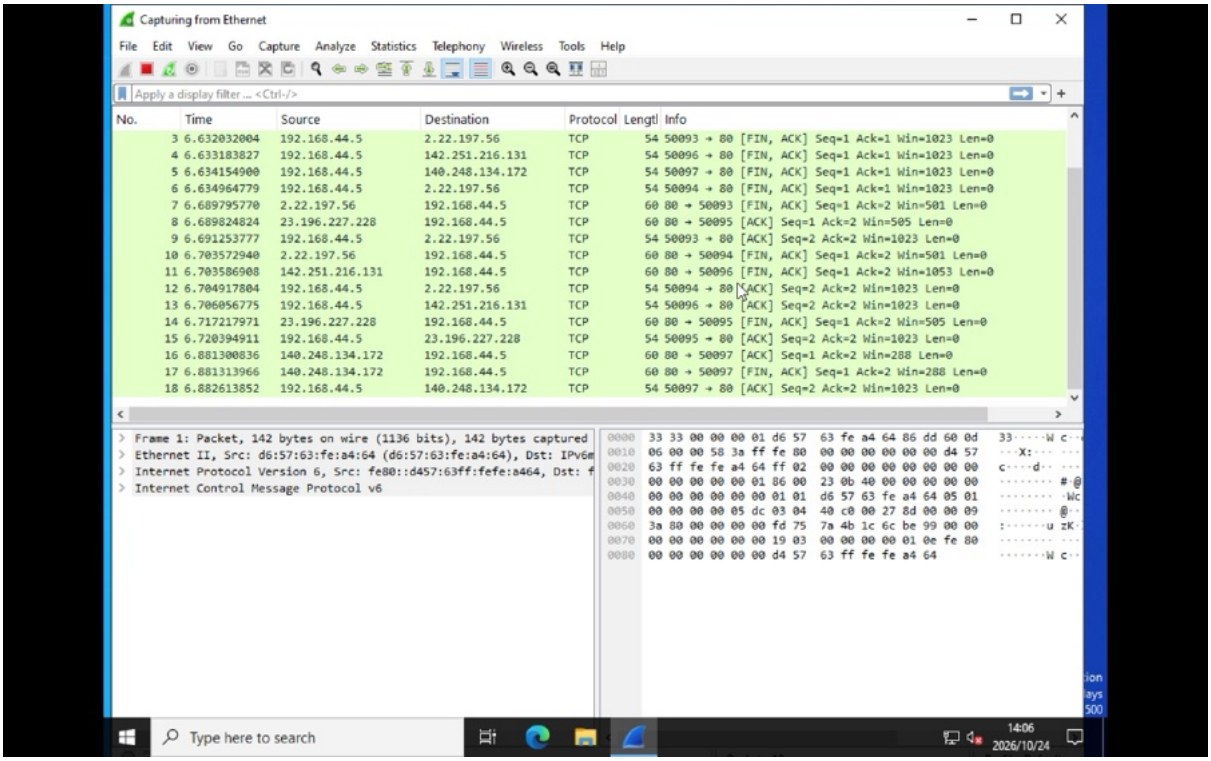
Question 2



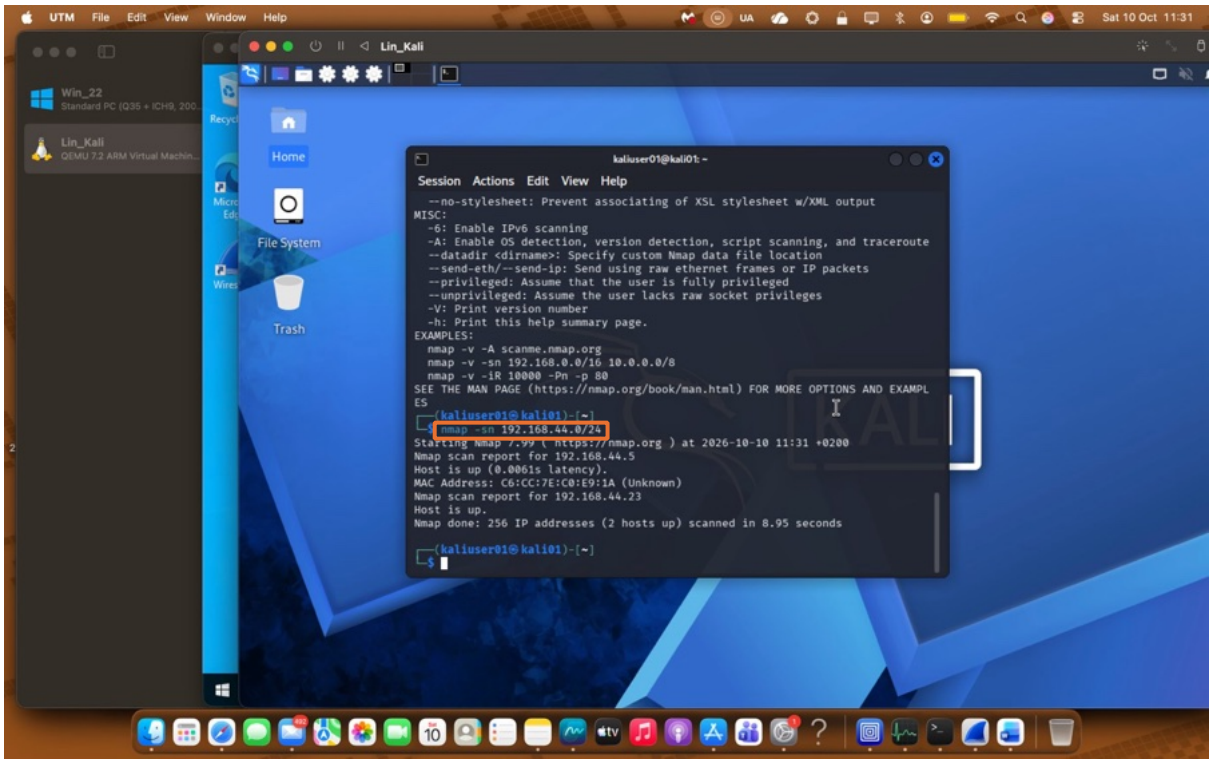
Installing Wireshark Win_22



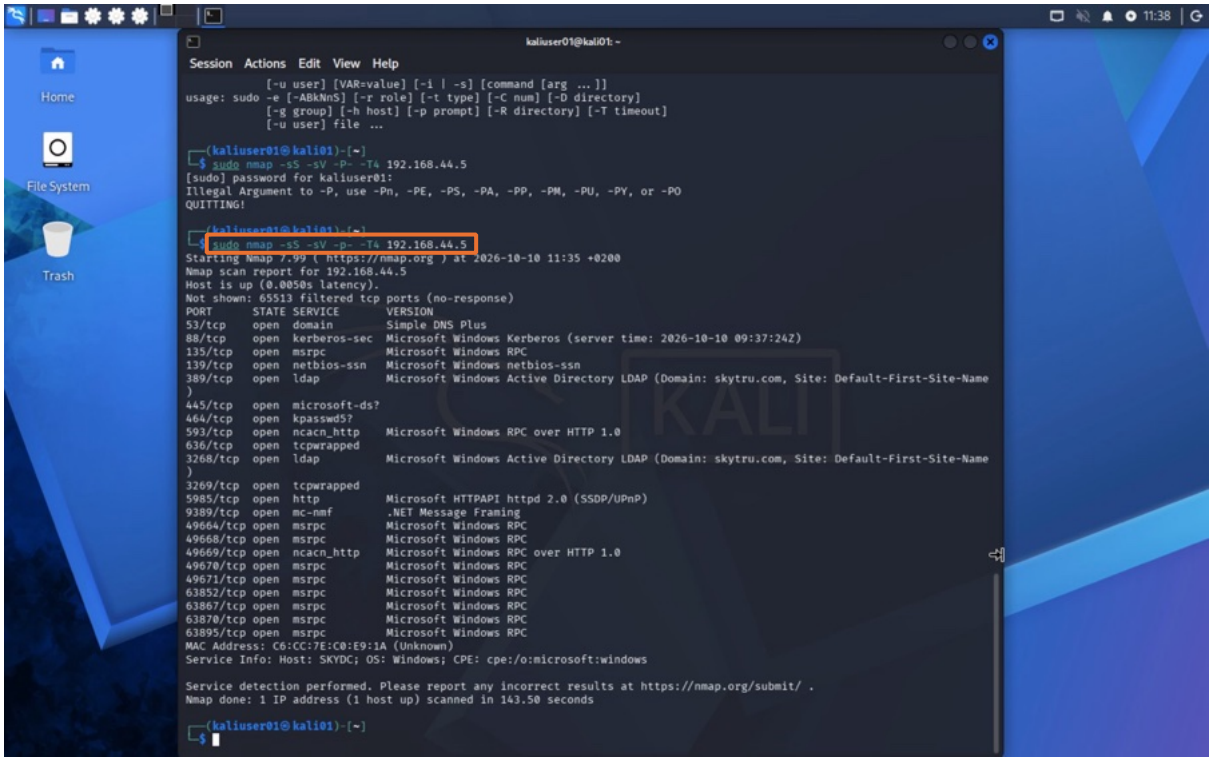
Starting Packet Capture.



Packet Capture Started.

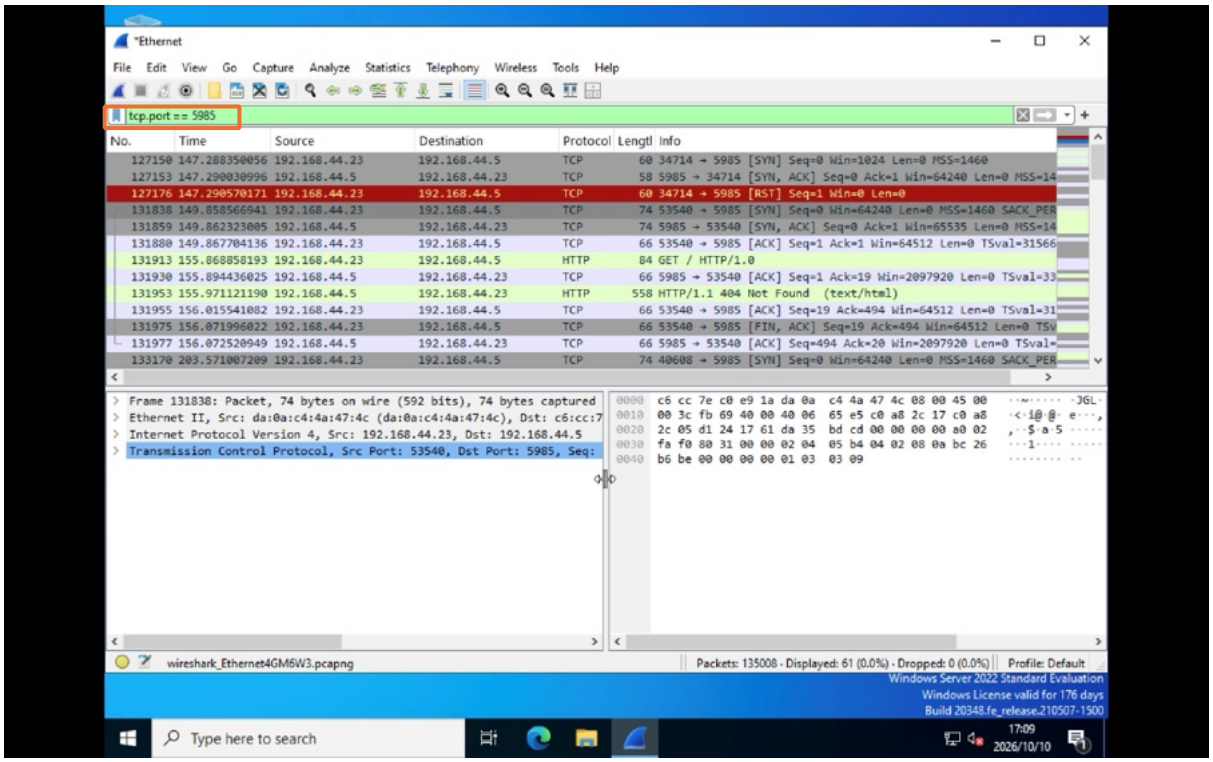


Running a Ping Scan against local network with Nmap.

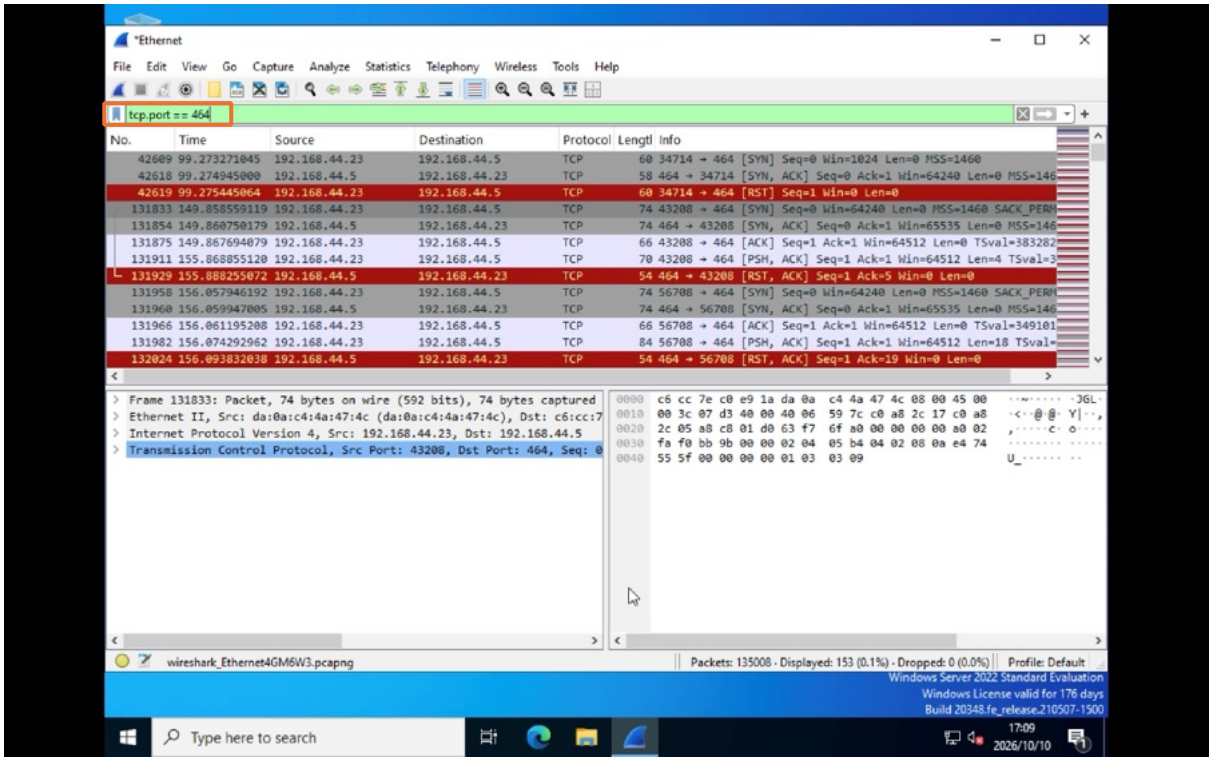


Running a Full Scan on Win_22.

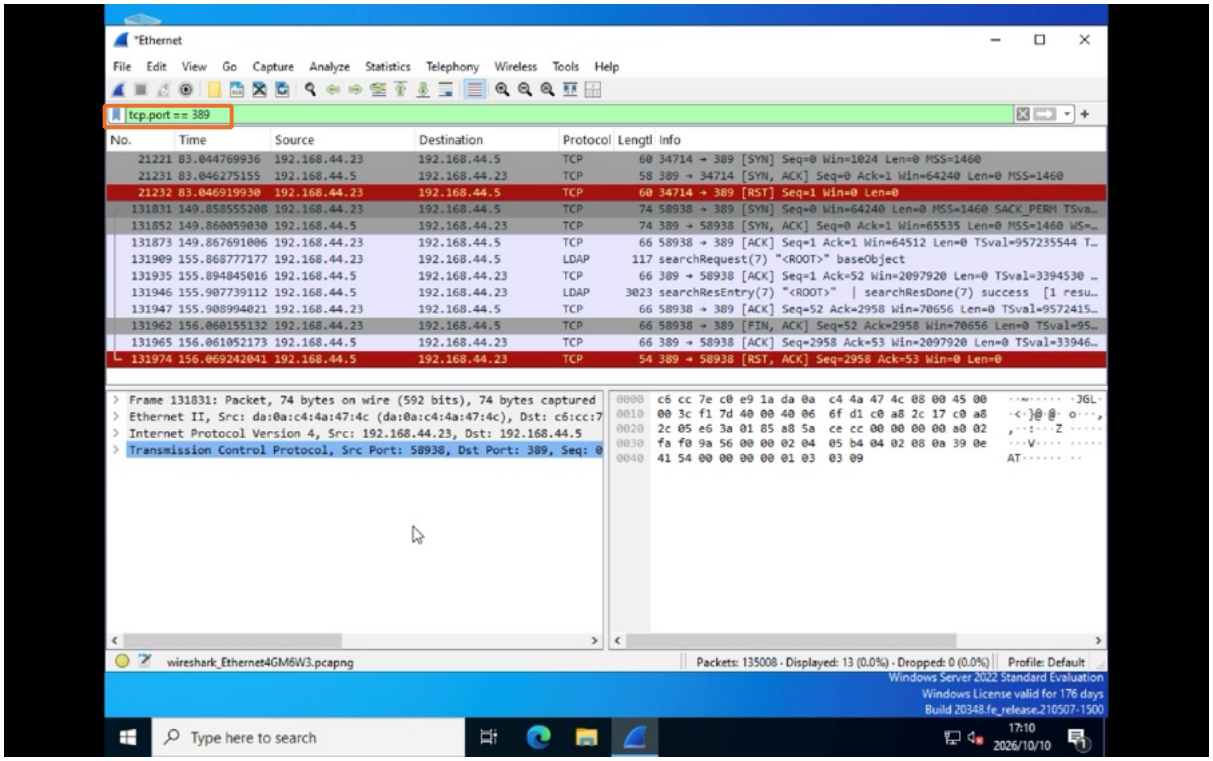
2.3 Analysing Captured Packet from Nmap using Wireshark.



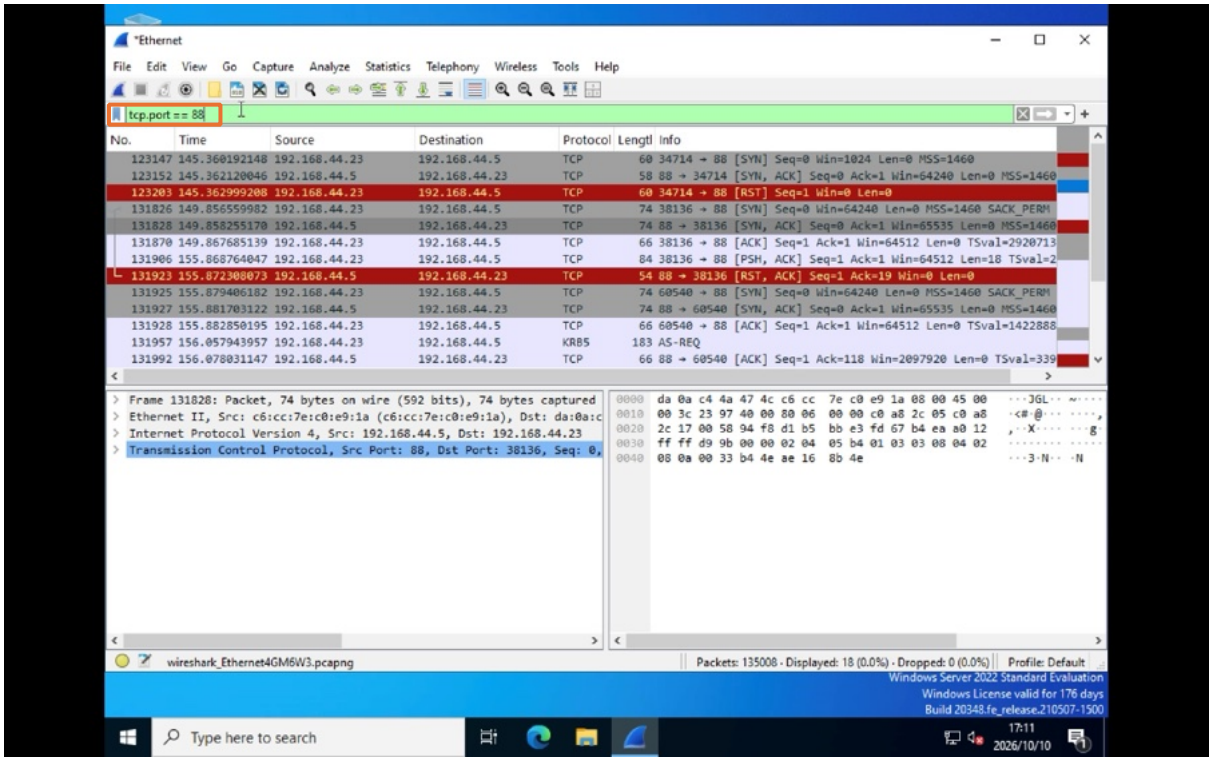
[http]: Microsoft – HTTPAPI httpd 2.0 (SSDP/uPnP) tcp {SYN},{RST},{ACK}.



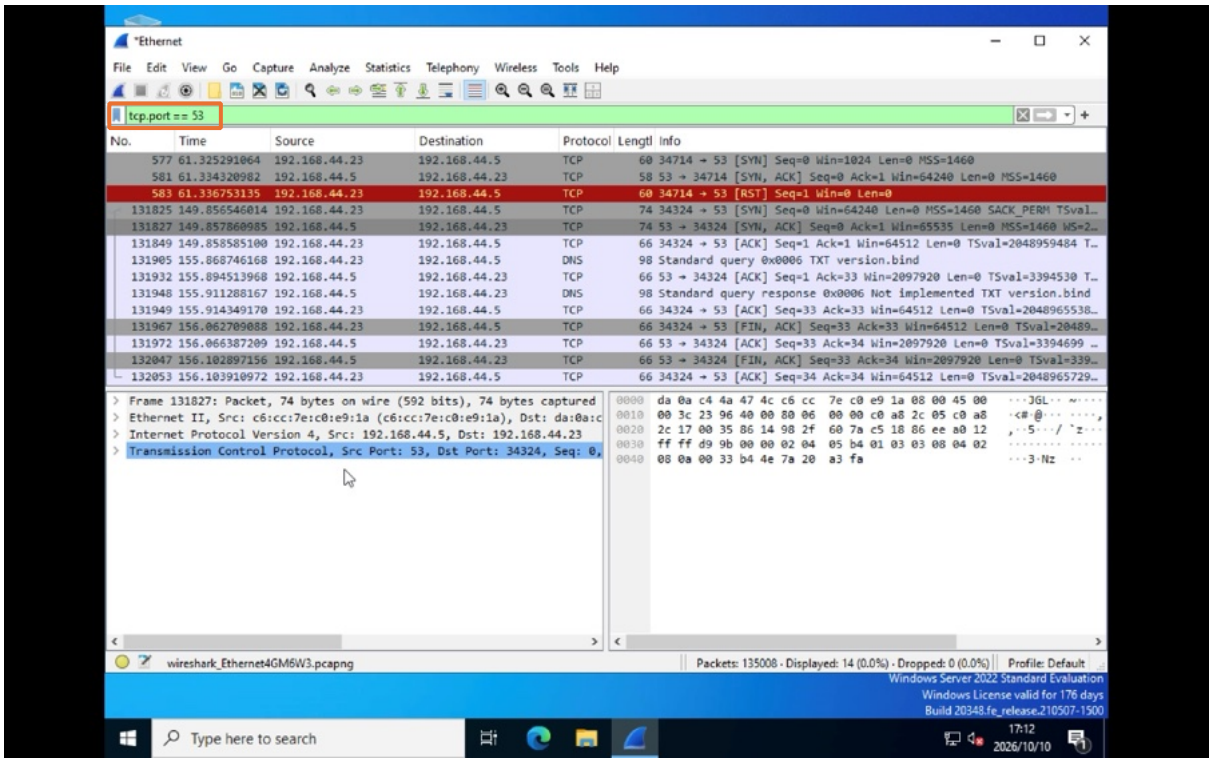
[kpasswd5]: tcp {RST},{SYN},{ACK},{PSH}.



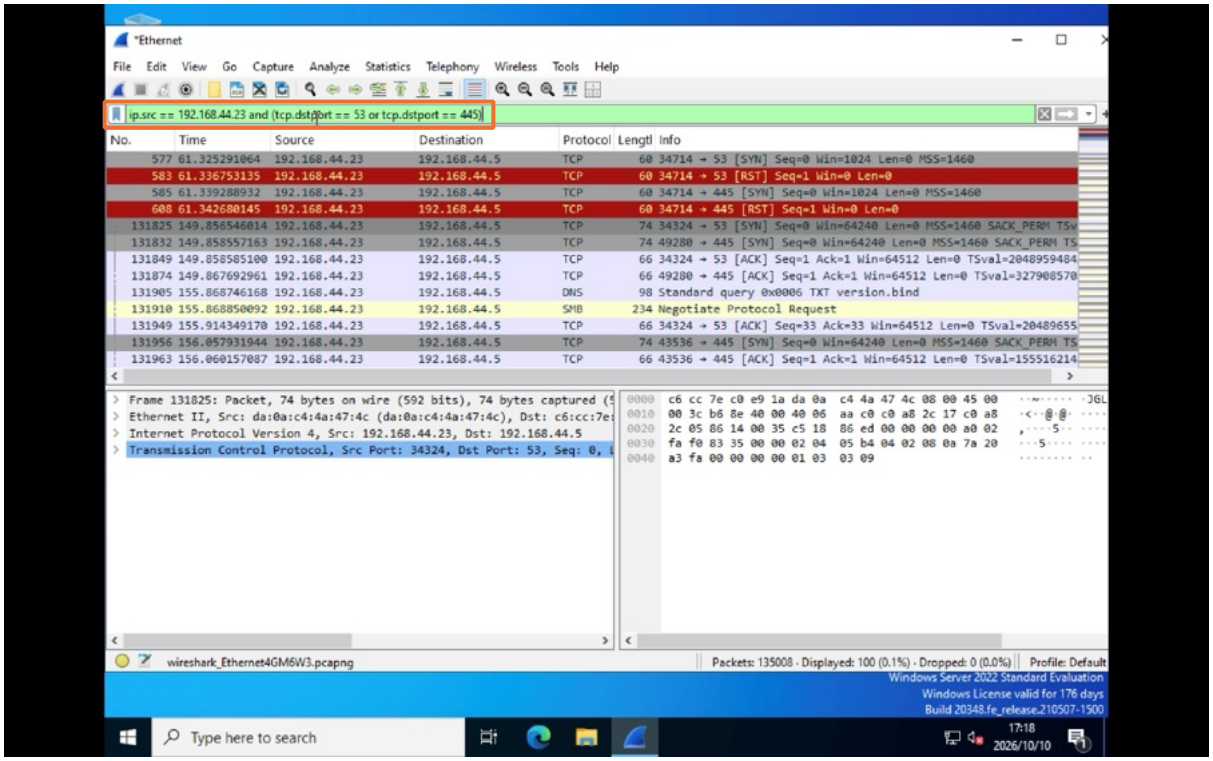
[ldap]: Microsoft Windows Active Directory LDAP skytru.com tcp {RST},{SYN},{ACK},{PSH}.



[Kerberos-sec]: Microsoft Windows Kerberos tcp {RST},{SYN},{ACK},{PSH}.

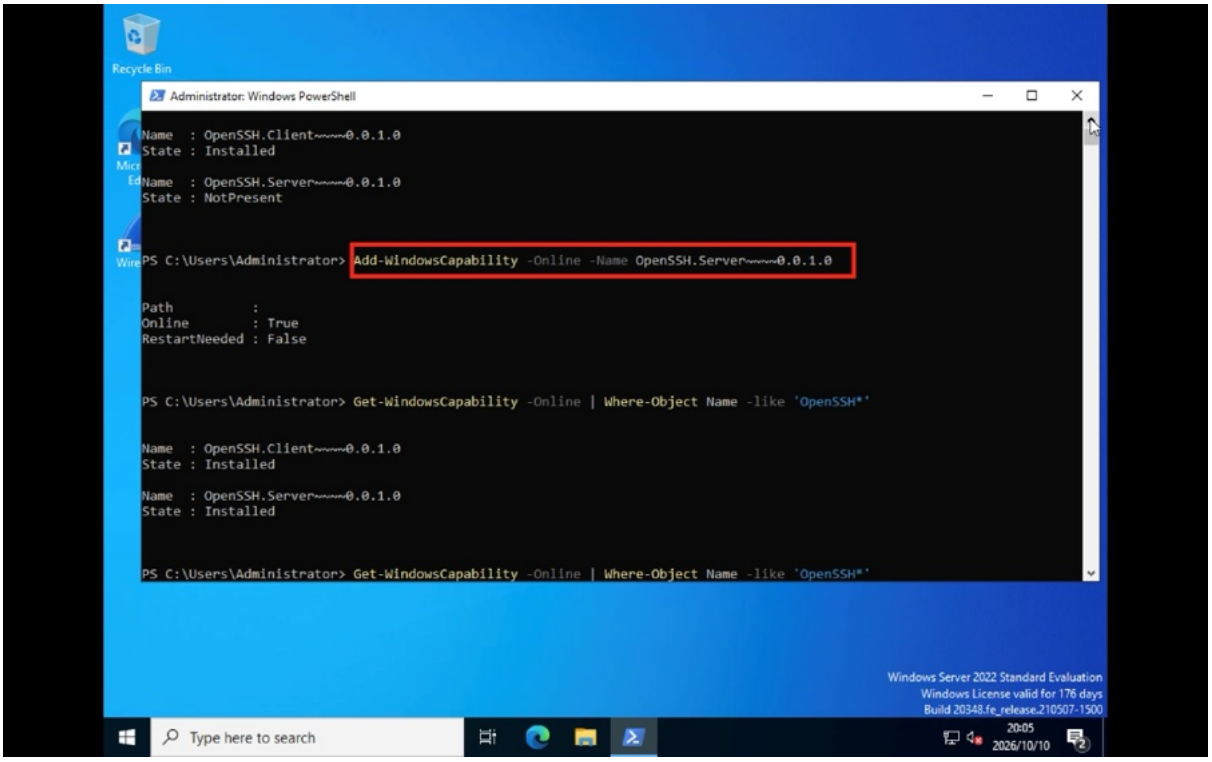


[Domain] DNS tcp {RST},{SYN},{ACK},{FIN}.

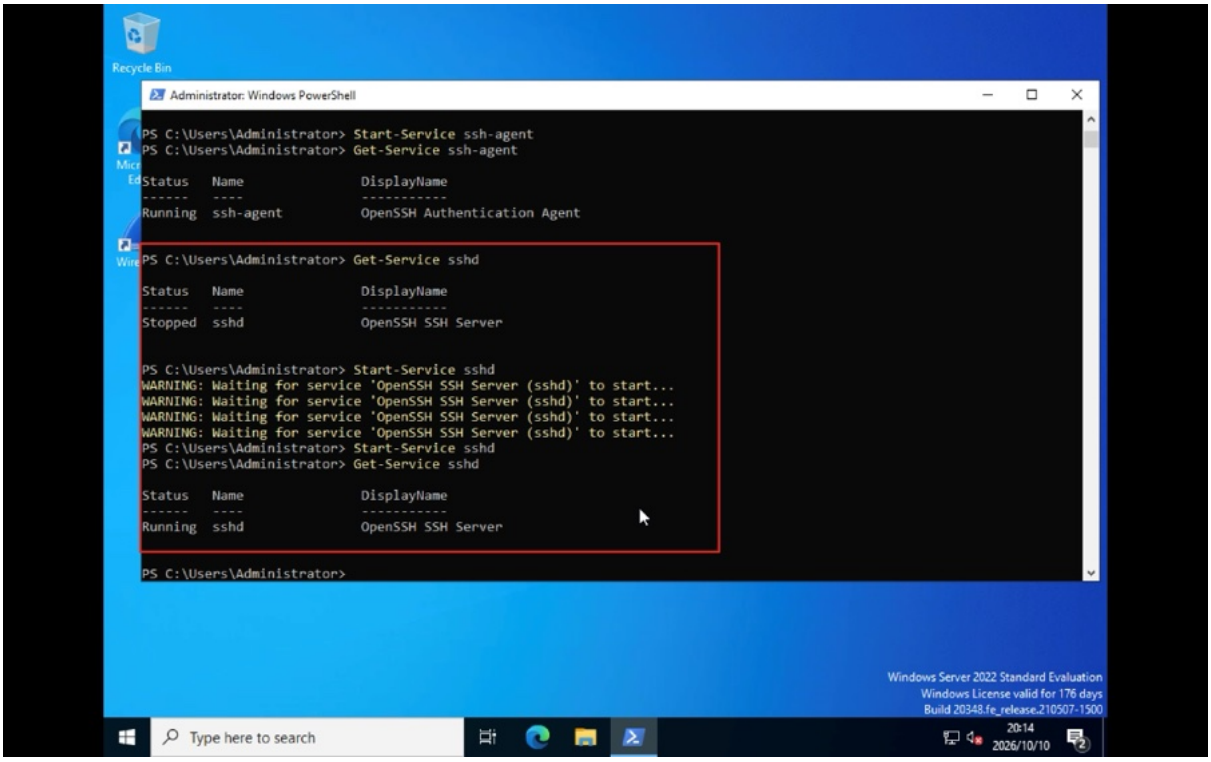


Filtering Wireshark to display packets on Port 53-(DNS) and 445-(SMB) coming from Lin_Kali.

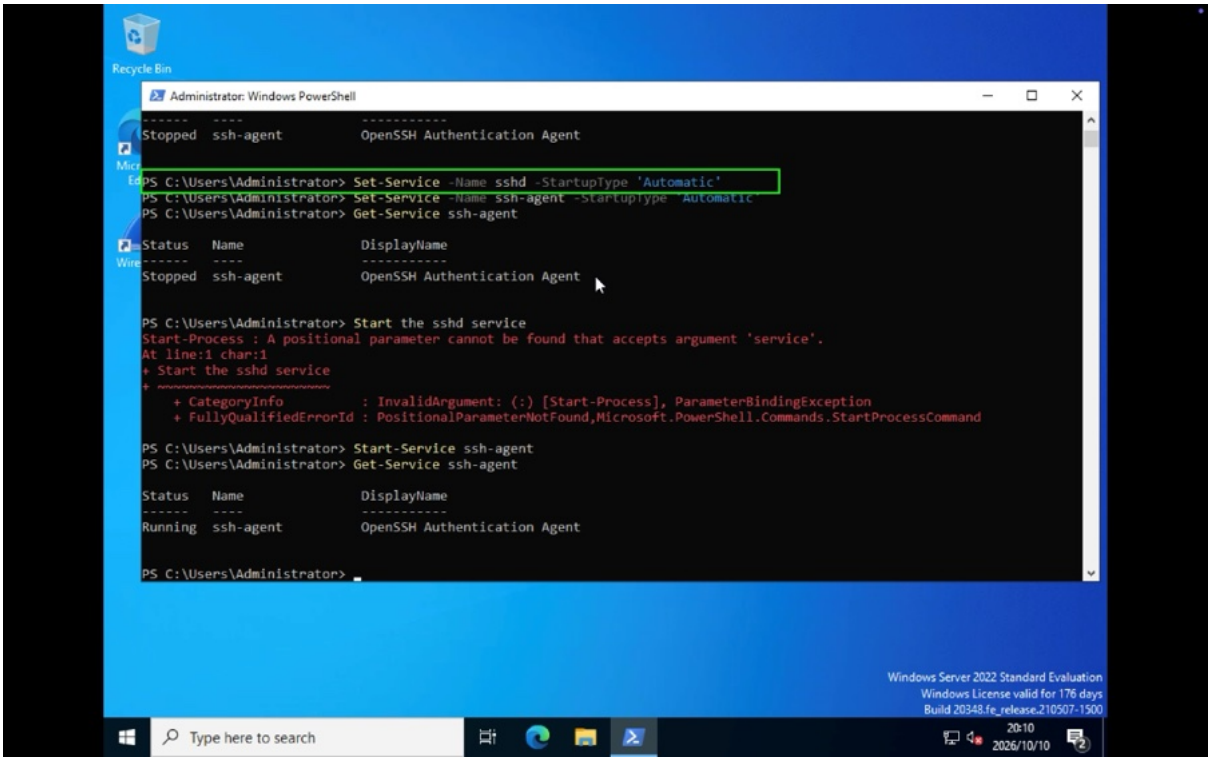
Question 3



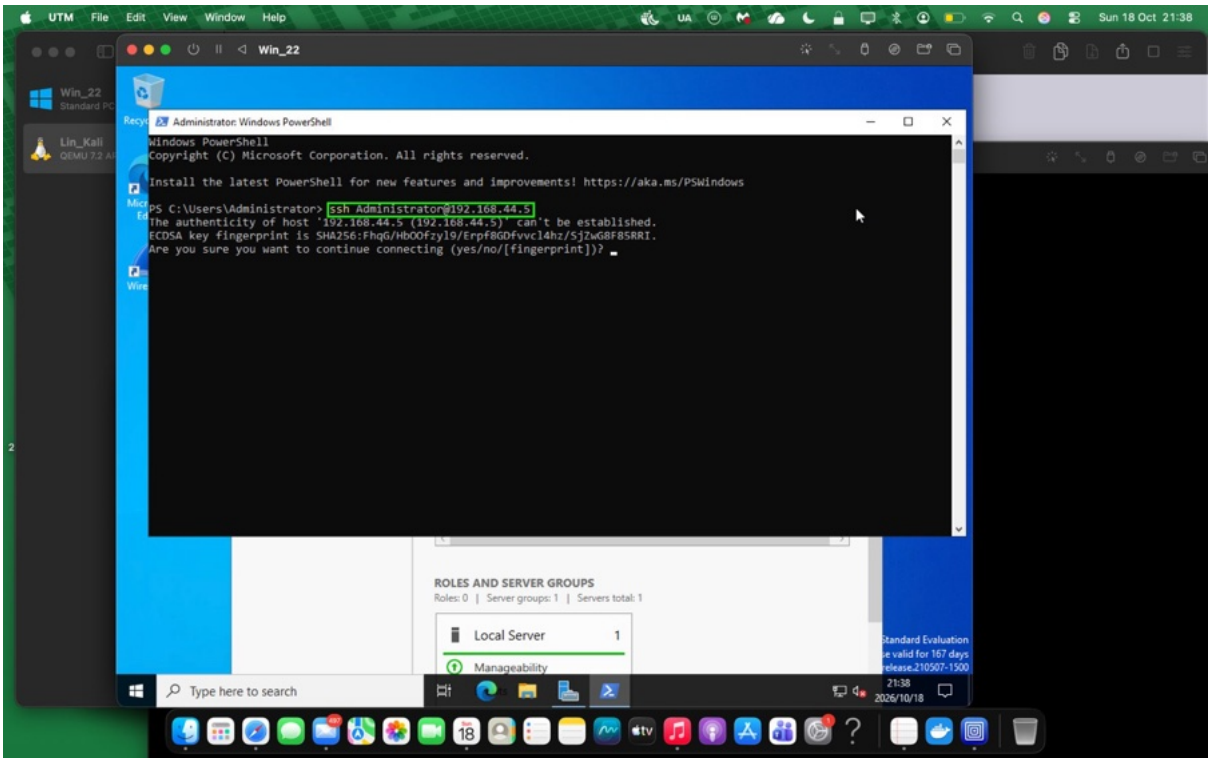
Installing OpenSSH server.



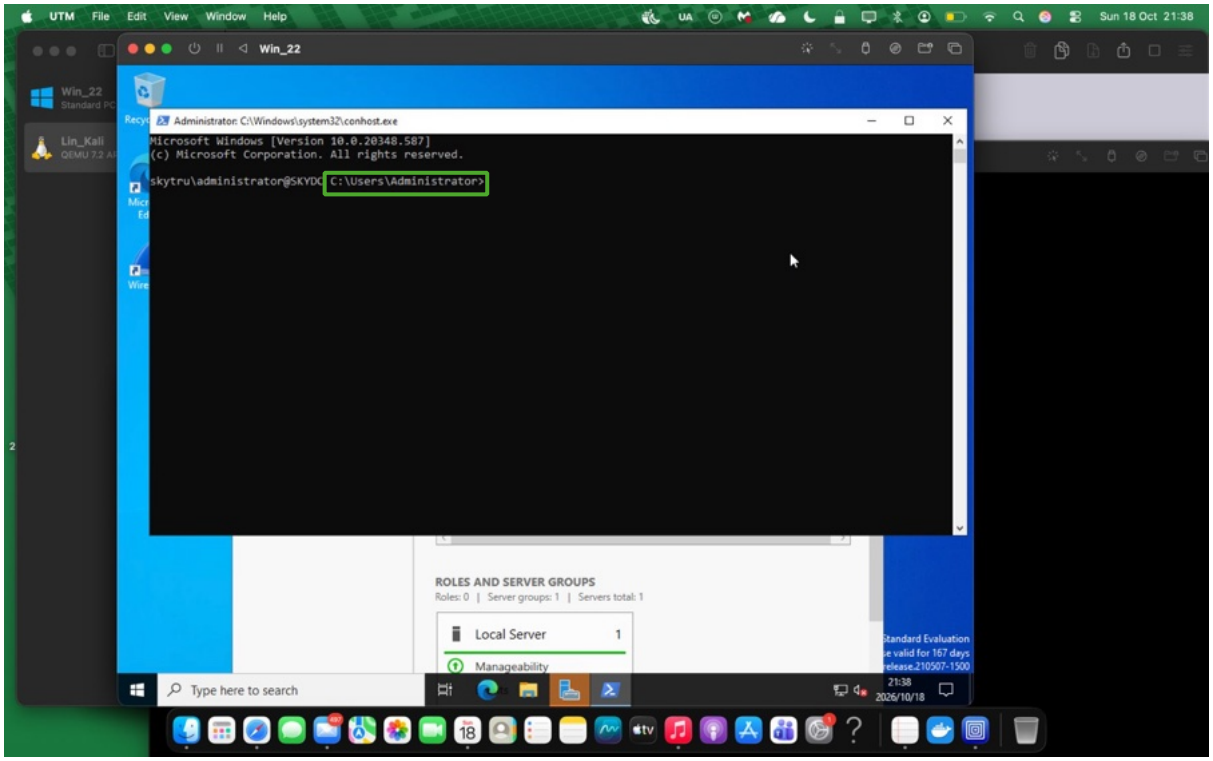
Getting Status of OpenSSH Server.



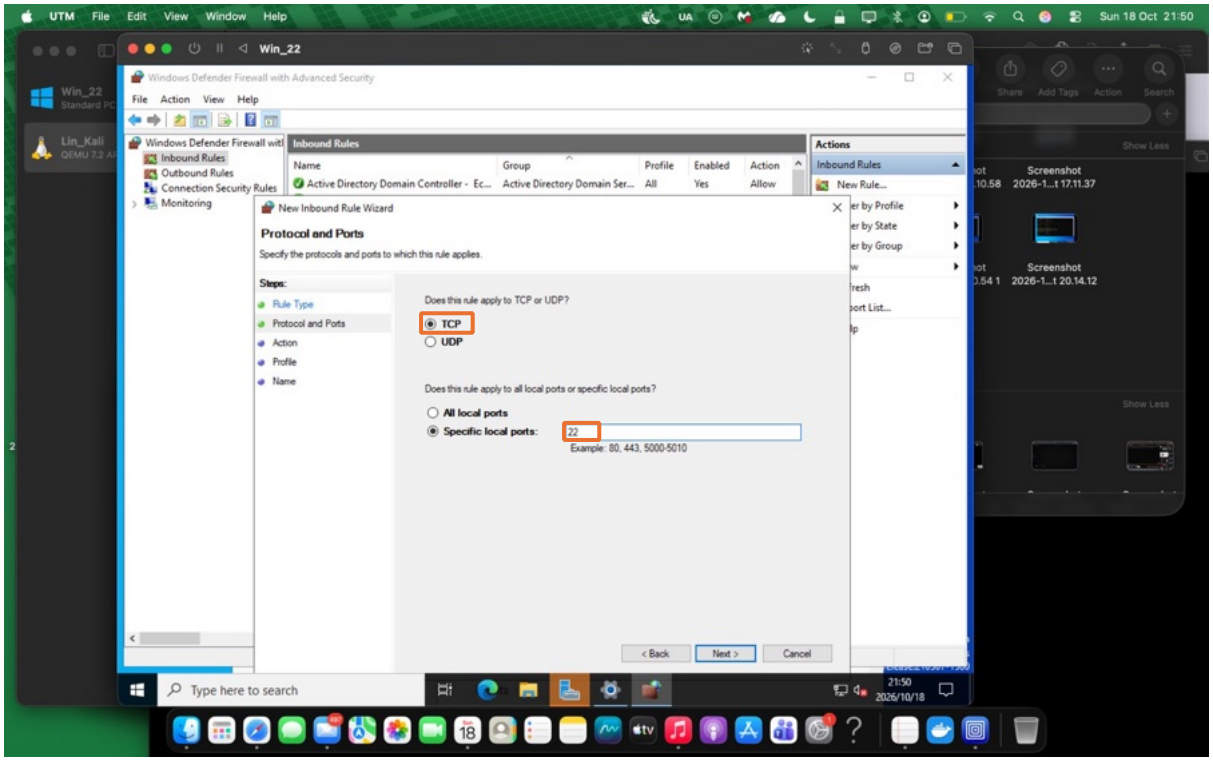
Setting services to automatically start-up.



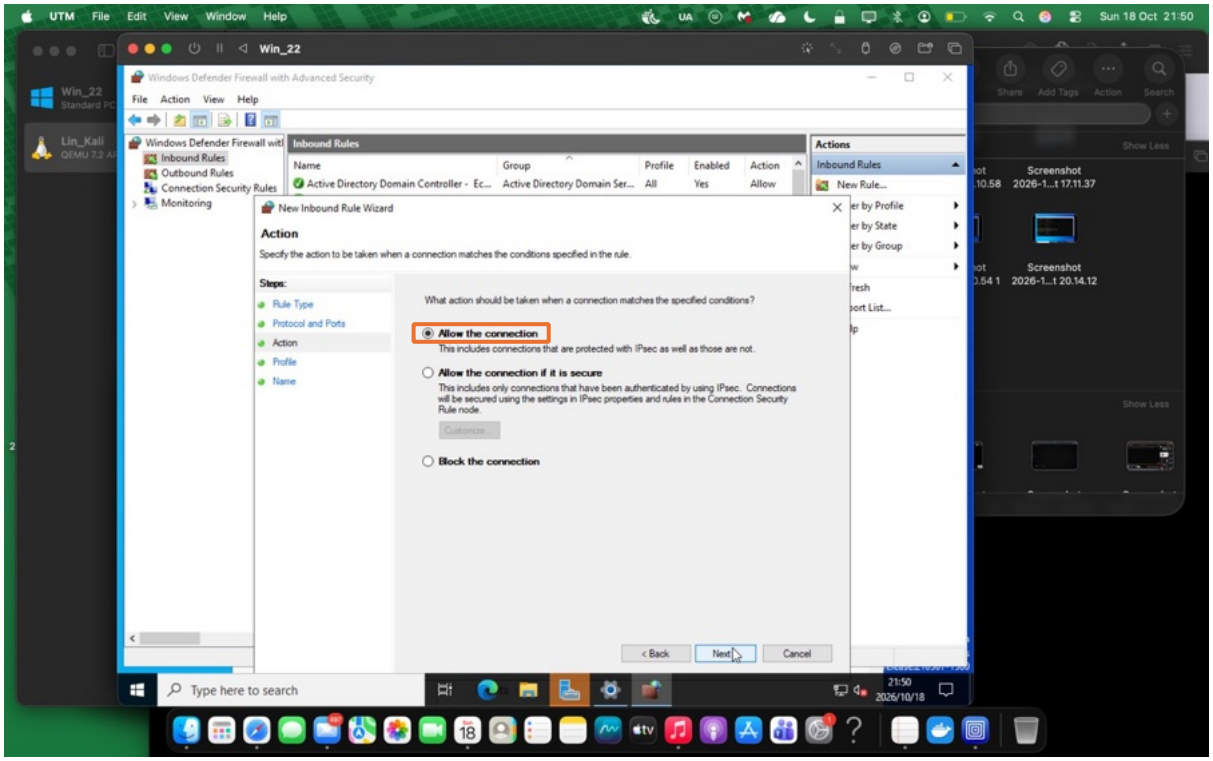
Testing OpenSSH.



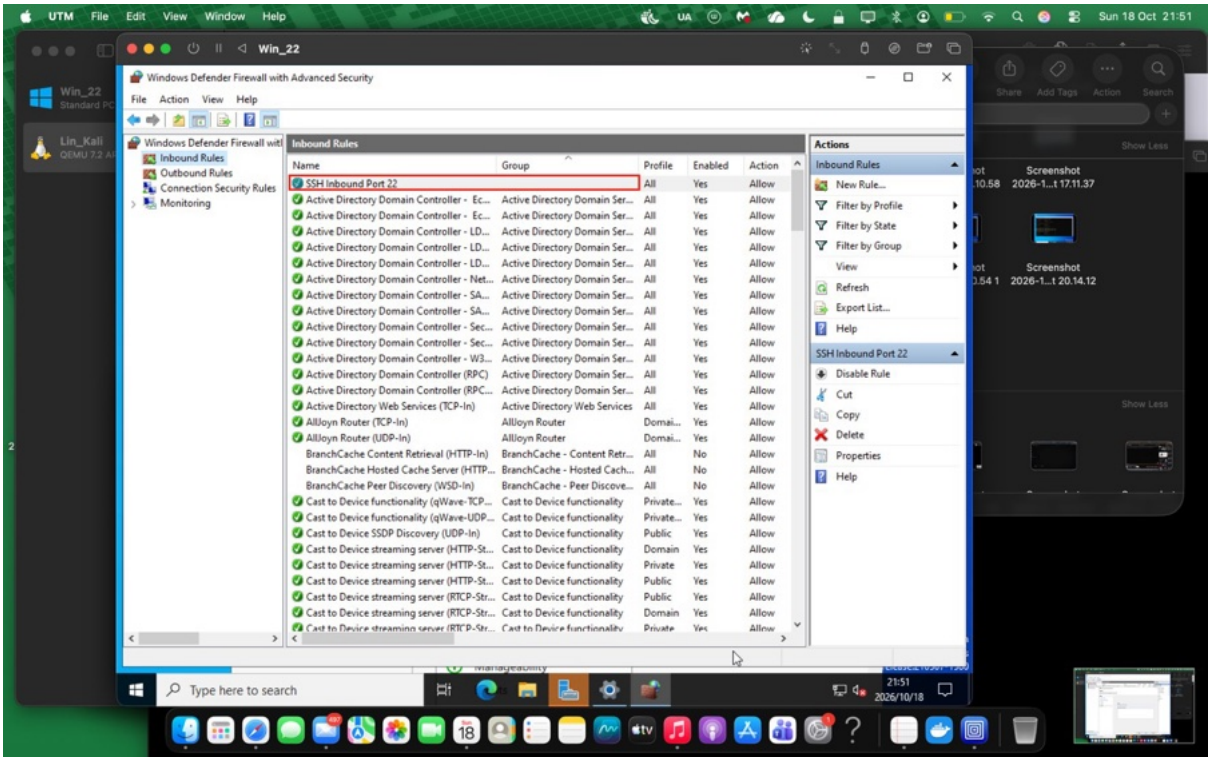
Successful OpenSSH login.



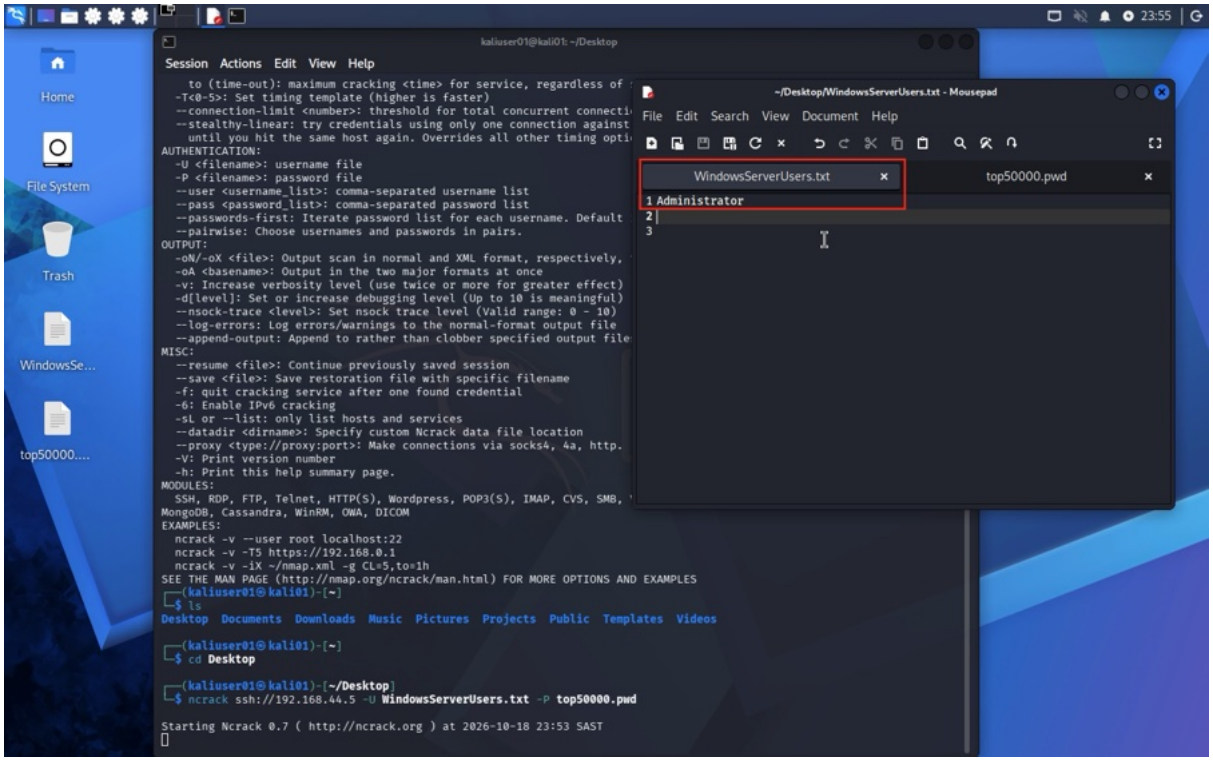
Creating inbound firewall policy for TCP port 22.



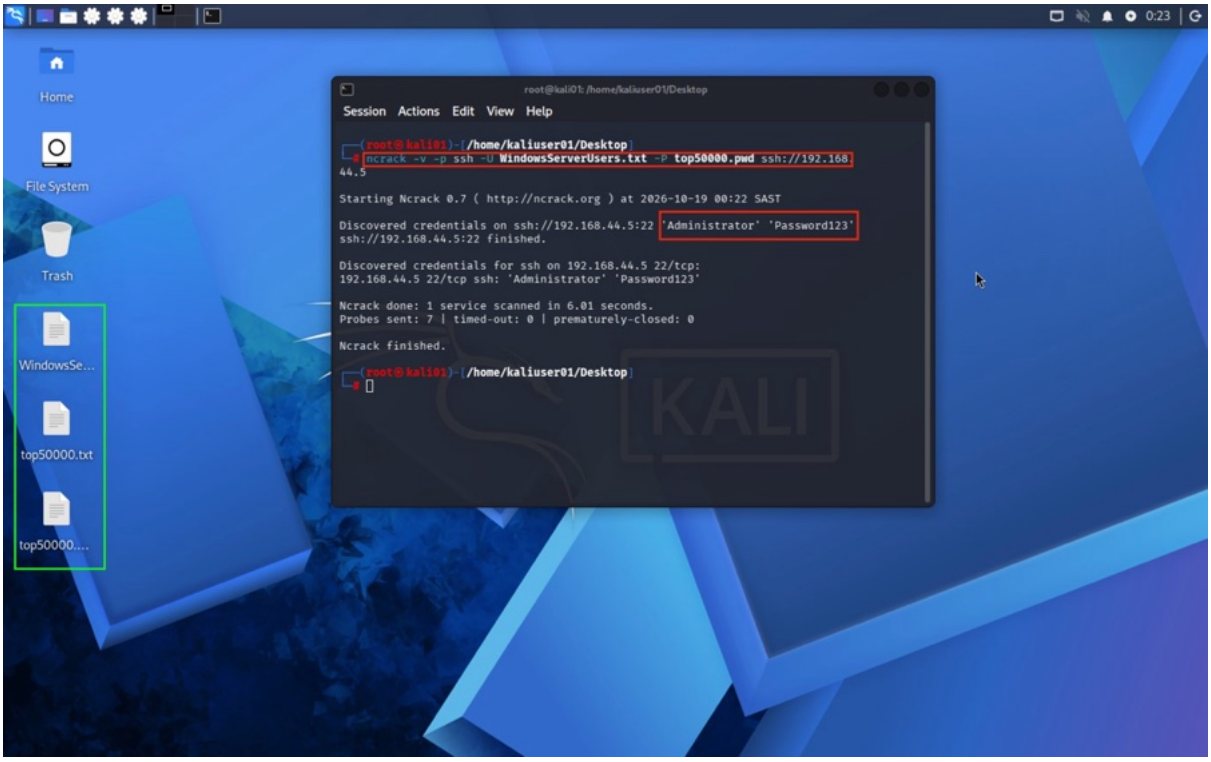
Allowing TCP port 22.



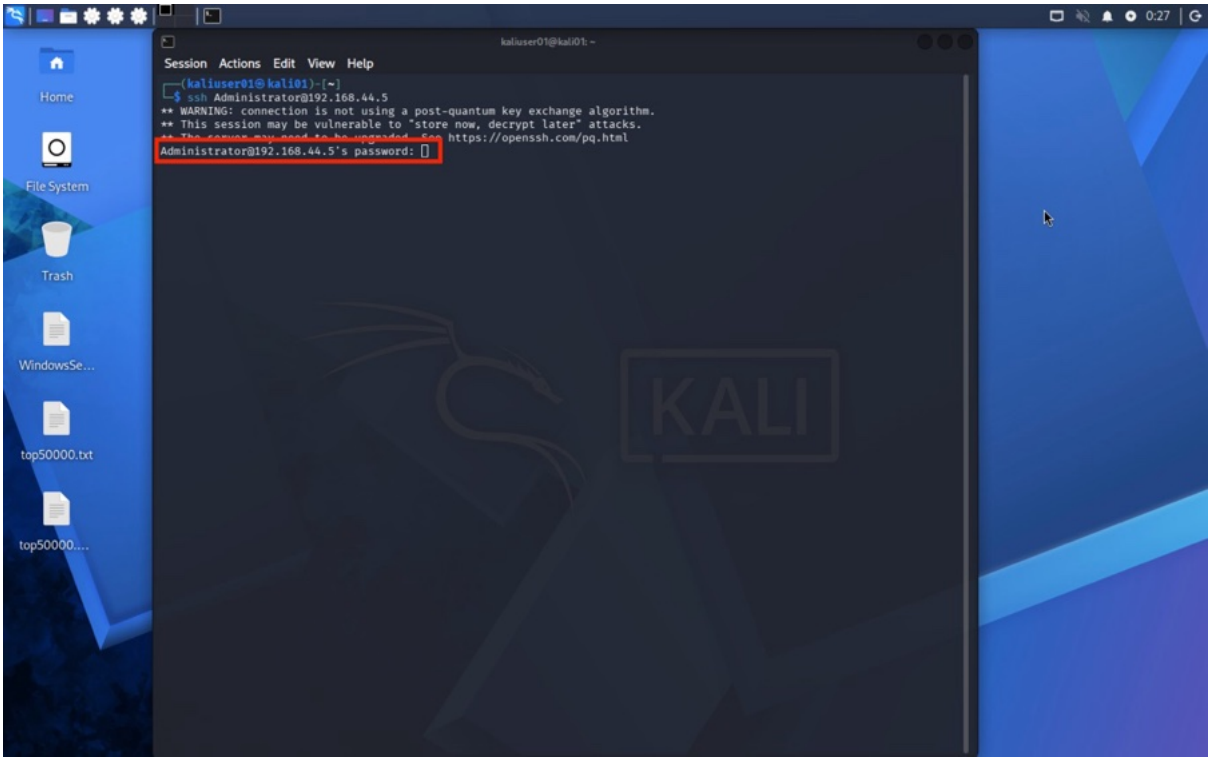
Successful “SSH inbound Firewall Port 22” rule.



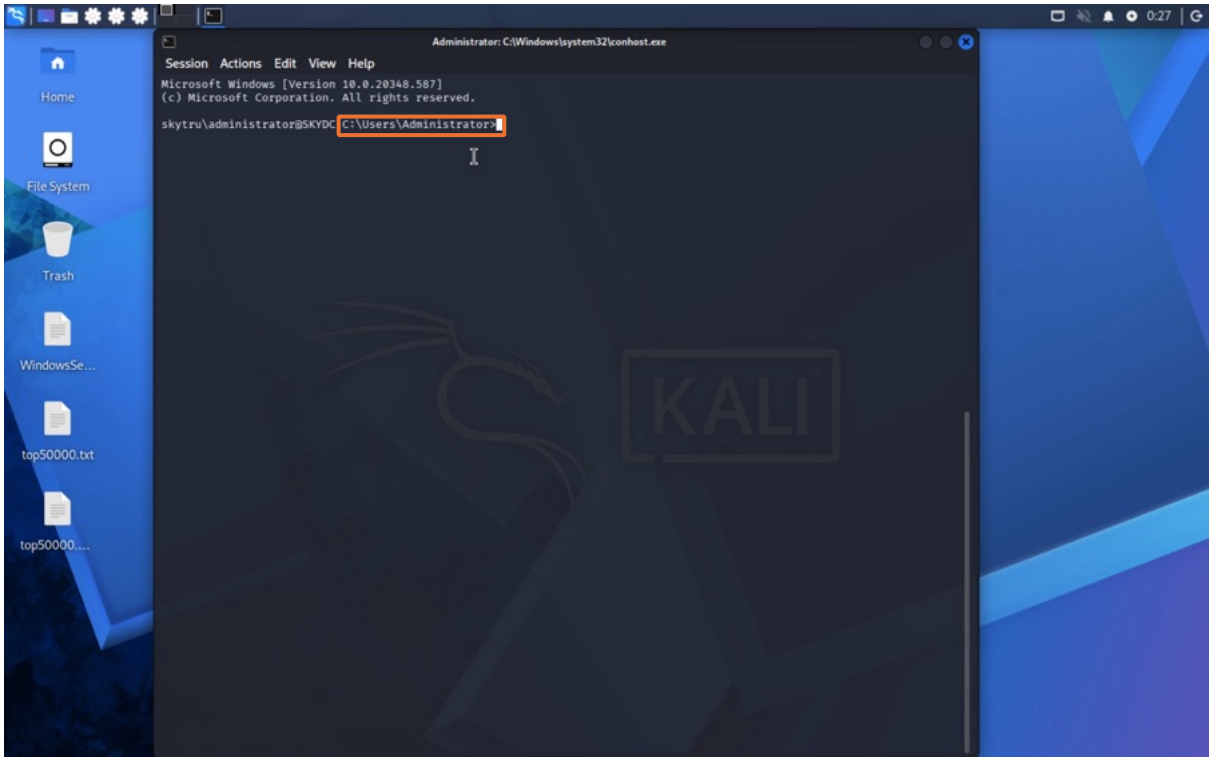
Creating User list. “WindowsServerUsers.txt”.



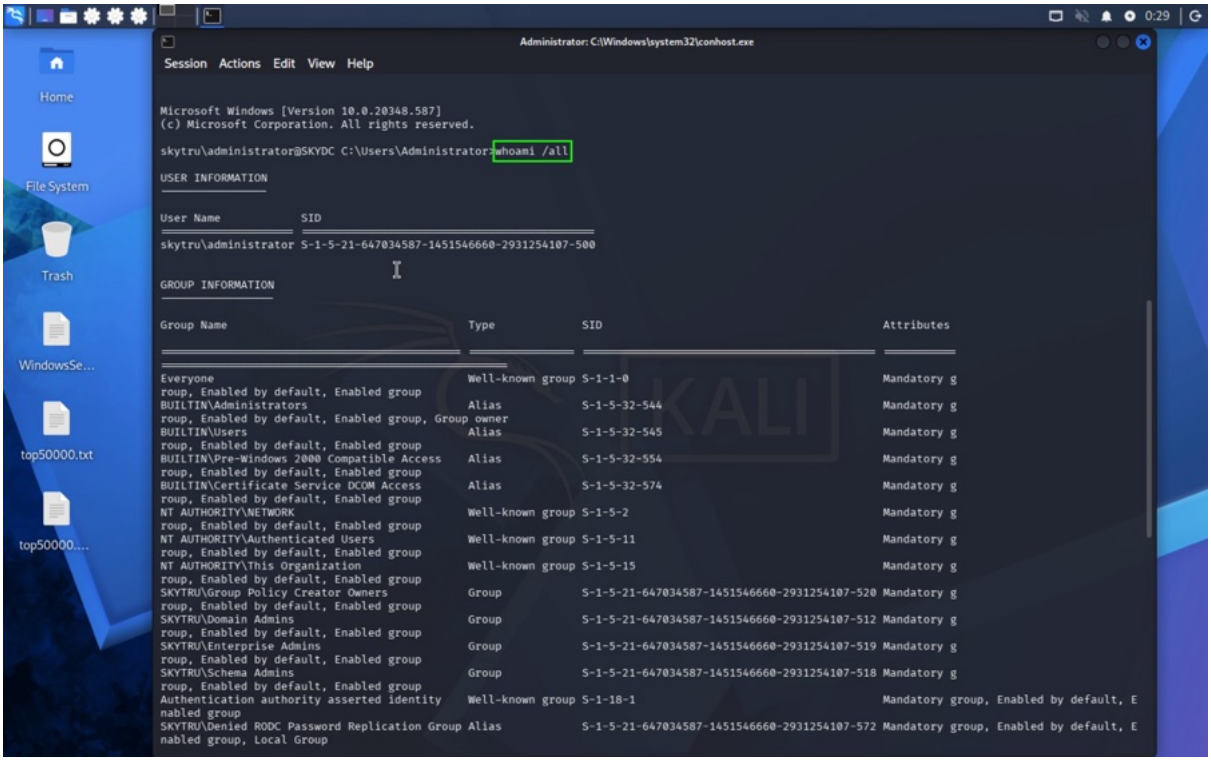
Using User file and Dictionary file top50000.pwd to running ncrack command to crack the password. Successful cracked Password.



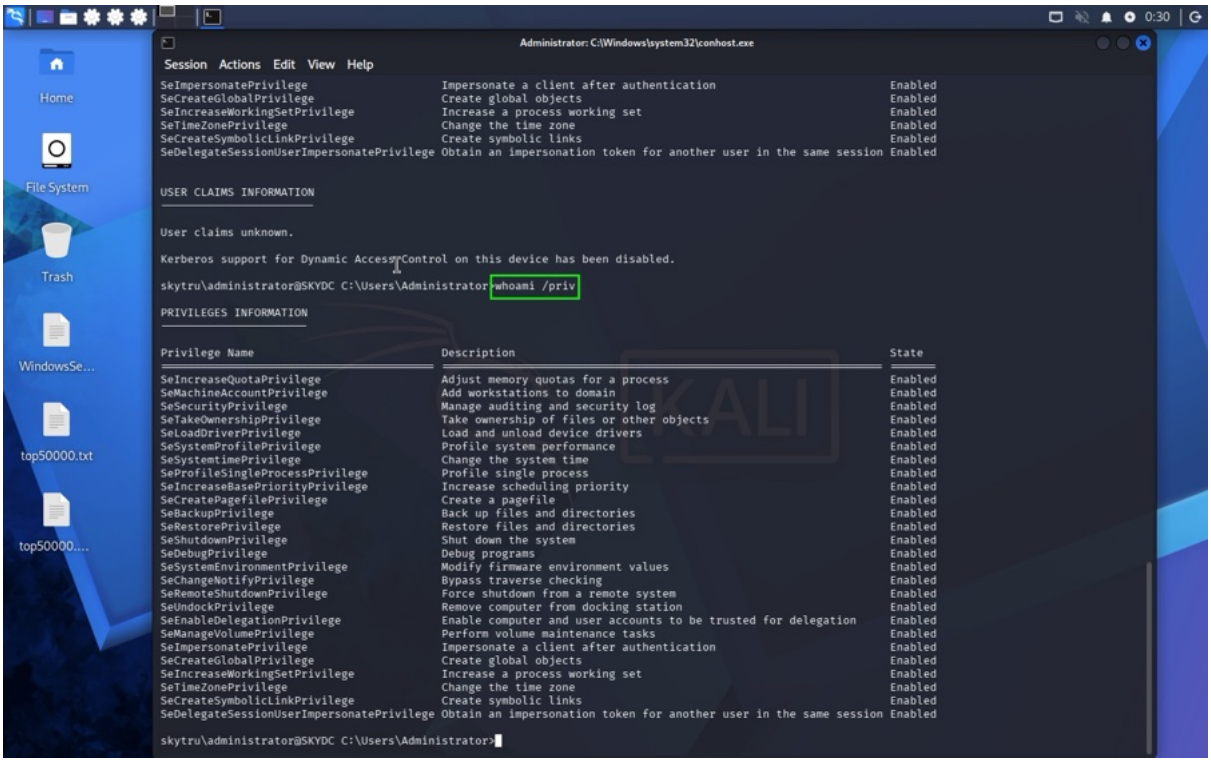
Logging into OpenSSH using successful cracked credentials.



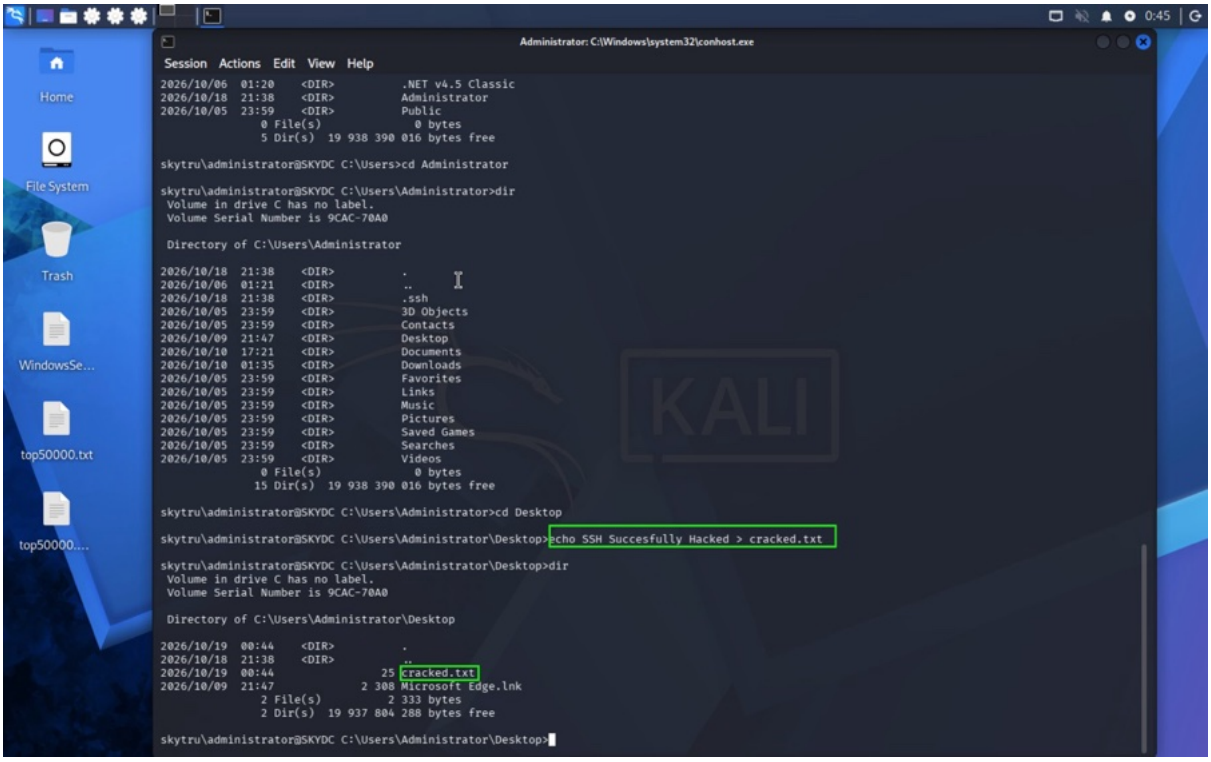
Successfully logged into the OpenSSH server using cracked credentials.



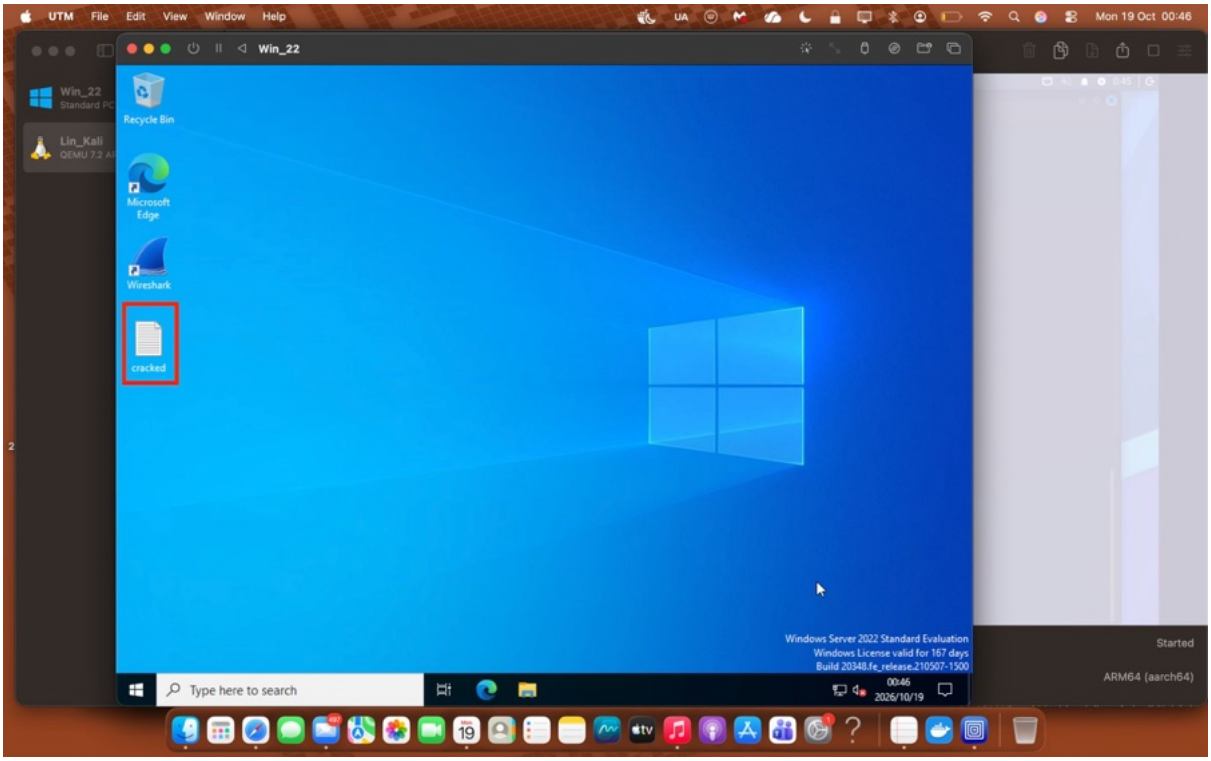
Running Command to display all privilege access.



Running Command to display all privilege access.



Creating File called cracked.txt using echo command with the message "SSH Successfully Hacked" and saving it to Win_22 Desktop.



Confirming file has been created on the Desktop.

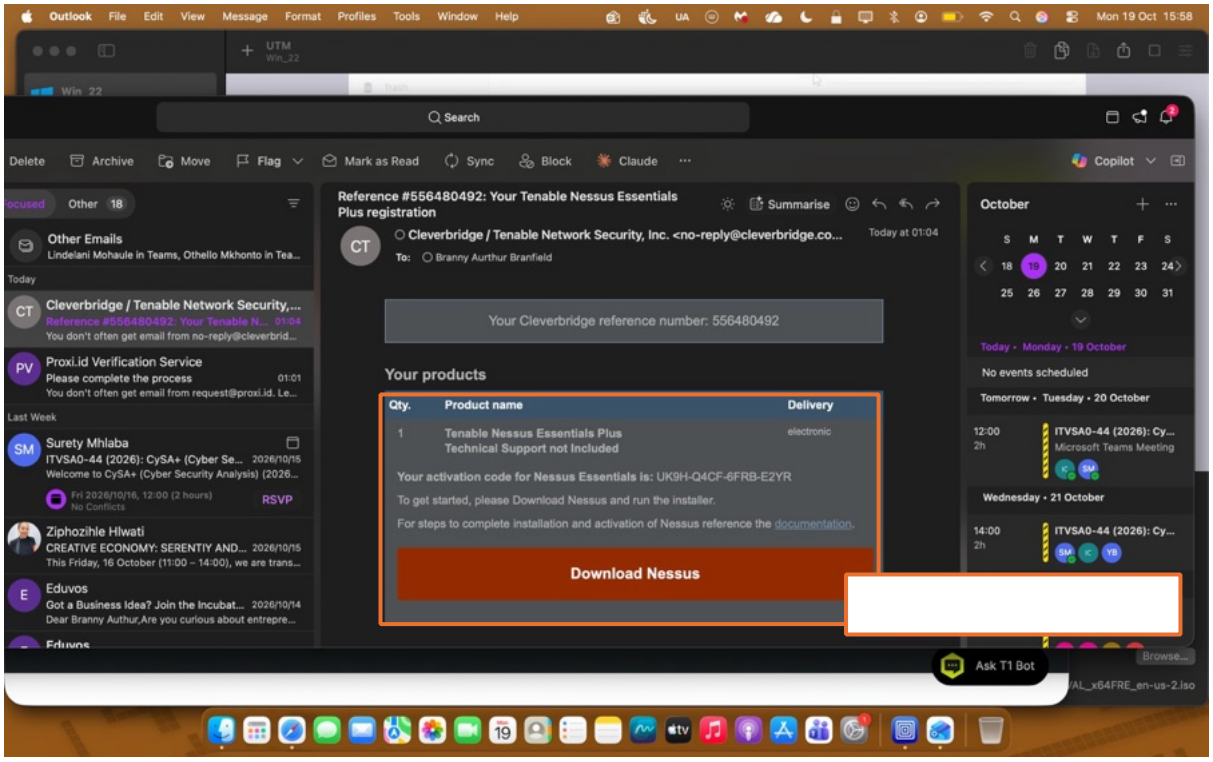
3.4 State other activities an attacker could do with this access.

- Some of the activities an attacker could do is Escalate Privilege for full system control and Gain Root Access.
- Exfiltrate and Espionage Data Stealing Sensitive files.
- SSH hopping Lateral Movement across the Network to other machines in the network.
- Aswell as deploying Malware, Ransomware, Modifying firewall and security Rules.

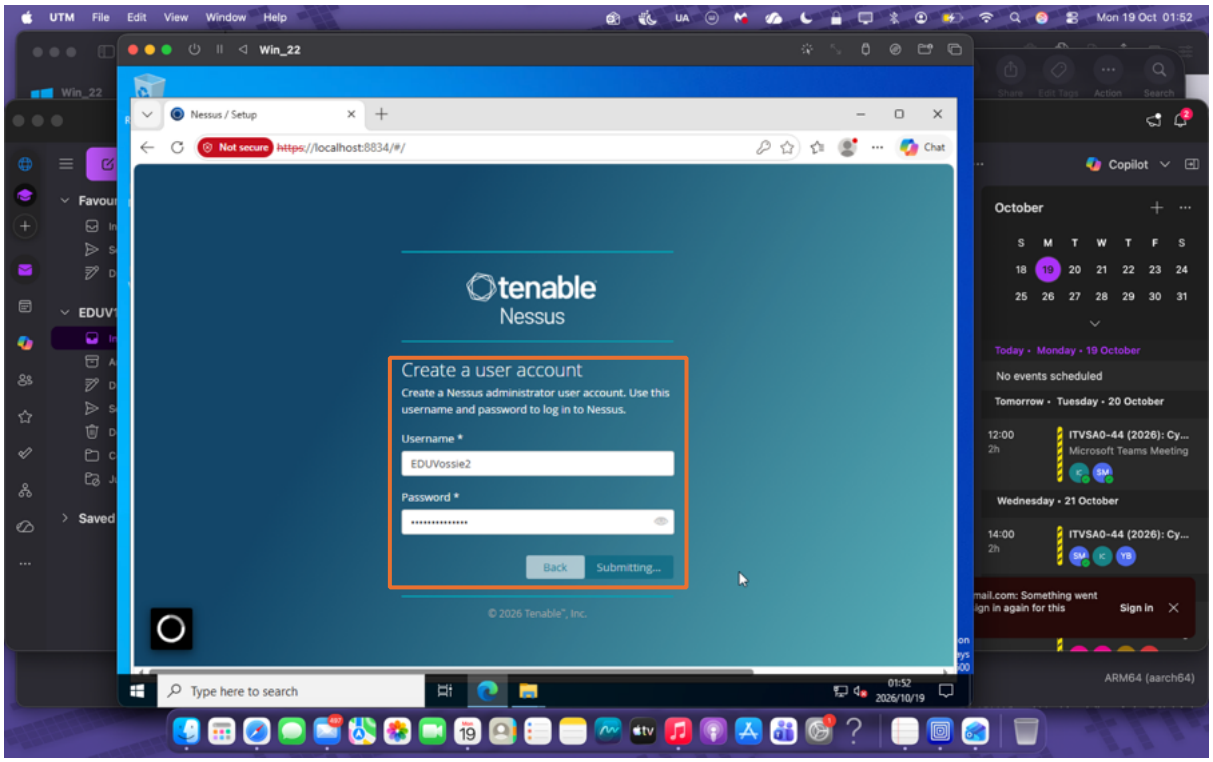
3.5 Explain how Security Administrators can defend against this type of attack.

- A Security Administrator can defend against SSH attacks by Enforcing Strong Authentication, Restrict Network Access & Visibility, Managing Keys and Lifecycle as well as Monitor and Audit Logs with SIEM or SOC platforms.

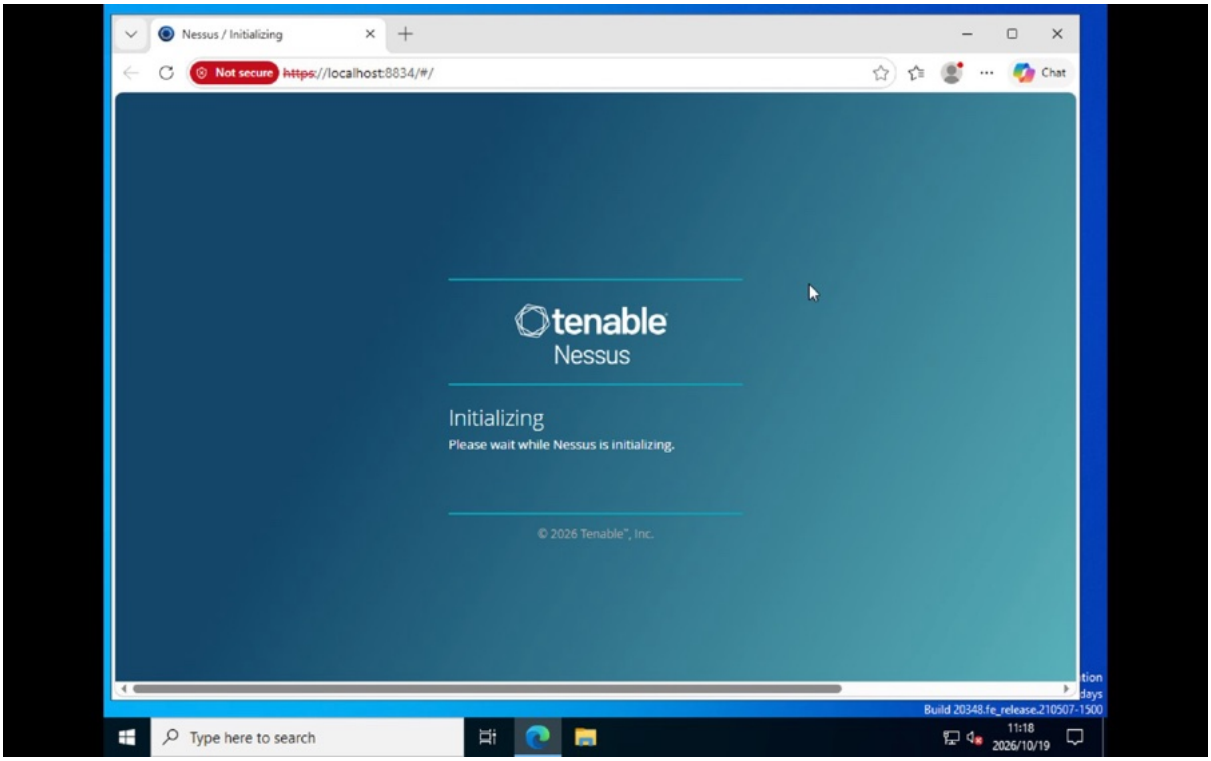
Question 4



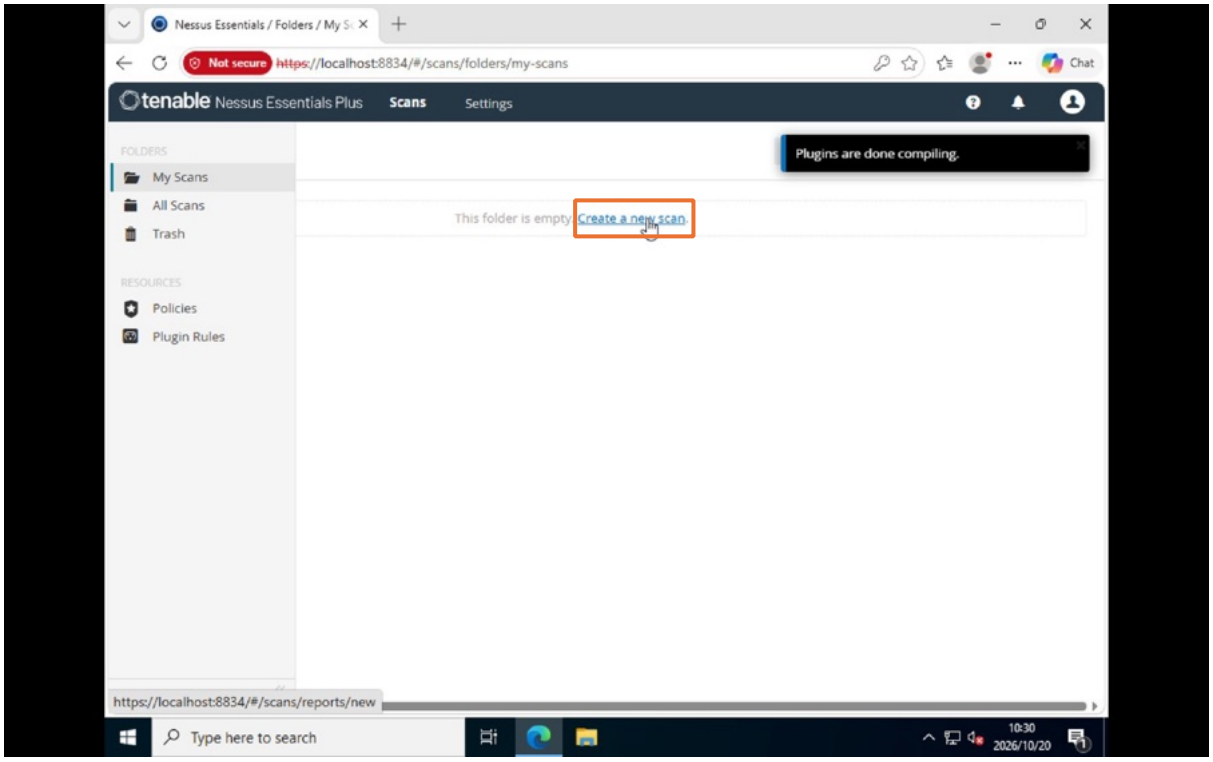
Using my Email Address to install and get one-time activation key for Tenable Nessus Essentials.



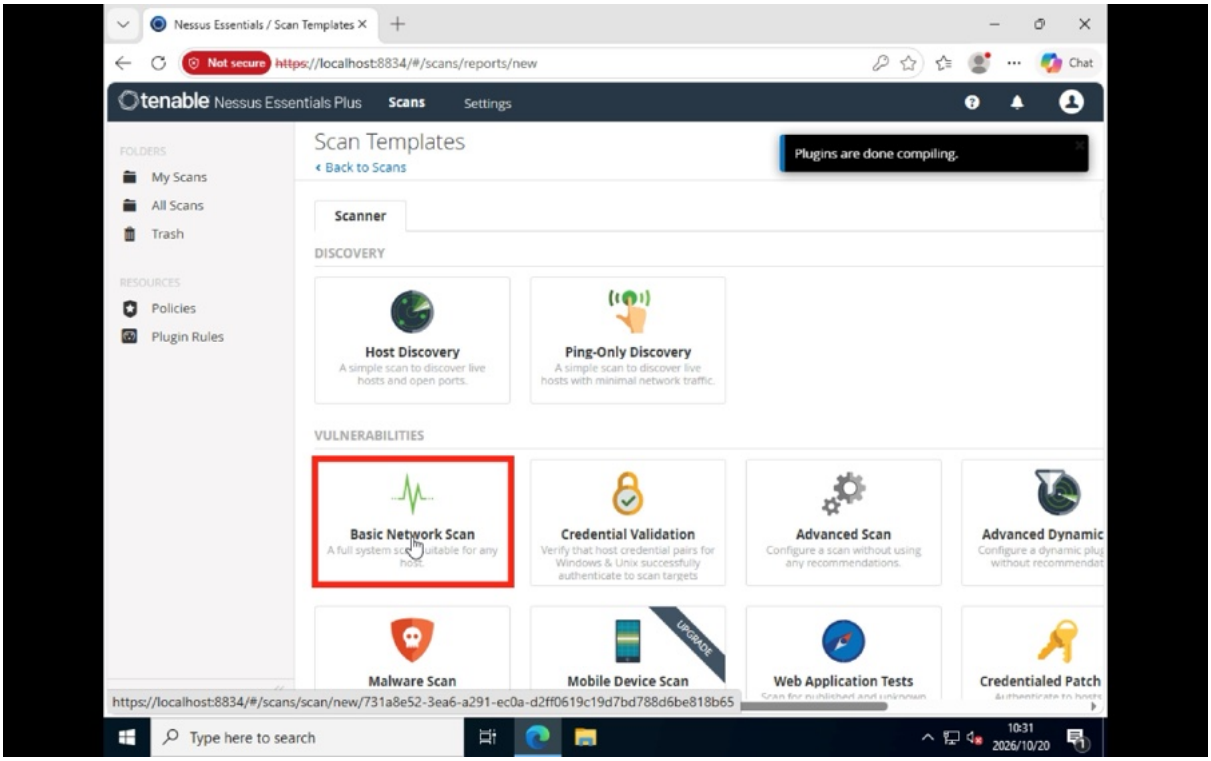
Create Nessus User Account.



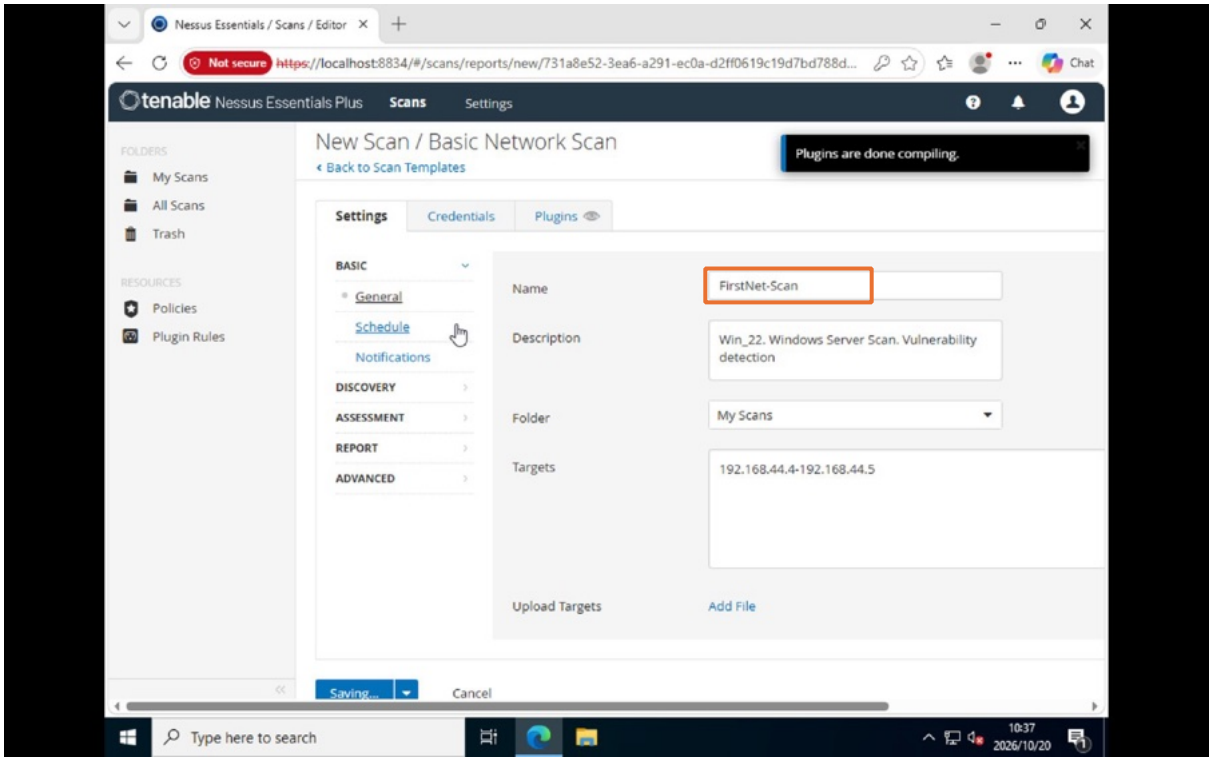
Nessus initializing and adding plugins.



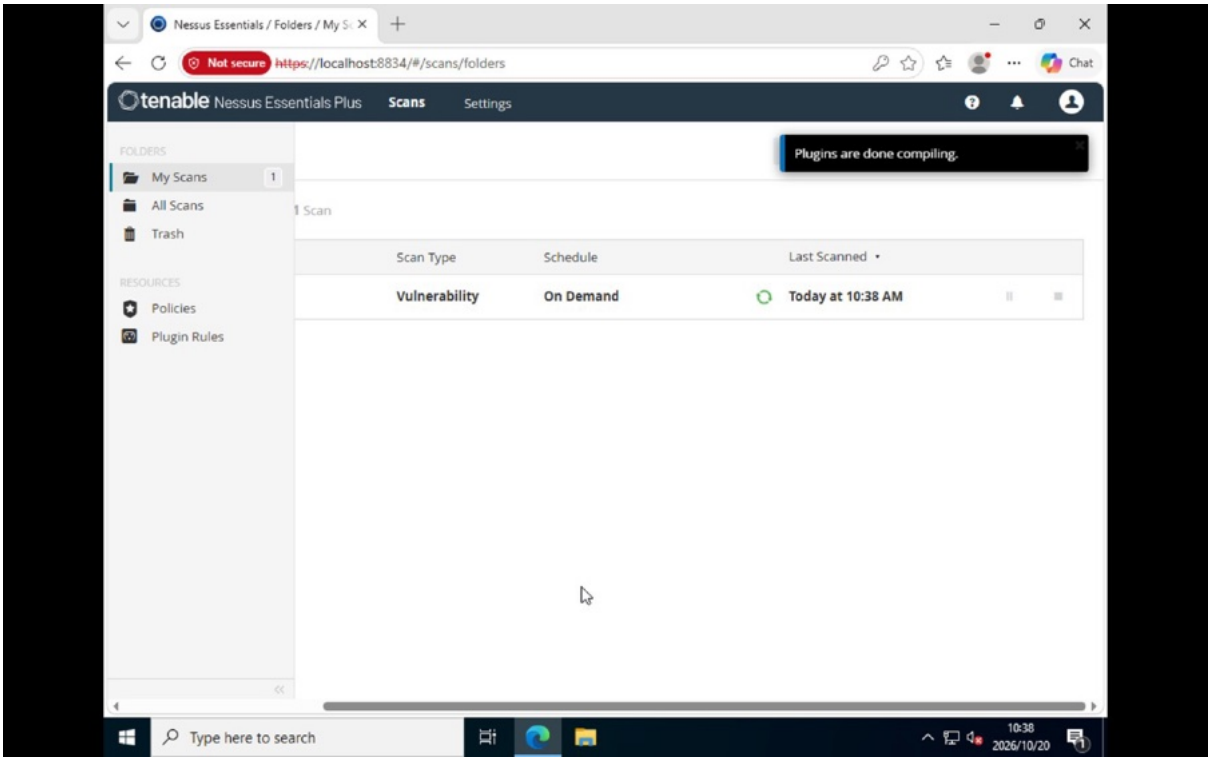
Creating a new Scan.



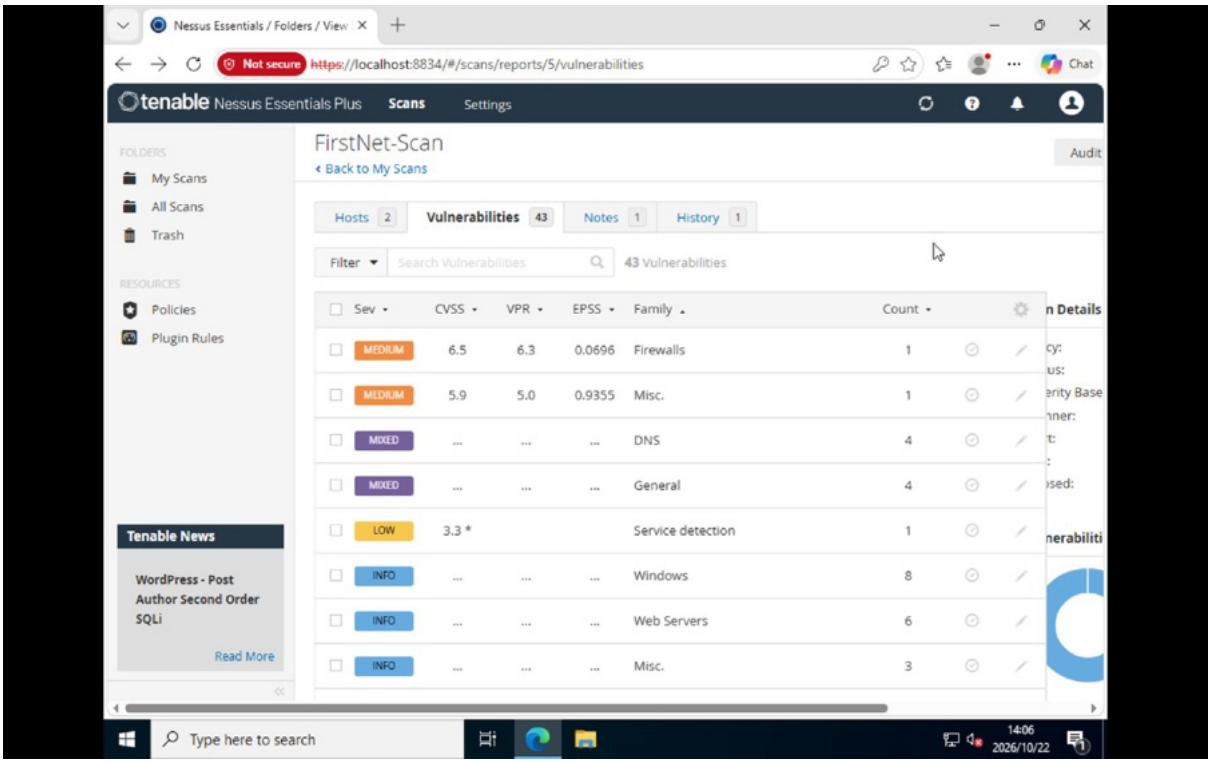
Running a Basic Network Scan.



Naming the Scan FirstNet-Scan.

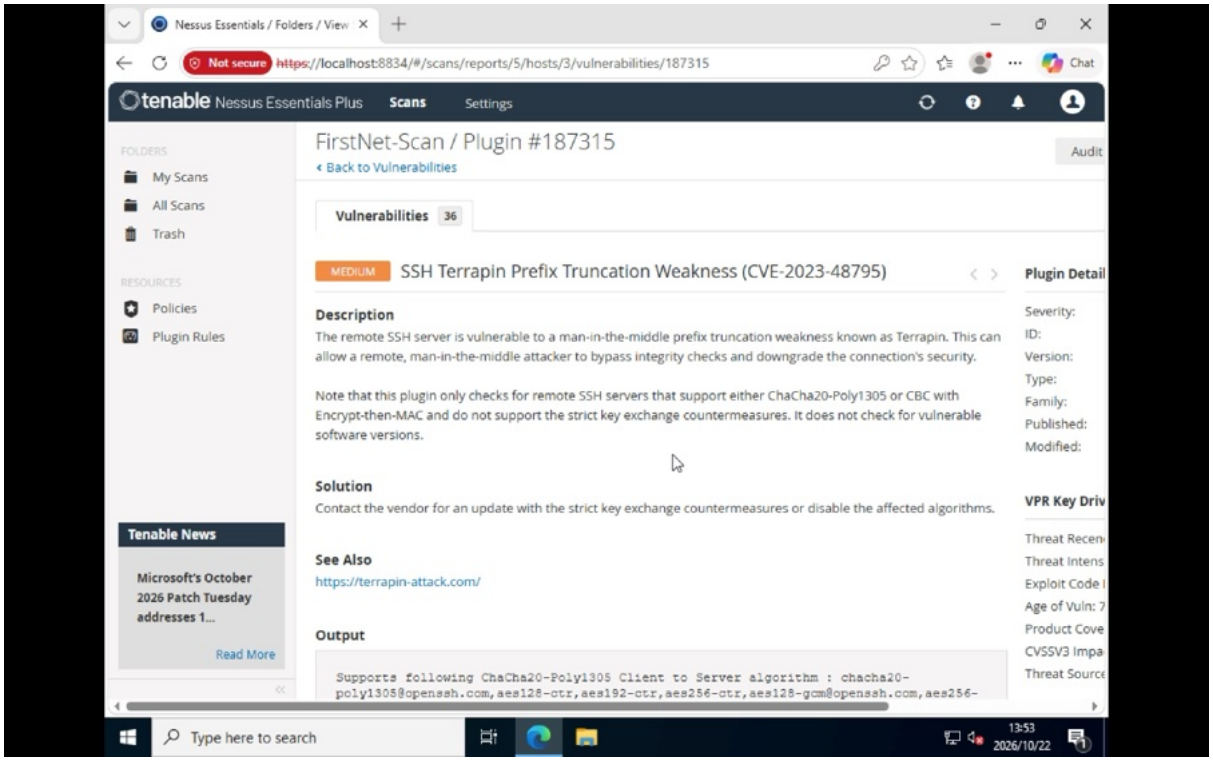


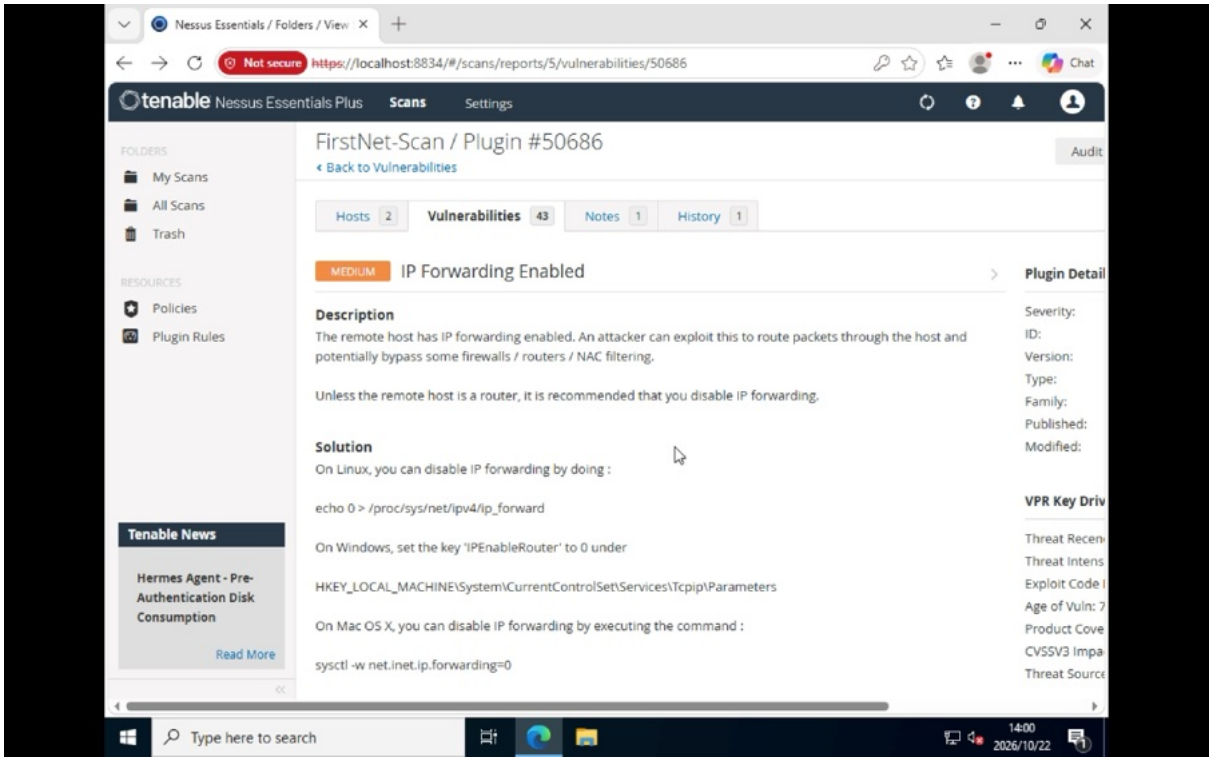
Scanning in session.

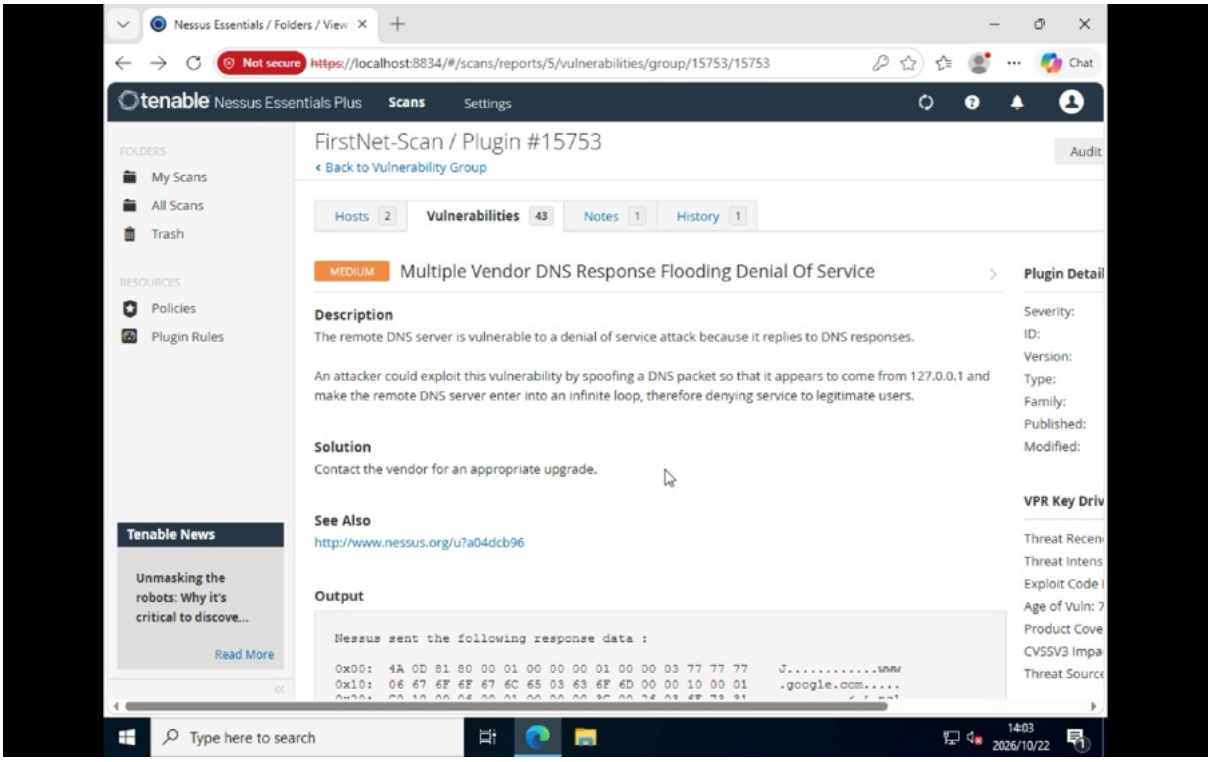


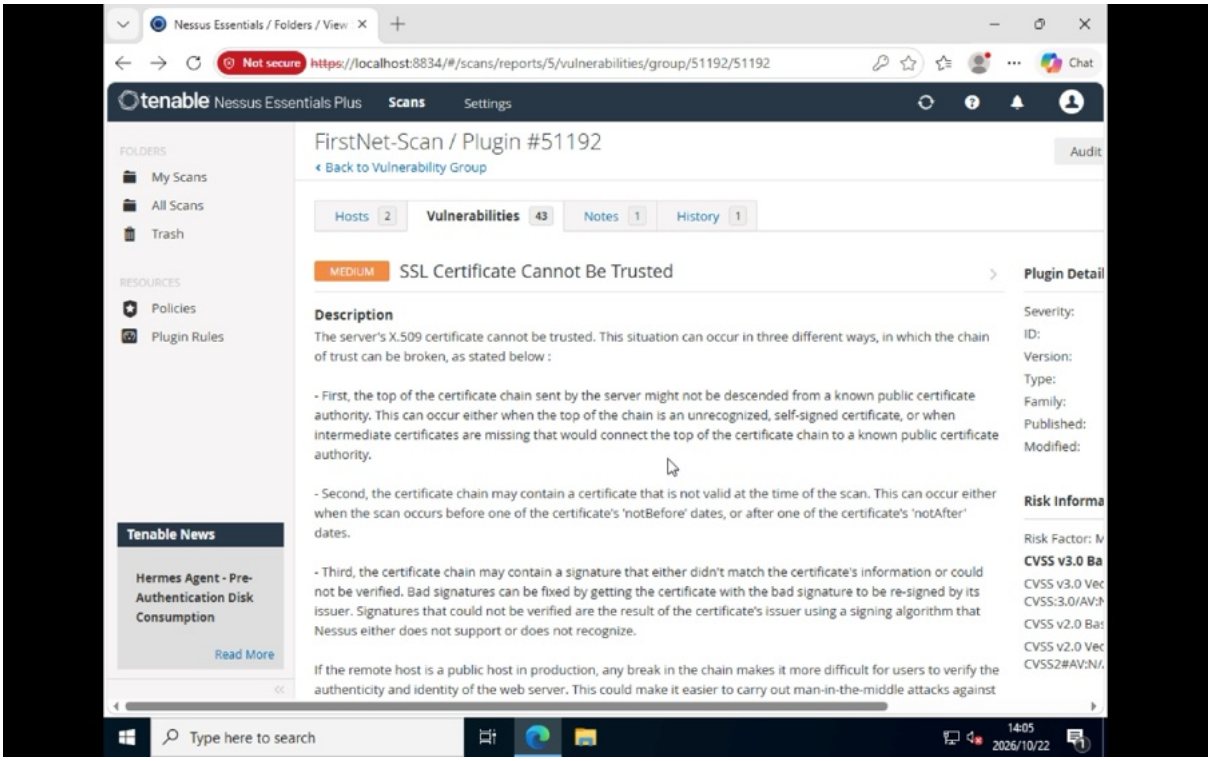
Scan complete.

4.3 Analysing the scanned results and vulnerabilities detected from the scan and how to remediate them.


Nessus Essentials / Folders / View
Not secure https://localhost:8834/#/scans/reports/5/hosts/3/vulnerabilities/187315
tenable Nessus Essentials Plus
Scans
Settings
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
Microsoft's October 2026 Patch Tuesday addresses 1...
Read More
FirstNet-Scan / Plugin #187315
Back to Vulnerabilities
Audit
Vulnerabilities 36
MEDIUM
SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)
Description
The remote SSH server is vulnerable to a man-in-the-middle prefix truncation weakness known as Terrapin. This can allow a remote, man-in-the-middle attacker to bypass integrity checks and downgrade the connection's security.
Note that this plugin only checks for remote SSH servers that support either ChaCha20-Poly1305 or CBC with Encrypt-then-MAC and do not support the strict key exchange countermeasures. It does not check for vulnerable software versions.
Solution
Contact the vendor for an update with the strict key exchange countermeasures or disable the affected algorithms.
See Also
https://terrapin-attack.com/
Output
Supports following ChaCha20-Poly1305 Client to Server algorithm : chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-
Plugin Detail
Severity:
ID:
Version:
Type:
Family:
Published:
Modified:
VPR Key Driv
Threat Recen
Threat Intens
Exploit Code
Age of Vuln: 7
Product Cove
CVSSV3 Impa
Threat Source
Type here to search
13:53
2026/10/22


Nessus Essentials / Folders / View
Not secure https://localhost:8834/#/scans/reports/5/vulnerabilities/50686
tenable Nessus Essentials Plus
Scans
Settings
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
Hermes Agent - Pre-Authentication Disk Consumption
Read More
FirstNet-Scan / Plugin #50686
Back to Vulnerabilities
Audit
Hosts 2
Vulnerabilities 43
Notes 1
History 1
MEDIUM
IP Forwarding Enabled
Description
The remote host has IP forwarding enabled. An attacker can exploit this to route packets through the host and potentially bypass some firewalls / routers / NAC filtering.
Unless the remote host is a router, it is recommended that you disable IP forwarding.
Solution
On Linux, you can disable IP forwarding by doing :
echo 0 > /proc/sys/net/ipv4/ip_forward
On Windows, set the key 'IPEnableRouter' to 0 under
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters
On Mac OS X, you can disable IP forwarding by executing the command :
sysctl -w net.inet.ip.forwarding=0
Plugin Detail
Severity:
ID:
Version:
Type:
Family:
Published:
Modified:
VPR Key Driv
Threat Recen
Threat Intens
Exploit Code
Age of Vuln: 7
Product Cove
CVSSV3 Impa
Threat Source
Type here to search
14:00
2026/10/22





The Vulnerabilities detected are SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795), Firewall issue CVSS.6.5, DNS and General Misconfigurations,

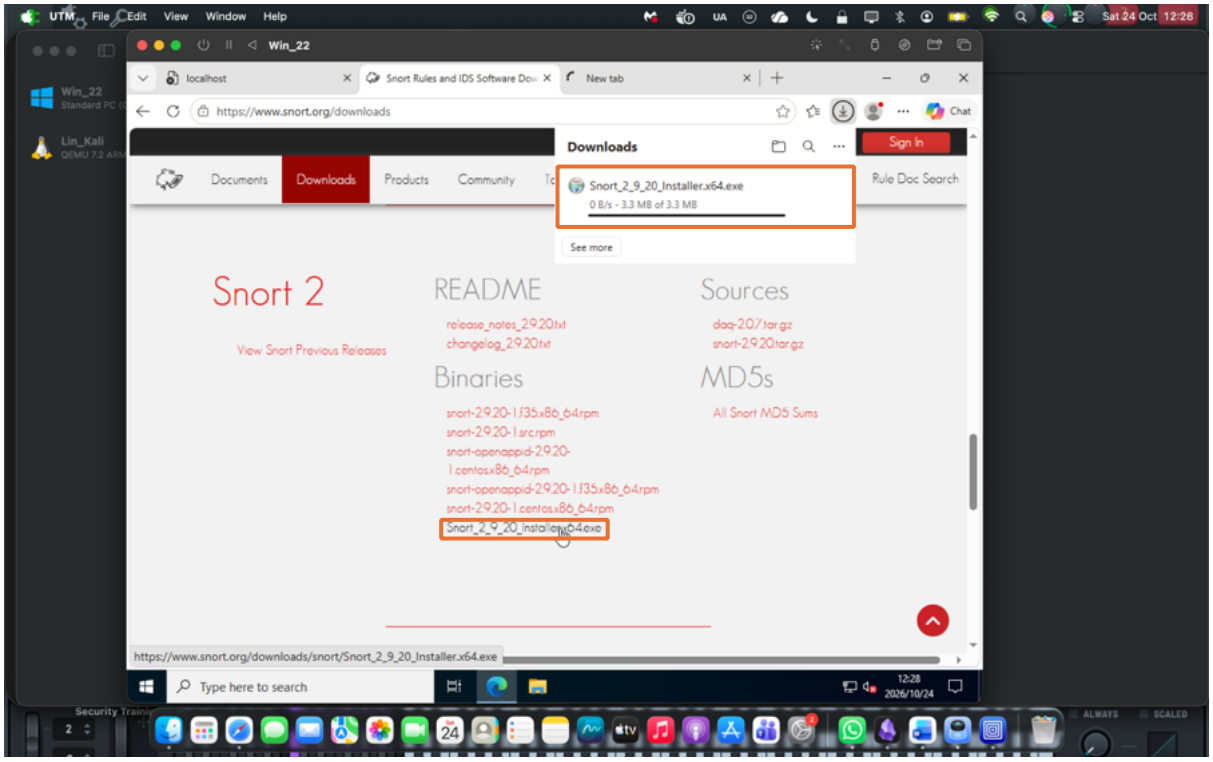
as well as information Disclosure (Services, Detection, Windows, Web Servers). To remediate them I would:

- Update SSH and Manually Disable Vulnerable Cipher for SSH (CVE-2023-48795).
- Block unauthorized access to administrative or Internal-Only management services, checking and disabling open ports while restricting access for firewall Openings(CVSS.6.5).
- Turning O‘ recuring for public addresses or limit strictly to internal local network clients with BIND DNS Server to prevent DDos attacks for DNS.
- And alter web server configuration so it does not broadcast descriptive operating system and software version in its HTTP headers e.g. nginx.conf with Nginx or httpd.conf / security.conf with Apache for Information Disclosure.

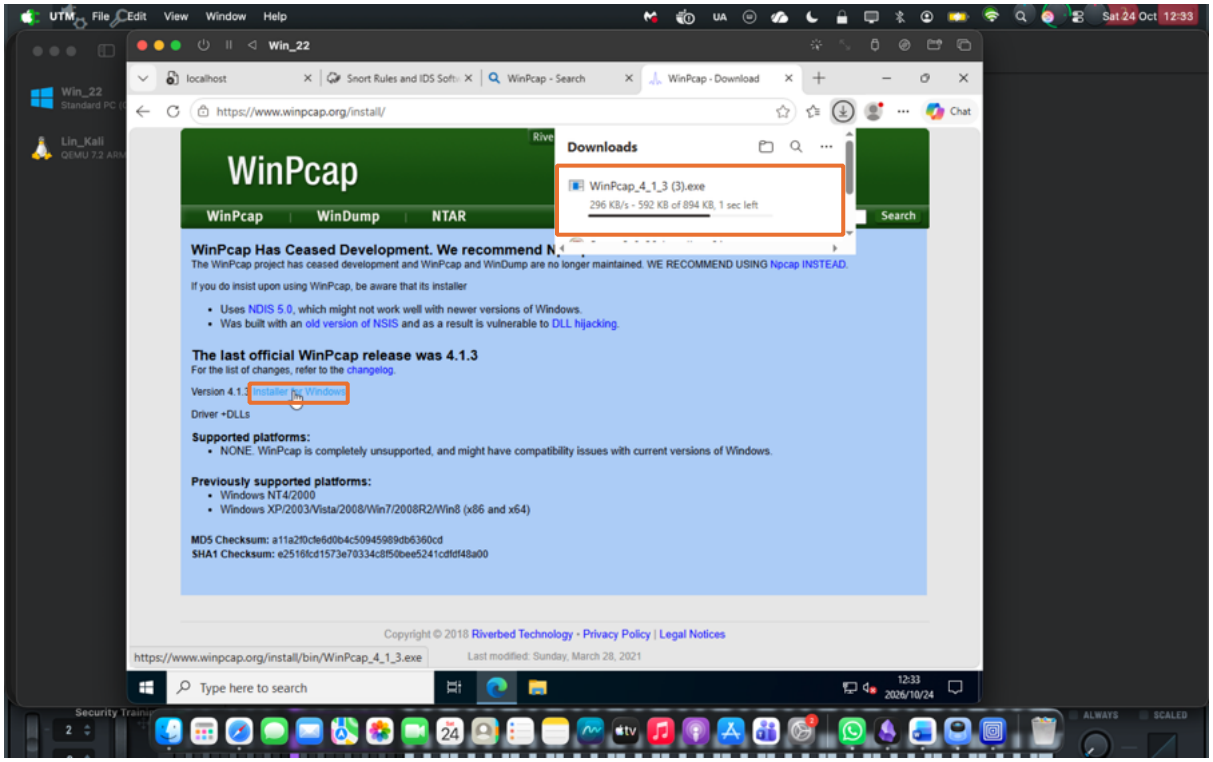
4.4 Explain how a vulnerability scan like this can be useful to a penetration test ?

- Vulnerability scans like this are useful for penetration testing as Manually checking thousands of network ports for known vulnerabilities takes an immense amount of time Nessus automates the scan in minutes.
- As well as Prioritization and Threat Modelling as scans are categorise by severity risks helping penetration testers focus on higher severity(Critical, High, Medium, Low, Info) like in our case Medium SSH Terrapin and Firewall CVSS6.5 configuration issue.
- Helping find potential Exploitation Entry Points, Eliminating Human Oversight like forgetting to check niche ports.
- And useful with Eliminating False Positives by having a Penetration tests Manually verify it the machine is actually vulnerable.

Question 5



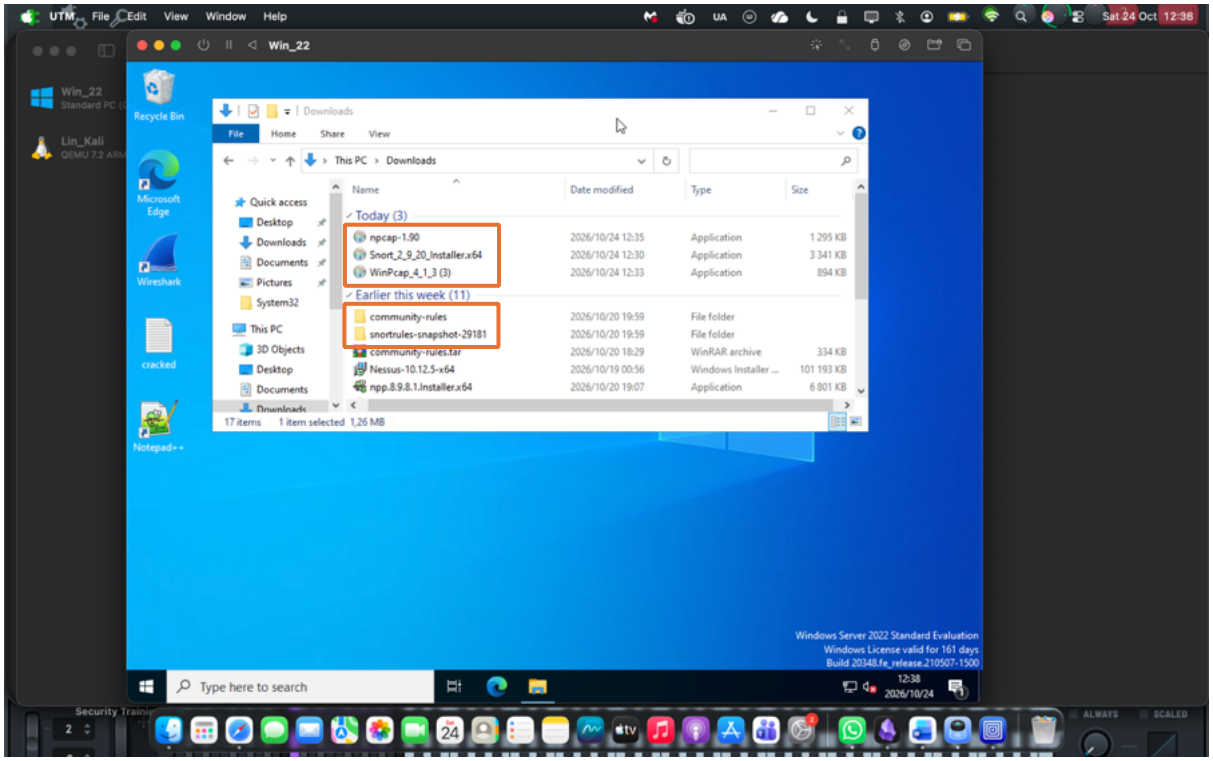
Installing Snort .



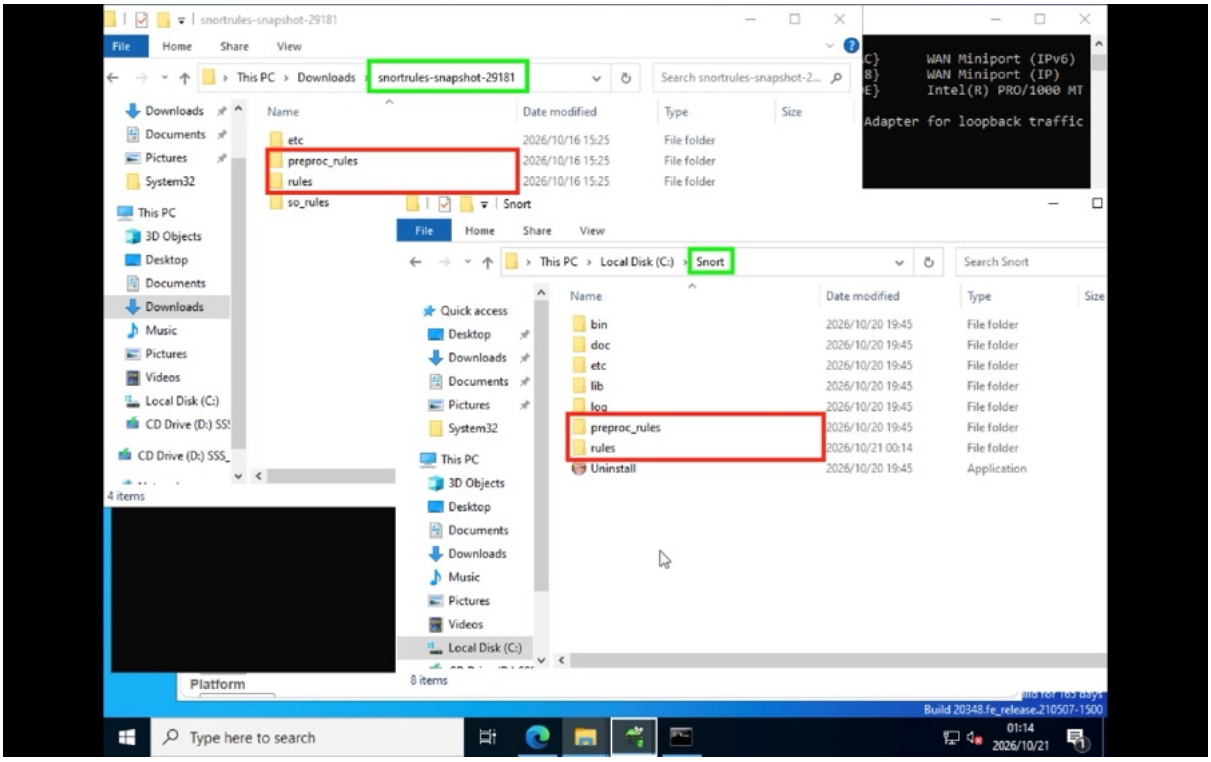
Installing WinPcap necessary for Snort.



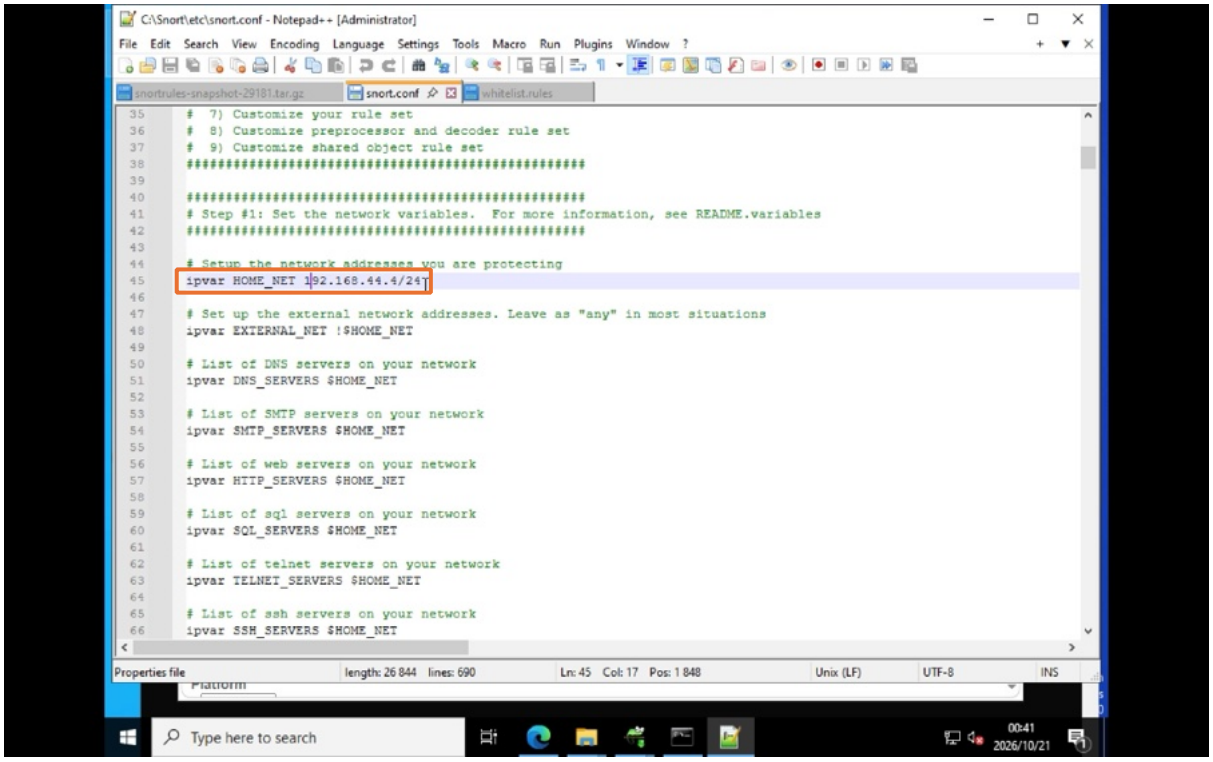
Installing Npcap necessary for Snort.



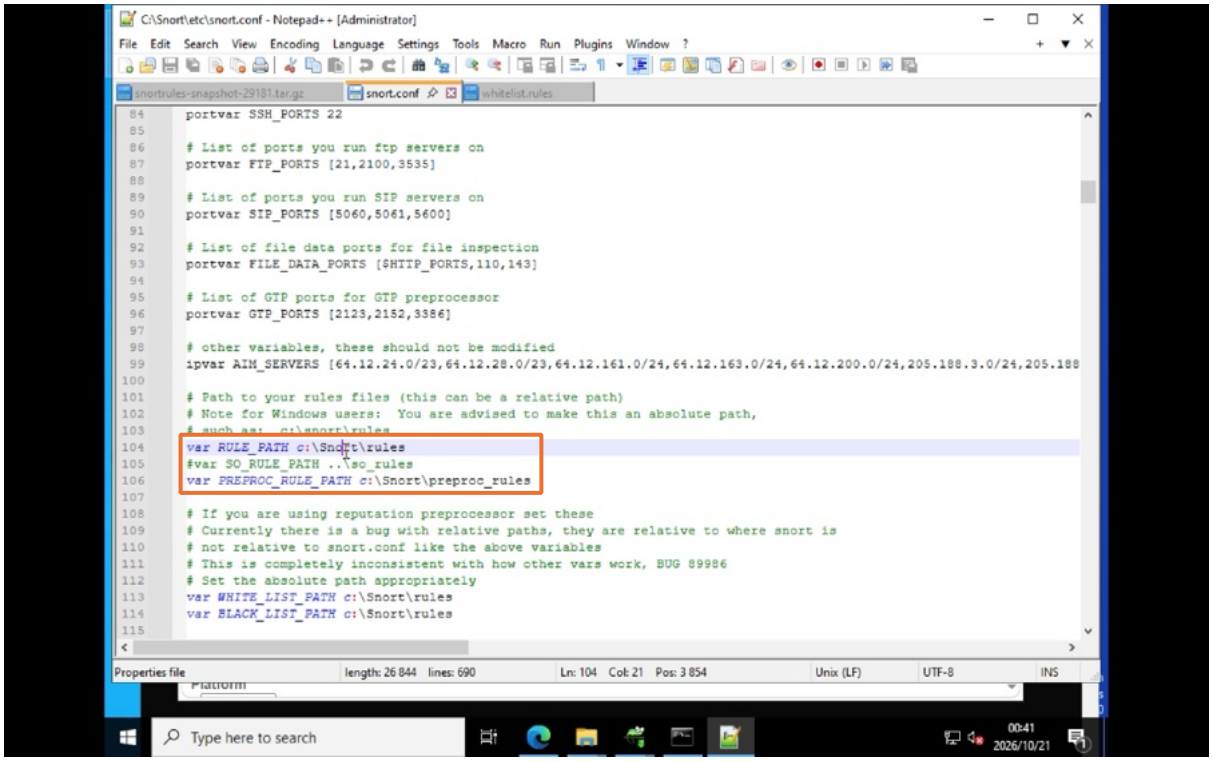
Installed files.



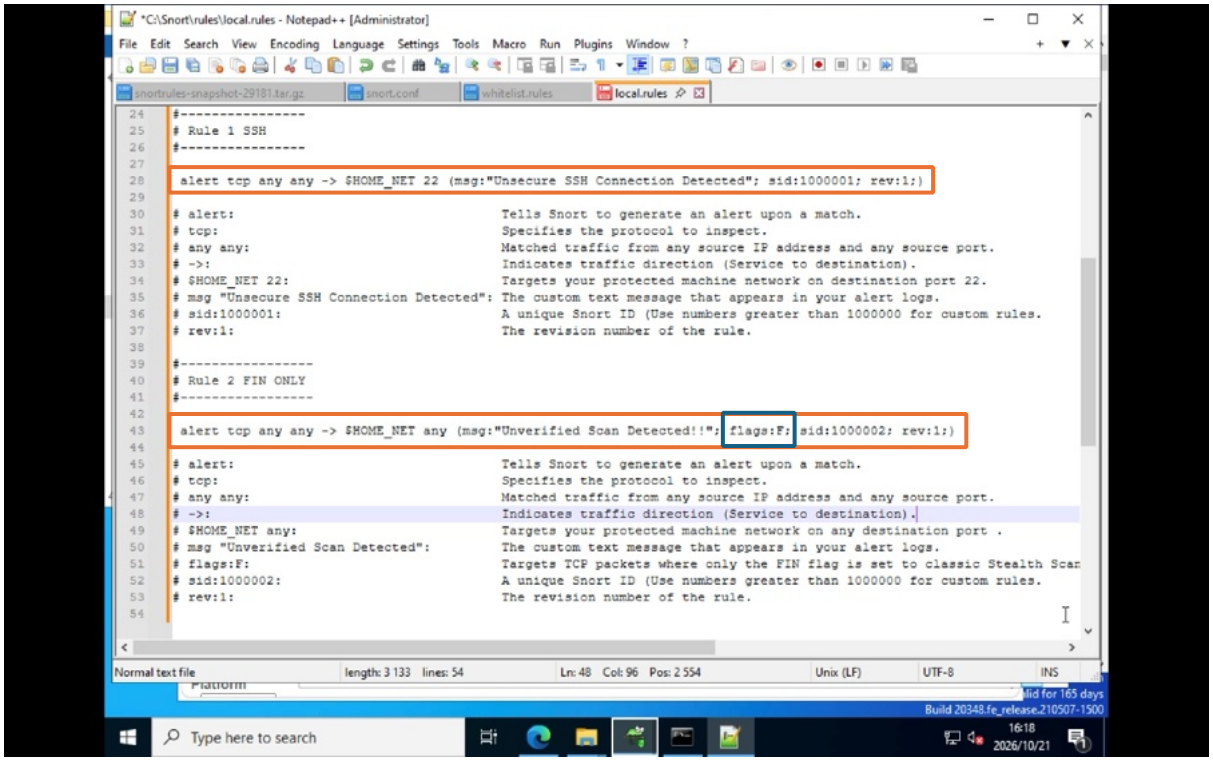
Copy Rule snort-rule folder “Preproc_rules” and “rules” to Snort folder.



Configuring the Home Network (HOME_NET) 192.168.44.0/24 in the snort.conf file.

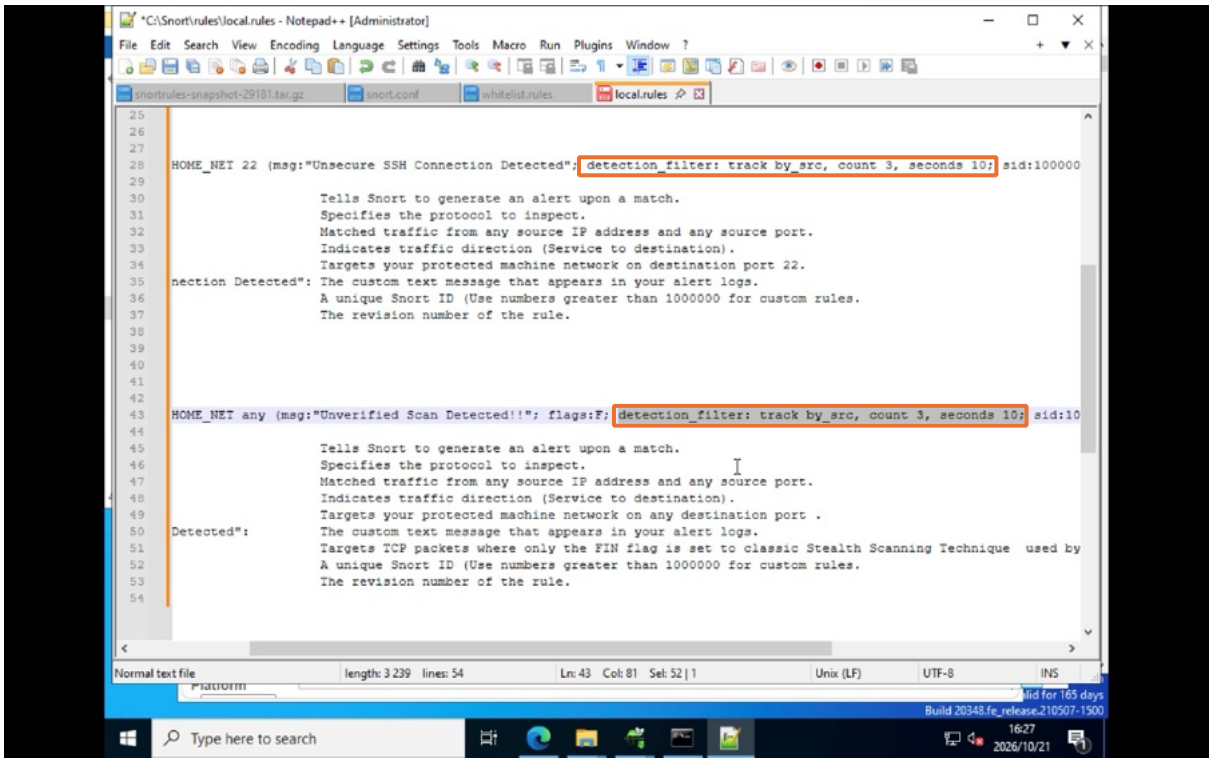


Configuring the file path to Snort Rules.

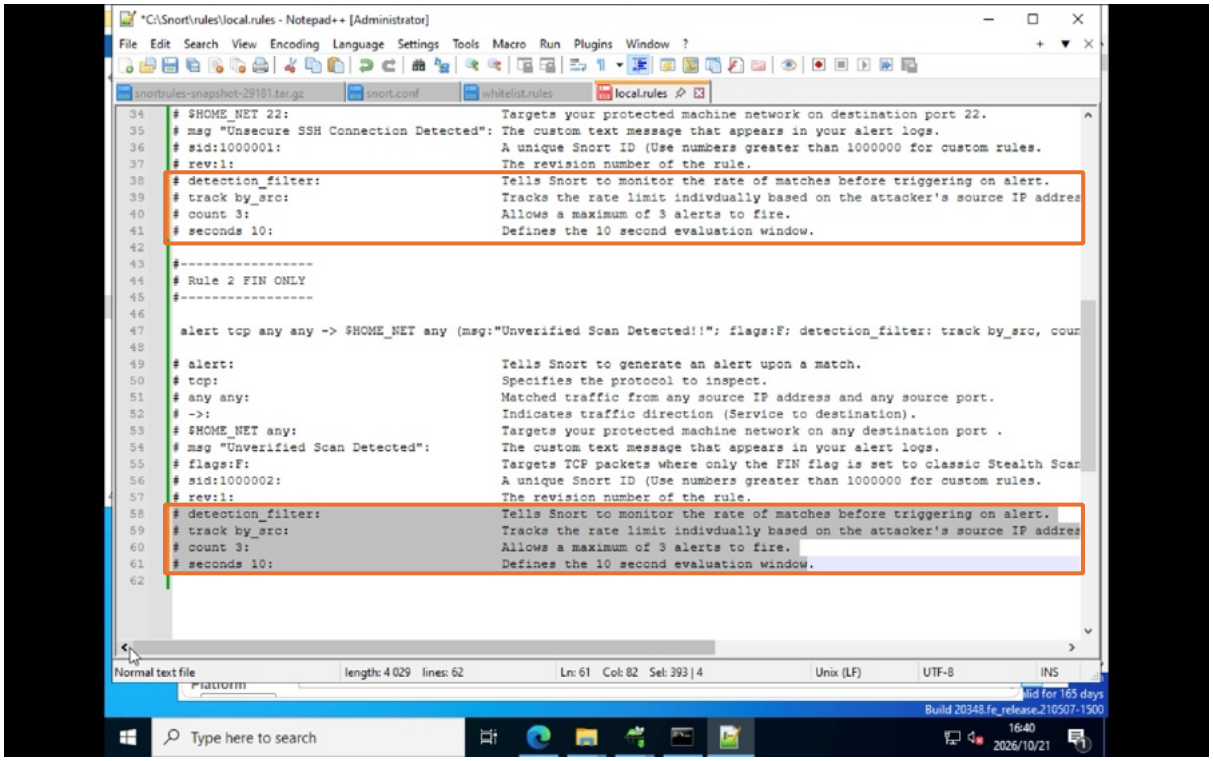


Creating an alert for any inbound TCP connection from any source IP address and any source port to the Win_22's IP address and SSH port. To alert message "Unsecure SSH Connectivity Detected!!".

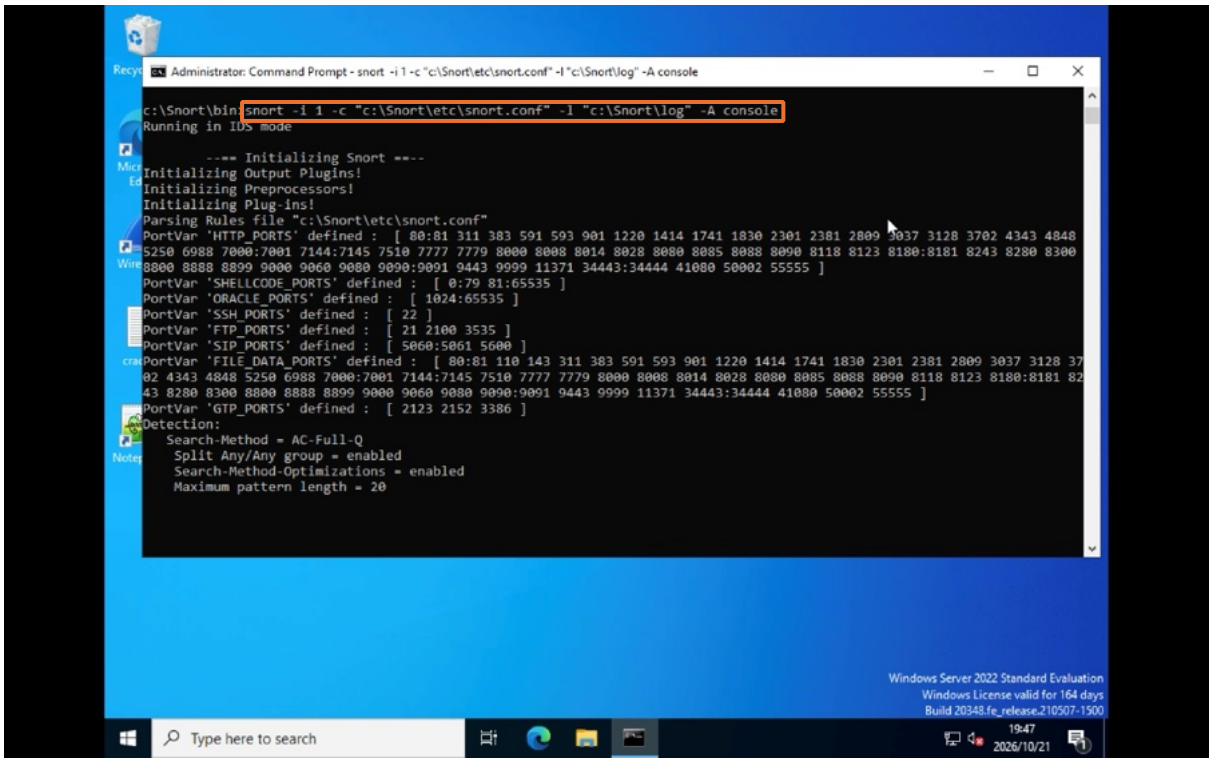
And Create an alert to detect scans coming from any IP and port to Win_22's network on any port with flag alert set to FIN only and having the alert display message "Unverified Scan Detected!!".



Setting Limit to the output of both rules to only show the first 3 alerts for every 10 seconds on "local.rules".

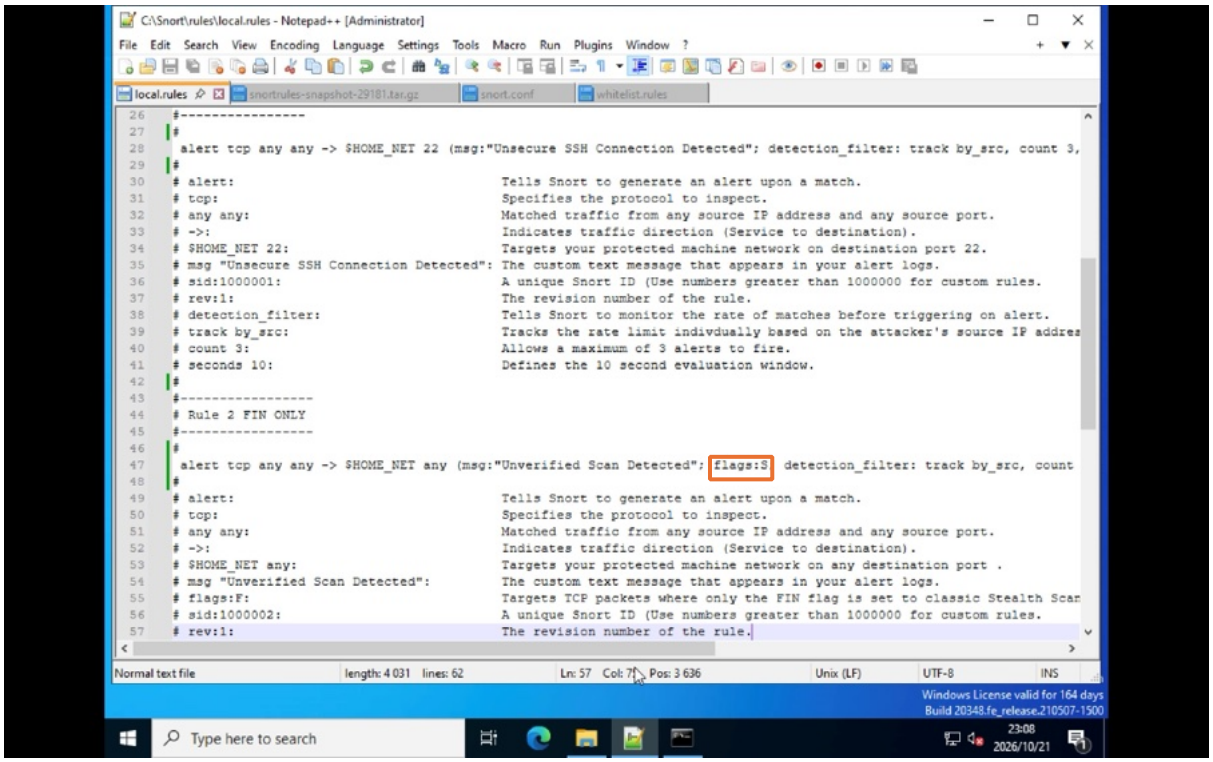


Notes for rules to only show the first 3 alerts for every 10 seconds on “local.rules”.

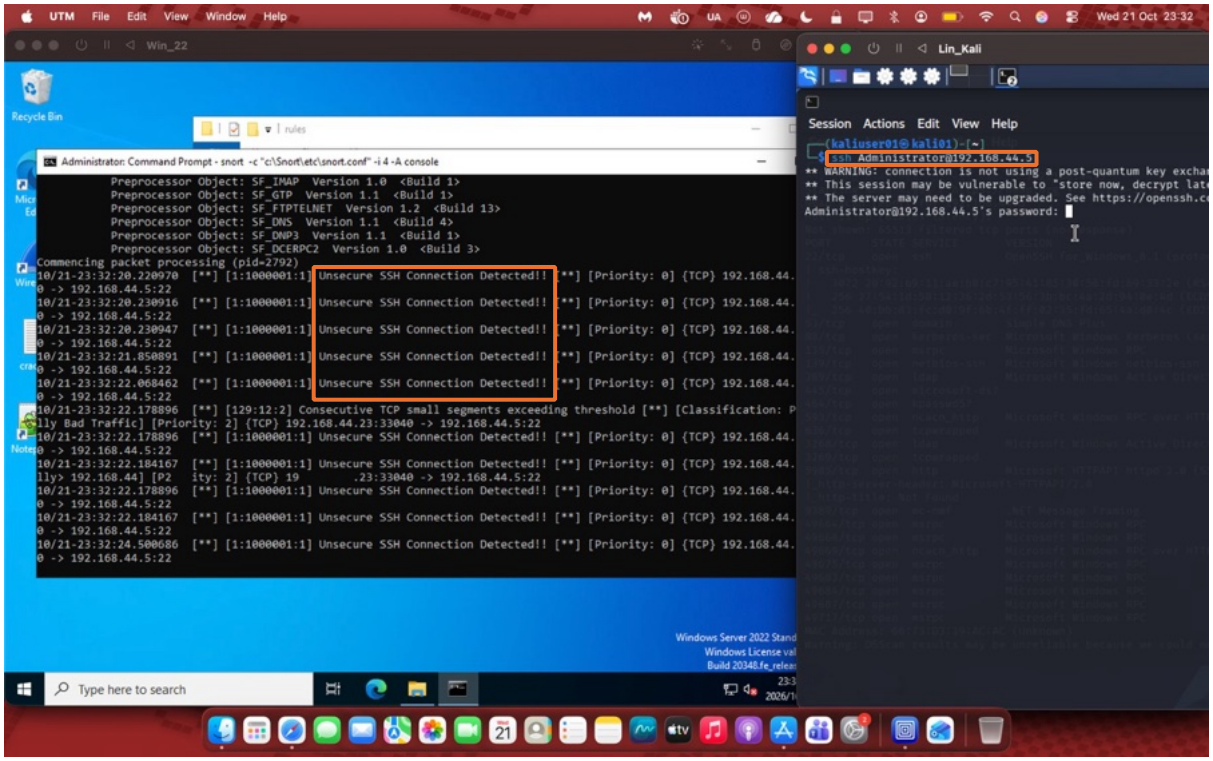


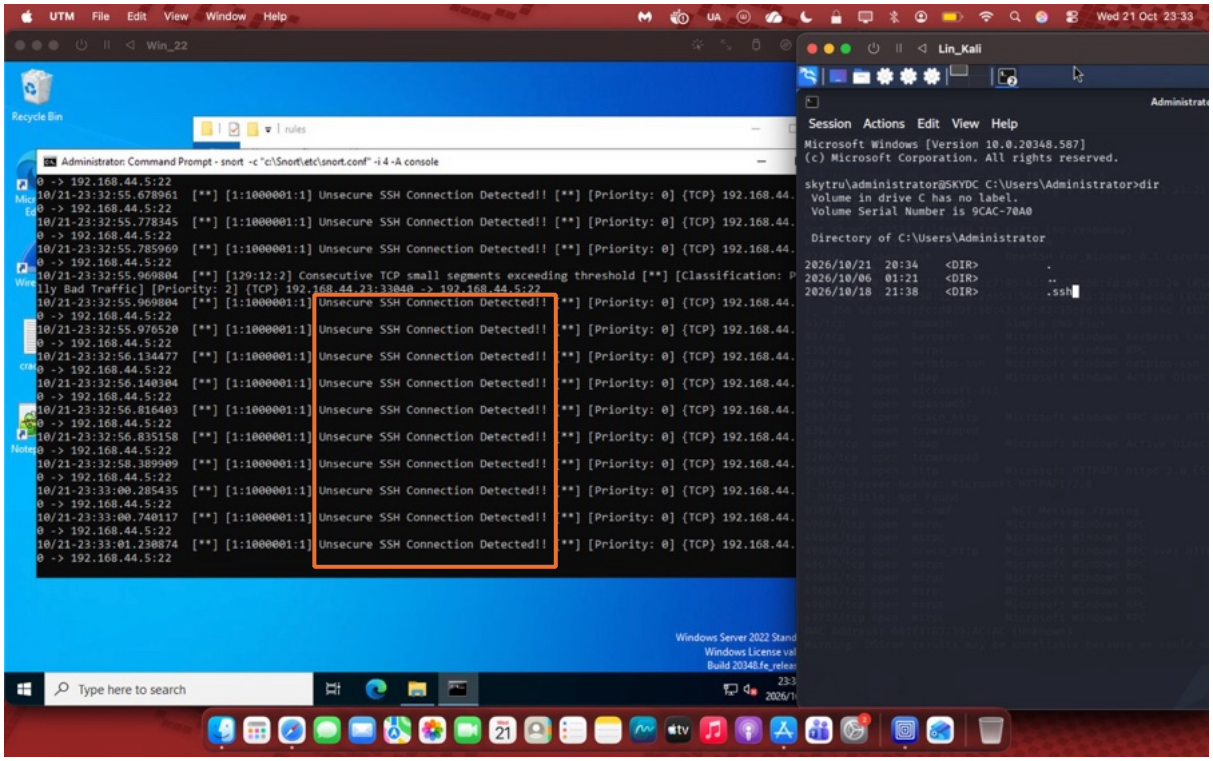
Running Snort to Capture Data.

NOTE: to get Snort to display message “Unverified Scan Detected !!” from Nmap Stealth Scan. I had to add a SYN “S” Flag instead of FIN “F” Flag.

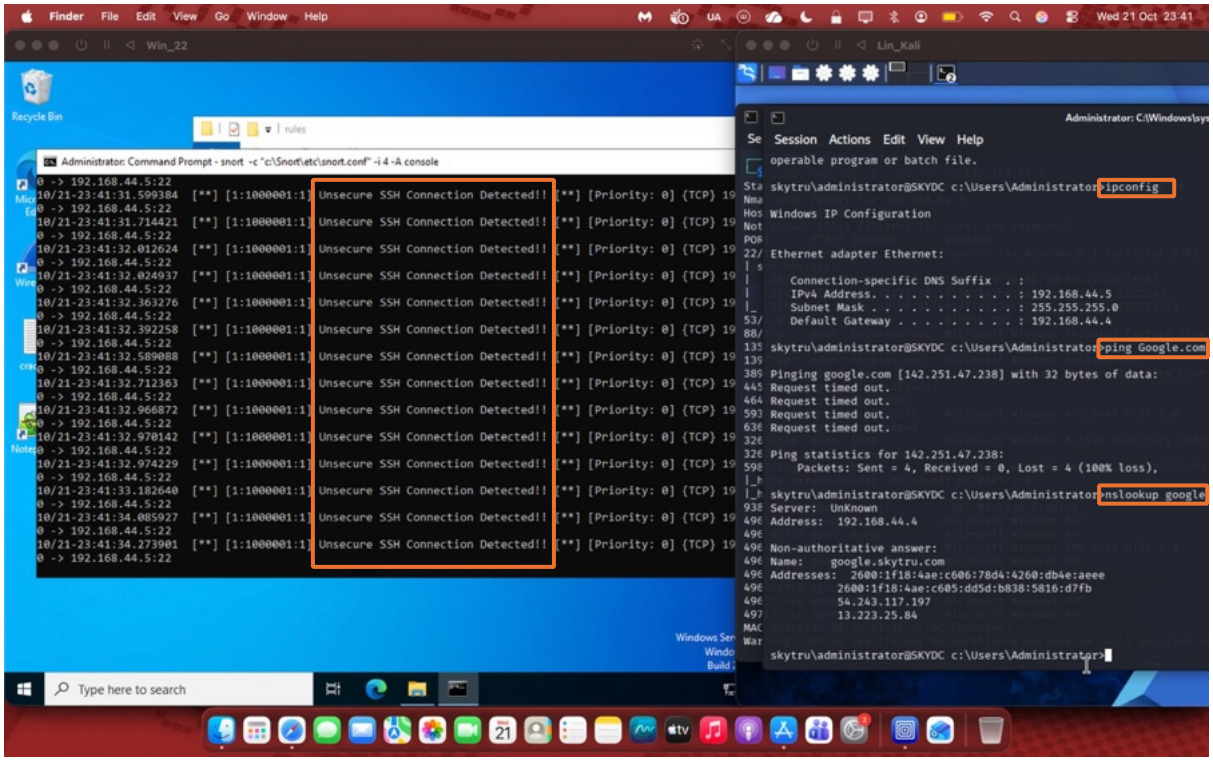


Adding S flag for SYN scan detection and message.

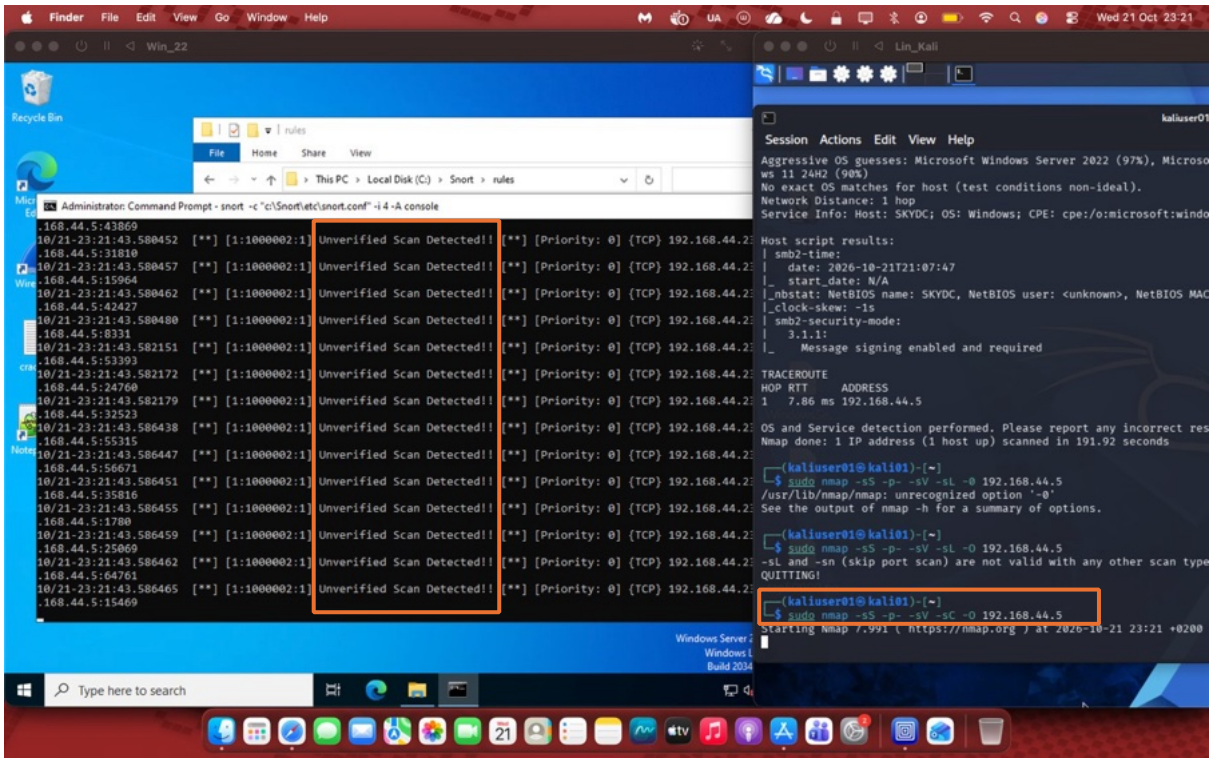




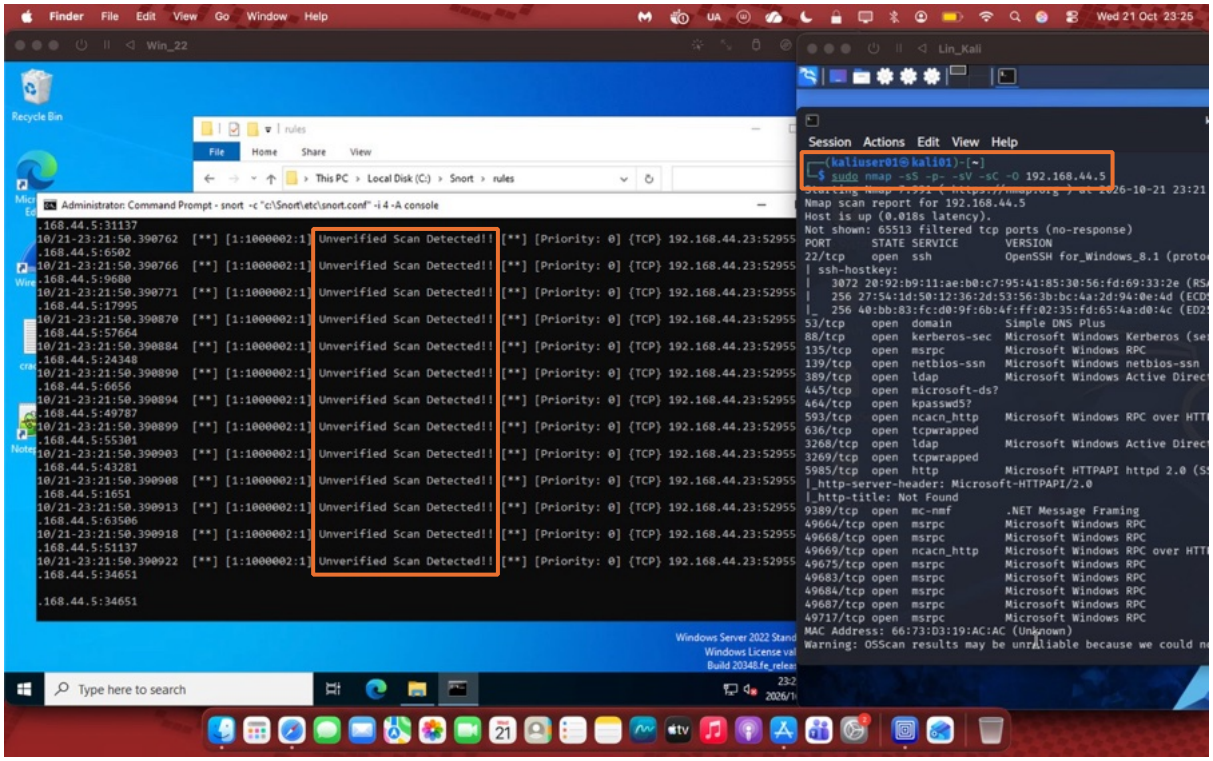
Establishing SSH session to Win_22 and viewing alerts display from Snort.



Running a few network commands in the session.



Performing a Full Nmap Scan on Win_22 and viewing alerts display from Snort.



Full Nmap Scan on Win_22 performed.